PSA
Nuts x AORTA/LSP

Datum:	06-02-2026
Status:	Concept / Vertrouwelijk
Versie:	0.1
Classificatie:	Klankboard document ter bespreking
Eigenaar:	xxx
Revisie:	

1 Wijzigingenblad 2
2 Inleiding 3
2.1 Context 4
2.2 Aanleiding 4
2.3 Doelstelling 5
2.4 Kaders 6
2.5 Deelnemers & Stakeholders 6
3 Voorgeschiedenis & aanpalende ontwikkelingen 6
3.1 Eerdere trajecten 7
3.2 Belangrijke besluiten uit het verleden 7
3.3 Aanpalende ontwikkelingen 7
3.4 Conclusies 9
4 Aanpak, fases en opzet 9
4.1 Aanpak 10
4.2 Toelichting fases 10
5 Nuts x AORTA/LSP – IST 11
5.1 Huidige situatie 12
5.2 Huidige technische architectuur 14
5.3 Knelpunten en beperkingen 15
6 Nuts x AORTA/LSP – SOLL 15
6.1 Gewenste situatie 16
6.2 Use case 18
6.3 Toekomstige situatie 18
6.4 Probleemomschrijving (Herbruikbaar vanuit Soll voor Generieke Use-Case) 19
6.5 Gewenste procesinrichting 27
6.6 Juridische uitgangspunten 32
6.7 Objectives 34
7 Requirements & onderzoeksvragen 34
7.1 Inleiding 35
7.2 Uitgangspunten en scope 35
7.3 Eisen aan de Harmonisatie 35
7.4 Eisen aan Lokalisatie 36
7.5 Eisen aan Identificatie 37
7.6 Eisen aan Authenticatie 39
7.7 Eisen aan Adressering 45
7.8 Open onderzoeksvragen & impactanalyse 46
8 Oplossingsrichtingen 48
8.1 Inleiding 49

8.2 Ontologie: partijen, rollen en relaties ... 49
8.3 Identiteitsmodel ... 52
8.4 Presentatie en verificatie ... 55
8.5 OAuth-profiel ... 56
8.6 Sleutelmateriaal en PKI ... 58
8.7 Adressering ... 59
8.8 Lokalisatie ... 60
8.9 Beantwoording onderzoeksvragen ... 61
8.10 Route 1: Nuts bevraagt LSP ... 61
8.11 Route 2: LSP bevraagt Nuts ... 61
8.12 Risico's en mitigaties ... 62
9 Begrippen en afkortingen ... 62
10 Bijlage 1: Technische Specificaties ... 63
10.1 Inleiding ... 64
10.2 Normatieve referenties ... 64
10.3 Cryptografische parameters ... 64
10.4 DID-documenten ... 66
10.5 VC-encoding ... 68
10.6 Credential-specificaties ... 70
10.7 Verifiable Presentations ... 77
10.8 Revocation ... 79
10.9 OAuth-profiel ... 81
10.10 Adressering ... 86
10.11 Voorbeelden ... 86

1 Wijzigingenblad

Versie	Datum	Omschrijving	Auteur
0.1			
0.2			
0.3			
0.4			
0.5			

2 Inleiding

2.1 Context

In 2023 sprak het Ministerie van VWS (hierna: VWS) de wens uit om Twiin, Nuts, LSP (VZVZ) en (optioneel) Zorgplatform met elkaar te verbinden, om zo de basis te leggen voor een landelijk dekkend netwerk – het Landelijk Dekkend Netwerk (hierna: LDN). VWS verzocht de betrokken partijen om, in lijn met deze wens, hun eigen initiatieven te formuleren.

Een belangrijke succesfactor voor het realiseren van het LDN is het onderlinge vertrouwen tussen de betrokken partijen: vertrouwen dat wordt omgezet in afspraken, juridische en technologische waarborgen en specificaties. In de loop van 2023/2024 zijn diverse projecten en programma's gestart om de stappen te definiëren (initiatieven, werkpakketten en benodigde afspraken) die moeten leiden tot een landelijk vertrouwensecosysteem – het Landelijk Vertrouwensstelsel (hierna: LVS).

Deze werkpakketten – waaronder de Interface Nuts x LSP x Zorgplatform – zijn vervolgens ondergebracht bij de VWS-programma's LDN en Implementatie Generieke Functies (IGF). Rond deze periode wees VWS ook Twiin aan als uitvoeringsorganisatie voor het LVS, later omgevormd tot het Programma Transitie Landelijk Afsprakenstelsel (LAS). Om die reden staat het project Koppeling Nuts x LSP in nauwe relatie tot Twiin/LAS en VWS.

2.2 Aanleiding

Actiz heeft sinds 2020 aandacht gevraagd voor de koppeling Nuts met AORTA/LSP. Toen reeds waren er plannen, maar die zijn om verschillende redenen niet ten uitvoer genomen. De wens voor een dergelijk koppeling is echter niet verdwenen. Vanuit AORTA zijn meerdere pogingen gedaan om dit onderzoek vlot te trekken.

In februari 2025 startte het Ministerie van Volksgezondheid, Welzijn en Sport (VWS) een Proof of Concept (PoC) met de titel PoC Nuts x LSP. Het primaire doel van deze PoC was het ontwerpen en testen van de technische infrastructuur die nodig is om gegevensuitwisseling tussen beide netwerken mogelijk te maken, met gebruikmaking van de Generieke Functies (GF's).

Kort na de start van de PoC sprak het regionale netwerk REN West-Brabant de ambitie uit om verder te gaan dan een puur experimentele opzet en een oplossing te realiseren die geschikt is voor productiegebruik. Hierdoor werd de scope van het project verbreed: naast een PoC werd ook een pilotfase toegevoegd.

Tijdens de opstartfase ontwikkelden architecten van Twiin, Nuts, VWS en VZVZ gezamenlijk een Project Start Architectuur (PSA). Uit deze architectuuranalyse kwamen verschillende knelpunten naar voren die verdere uitwerking en besluitvorming vereisten. De ambitie om op korte termijn richting productie te bewegen bracht extra complexiteit met zich mee:

- architectuuroplossingen moesten binnen beperkte tijd een hoger volwassenheidsniveau bereiken;
- enkele noodzakelijke componenten (zoals onderdelen van de Generieke Functies) bevonden zich nog in de ontwerpfase en zouden binnen de beschikbare tijd niet de benodigde productievolwassenheid kunnen bereiken.

Op basis van deze bevindingen concludeerden VWS, Nuts en VZVZ (namens Twiin en LSP) gezamenlijk dat het te complex was om zowel de volledige toepassing van de Generieke Functies uit te werken als deze oplossingen binnen korte tijd in productie te brengen. Daarom werd besloten het initiatief op te splitsen in twee complementaire, parallelle en convergerende trajecten:

- Een kortetermijnproject - Interface Nuts x LSP (door Nuts and VZVZ) - Gericht op het op korte termijn mogelijk maken van gegevensuitwisseling tussen Nuts en LSP, geschikt voor gebruik in zowel pilot- als productieomgevingen.

- Een langetermijnproject - (PoC 12 LSP x VVT (door VWS) - Gericht op het verder uitwerken van de toepassing van de Generieke Functies, voortbouwend op en uitbreidend ten opzichte van de kortetermijnoplossing, en aansluitend bij toekomstige ontwikkelingen.

2.3 Doelstelling

Dit project heeft als doel:

- een ontwerp te maken van een bi-directionele koppeling tussen AORTA/LSP en Nuts inclusief de mogelijkheid om gespreid bevragen door AORTA/LSP;
- met draagvlak binnen Nuts en VZVZ en in lijn met landelijke ontwikkelingen zoals Twiin en LDN (VWS);
- de koppeling te realiseren met leveranciers en beproeven in een test- en later in een productieomgeving om bevindingen en aanbevelingen te verzamelen;
- Het creëren van de randvoorwaarden om verdere uitrol mogelijk te maken;
- Het uitwerken van een vertrouwensmodel op basis van Twiin of AORTA op welk de uitwisseling plaatsvindt;
- om zo tot een blijvende gegevensuitwisseling van een concrete bestaande zorgtoepassing te komen.

2.3.1 Beoogde resultaten

Het project streeft de volgende resultaten na:

- Een ontwerp en realisatie van de koppeling tussen Nuts en LSP conform gestelde randvoorwaarden dat wordt gedragen door VZVZ en Stichting Nuts. Dit omvat onder meer:
    - een werkende bi-directionele koppeling tussen Nuts en het LSP;
    - het LSP is in staat om op Nuts aangesloten zorgaanbieders te bevragen middels een gespreide bevraging (agnostisch)
    - het vertrouwen is uitgewerkt in een release candidate (beproefde bèta versie) die opgenomen is/wordt in het Twiin of AORTA Afsprakenstelsel
    - een gewijzigde infrastructuur van AORTA/LSP en Nuts
    - een werkend Nuts-GtK in productie

- We volgen het volwassenheidsmodel; ontwerpkeuzes leggen we voor aan relevante stakeholders.
    - opgehaald tijdens drie klankbordsessies gedurende het project met bijzondere aandacht voor effecten op processen, infrastructuur en governance, en inbreng vanuit Twiin standaardisatie.
    - inclusief het formuleren en uitzetten van eventuele vervolgacties (bij Nuts- of VZVZ-collega's) om impact te mitigeren t.b.v. de pilot en latere release, of om draagvlak te vergroten onder stakeholders.
    - het bespreken van ontwerpkeuzes tijdens de TPA
    - afstemming met relevante projecten, uitwerkingen en realisaties van onder andere Twiin, VWS (LDN, PoC 12 LSPxVVT, DEZI).

- Een beproeving van het gerealiseerde ontwerp waarbij bevindingen en aanbevelingen zijn opgehaald ter verbetering van het ontwerp middels:
    - het uitvoeren van een tweetal PoC's (NUTS bevraagt LSP, LSP bevraagt NUTS) in een referentieomgeving;
    - het uitvoeren van een tweetal pilots (NUTS bevraagt LSP, LSP bevraagt NUTS) in een productieomgeving met eindgebruikers en een concrete zorgtoepassing met speciale aandacht voor de verificatie van juridische, technische en functionele randvoorwaarden, en logging, toestemming, governance en vertrouwen.

- Een rapportage van bovenstaande beoogde resultaten met daarin een verslag van
    - het uitgevoerde project, bevindingen en aanbevelingen en behaalde resultaten
    - gerealiseerde ontwerpen met benodigde toelichting

- aanbevelingen voor besluitvorming over landelijke uitrol en structurele borging van de gerealiseerde gegevensuitwisseling
- indien pilots worden doorgeschoven naar een separaat project: voorstel voor doorontwikkeling richting tweerichtingsverkeer.

2.4 Kaders

2.4.1 Uitgangspunten

- Leveranciers worden betrokken gedurende het project. In de PoC fases kan dit nog in mindere mate zijn om snelheid te maken. Tijdens de pilot is dit afhankelijk van de aangemelde samenwerkingsverbanden (uit het veld) die willen deelnemen aan de pilots
- Onderzocht wordt hoe we verder samen werken met Twiin en hoe we het vertrouwensmodel anders of aanvullend kunnen vormgeven, zodat beide trajecten goed op elkaar aansluiten.

2.4.2 Randvoorwaarden

- We ontwikkelen op onze eigen kracht en op ons eigen tempo. Dat betekent dat we aansluiting zoeken bij landelijke initiatieven maar ons daar niet afhankelijk van maken.
- De koppeling voorziet in bi-directioneel verkeer tussen Nuts en AORTA. De koppeling is use case agnostisch. De gehanteerde use cases in de pilots worden afgestemd met de deelnemende partijen aan deze pilots.
- Nuts en LSP worden gekoppeld via een in dit project te ontwikkelen boven op de bestaande LSP-GtK die communiceert met een Nuts-GtK (dat kunnen er meerdere zijn).
- Nuts en VZVZ werken gezamenlijk in een multidisciplinair team, waarbij beide organisaties expertise en capaciteit inbrengen. Hierdoor is gewaarborgd dat de benodigde kennis op het juiste moment beschikbaar is om inhoudelijke en organisatorische vraagstukken adequaat te adresseren.
- We conformeren ons aan landelijke ontwikkelingen zoals het werkpakket LDN Nuts x AORTA/LSP
- Waar generieke functies beschikbaar zijn, worden deze benut, zo lang als dit de voortgang en uitvoerbaarheid van het project niet onevenredig belemmert

2.4.3 Buiten scope

- De ontwikkeling van nieuwe zorgtoepassingen
- Opschaling naar productie
- Uitbreiding met patiënt perspectief

2.5 Deelnemers & Stakeholders

Stakeholder	R	A	S	C	I	toelichting
Stichting Nuts	●	●				Trekkers project
AORTA/ZORG-ID (VZVZ)	●	●				Trekkers project
Itzos			●	●		Leverancier van VZVZ
AET Europe			●	●		Leverancier van VZVZ
Het Ministerie van VWS				●	●	Organiseert aanverwante projecten
Twiin (VZVZ)	(●)		(●)	●	●	Stelsel waar oplossing in zou moeten passen
Stichting Gemeenschappelijke Voorzieningen voor Zorgcommunicatie (GVvZ)			(●)	●	●	
Management/Directie VZVZ					●	
Overige VZVZ-afdelingen			(●)	●	●	
Zorgaanbieders	●			●	●	Deelnemer Pilots
Leveranciers	●			●	●	Deelnemer Pilots (en PoC's)
Zorgverzekeraars Nederland (ZN)					●	Financier VZVZ
ActiZ (en andere branchorganisaties/koepels)					●	Vertegenwoordigen zorgaanbieders

3 Voorgeschiedenis & aanpalende ontwikkelingen

3.1 Eerdere trajecten

Na het verzoek van Actiz aan VZVZ is dit project lang op de bestuurlijke tafels blijven liggen, omdat een oplossing niet direct voor handen leek te liggen. Ook tijdens de COVID-periode zijn verschillende opties ter realisatie besproken.

Er zijn verschillende trajecten doorlopen, zoals:

- Twiin formaliseert het koppelen van afsprakenstelsels. Twiin is echter nog niet ver genoeg om daadwerkelijk te koppelen. Wel is er door Twiin een onderzoek gedaan tot de vereisten voor landelijke gegevensuitwisseling en de route die Nuts moet doorlopen om aan deze eisen te voldoen.
- Het project 'Generieke Functies' heeft zich gericht op de adressering. Ook is er gewerkt aan de 'TA (Technical Agreement) notified pull, waarbij VC's van Nuts worden ingezet.
  Voor Adressering is er in 2024 een hackathon Nuts x LSP geweest.

3.2 Belangrijke besluiten uit het verleden

'Voortborduren op beslissingen die in het verleden genomen zijn'. Het aansluiten van afsprakenstelsels op Twiin heeft als doel om gedane investeringen niet te vernietigen, maar juist in te zetten om verder te groeien.

Uitgangspunt is dat de GtKen (Gekwalificeerde Twiin Knooppunten) de 'verschillen' tussen de afsprakenstelsels overbruggen. Één onderwerp laat zich echter niet overbruggen en dat is het 'Vertrouwen'. Omdat alle deelnemende afsprakenstelsels binnen Twiin hiervoor een oplossing nodig hebben, is ervoor gekozen voor een duale oplossing: binnen het afsprakenstelsel wordt gebruik gemaakt van de 'eigen' afspraken, maar voor communicatie via Twiin, zullen voor de deelnemers (zorgaanbieders) generieke VCs worden uitgewisseld (basis bouwblokken), die per use-case (toepassing) worden gedefiniëerd. De invulling van de VC's is erop gericht ze in alle contexten te kunnen toepassen, zowel binnen een afsprakenstelsel als daarbuiten.

De ambitie om het netwerk van NUTS te koppelen aan het AORTA Afsprakenstelsel via het Landelijk Schakelpunt (LSP) is niet nieuw. In een eerder stadium is tijdens een designathon al verkend hoe dit kan. Deze verkenning is de eerste aanzet geweest tot een technisch en functioneel haalbaarheidskader. Hierbij wordt via GtKen gecommuniceerd, zodat 'later' ook andere afsprakenstelsels op gelijke wijze kunnen worden gekoppeld.

Belangrijke conclusies uit hackathon Nuts x LSP. De VC-adressering zou uitgegeven kunnen gaan worden door ZORG-AB, zolang het 'Landelijke Adresboek' nog niet beschikbaar dan wel gevuld is.

Twiin wordt de landingsplaats voor afspraken over de afsprakenstelsels heen.

Het gebruik van Generieke Functies wordt door Twiin, Nuts én AORTA bevorderd, maar zal niet dwingend zijn als deze (nog) niet op het noodzakelijke niveau beschikbaar zijn

In de aanloop naar dit project heeft afstemming op hoofdlijnen plaatsgevonden met architecten van zowel VZVZ als NUTS en Twiin. Op basis van deze gesprekken en de eerder uitgevoerde designathon is vastgesteld dat een koppeling tussen NUTS en het LSP technisch haalbaar lijkt.

3.3 Aanpalende ontwikkelingen

Om tot een duurzame oplossing te komen wordt afstemming en aansluiting gezocht bij landelijke ontwikkelingen.

3.3.1 Samenhang en afhankelijkheden

Vanuit het Landelijk Vertrouwensstelsel (LVS) is een werkpakket gedefinieerd dat voorziet in het aan elkaar koppelen van de infrastructuren van NUTS en LSP. Dit werkpakket is nu in beheer bij het Landelijk Dekkend Netwerk. Het LDN is voornemens om het werkpakket op te gaan pakken na afronding van het werkpakket Veilig Netwerk. De te realiseren koppeling zal in het kader van dit werkpakket worden uitgevoerd. Hierbij zal de uitwisseling tussen de twee infrastructuren gebeuren op basis van de Gevalideerd Twiin Knooppunt (GtK) route waarbij het vertrouwen door het Twiin afsprakenstelsel wordt geleverd.

Een belangrijk deel van het koppelen van NUTS en AORTA/LSP, is de identificatie en authenticatie (I&A) van de zorgaanbieder en de zorgverlener. Hier is het team Generieke Functies (GF) van VWS mee bezig onder de naam Dé Zorgidentiteit, afgekort DEZI. DEZI wordt door VWS ontwikkeld om zorgverleners en -aanbieders in het gehele zorgveld de mogelijkheid te bieden zich veilig en betrouwbaar te identificeren en authenticeren.

Samen met betrokken architecten van GF, VZVZ (AORTA/LSP en Twiin) en NUTS is een PoC gedefinieerd om de randvoorwaarden voor I&A en andere generieke functies verder uit te werken. Ook Twiin is hierbij betrokken. Binnen dit project worden generieke functies, zoals DEZI, lokalisatie, autorisatie, adressering en logging, benut en, waar nodig, verder doorontwikkeld om ze geschikt te maken voor deze specifieke koppeling en toekomstige herbruikbaarheid. Deze PoC kent meerdere benamingen zoals PoC LSPxNUTS, PoC LSPxVVT. Wij noemen hem hier PoC DEZI.

Onder regie van Twiin wordt gewerkt aan een Technical Agreement voor Pull-uitwisselingen (TA Pull), waarbij ook VZVZ actief is betrokken. Een van de onderwerpen binnen deze TA Pull is I&A.

Er is nog weinig zicht op definitieve tijdslijnen van de genoemde initiatieven. Mogelijk lopen de agenda's voor op die van Twiin en het LDN. Zowel vanuit Twiin als vanuit VWS LDN is mondeling aangegeven dat men bereid is samen te werken. Hierdoor kan het voorkomen dat projecten beide ontwikkelingen in een ander tempo worden vormgegeven, maar later zullen worden samengevoegd voor het beoogde eindresultaat.

3.3.2 Afstemming met andere ontwikkelingen

Afstemming tussen deze projecten vindt continu plaats:

- De **PoC 12 LSP x VVT** (VWS) beproeft de generieke functies toepast op een koppeling tussen het Nuts-netwerk en het LSP voor de toekomstige situatie waar landelijk wordt gewerkt met de generieke functies. Dit project voor de Koppeling Nuts x LSP is de opmaat naar deze toekomstige situatie. Met deze PoC vindt directe coördinatie plaats binnen het Nuts x LSP-projectteam, waarvan de teamleden ook deelnemen aan PoC LSP x VVT.
- Met **Twiin** (en haar werkgroepen omtrent de Technical Agreement Notified Pull (TA NP)) om te zorgen dat de koppeling zo veel mogelijk berust op concepten uit, geschikt voor of in lijn met het Twiin Afsprakenstelsel. Deze koppeling kan daarmee op termijn worden ondergebracht in Twiin en later in het Landelijk Afsprakenstelsel.

Met Twiin en VWS organiseren we wederzijdse reviews van specificaties met als doelstellingen:

- het voorkomen van desinvesteringen,
- het waarborgen van architecturale consistentie, en
- het vaststellen van een duidelijke groeilijn van Nuts x LSP, naar LSP x VVT, en uiteindelijk richting de LAS.

Ook volgen we de ontwikkelingen bij Nictiz over de Informatiestandaard Lokalisatie. Deze standaard is nodig om lokalisatiegegevens tussen Nuts en AORTA te kunnen uitwisselen zodat de zorgaanbieders met gegevens van de patiënt kunnen worden gevonden.

3.4 Conclusies

Het project Nuts x AORTA/LSP zal de verbinding leggen tussen beide afsprakenstelsels op basis van de huidige mogelijkheden, waarbij de resultaten van dit project zullen worden afgestemd en vastgelegd binnen het Twiin-afsprakenstelsel.

Gezien de wens tot realisatie van een oplossing én het inzicht dat vertrouwen zich niet laat vertalen is ervoor gekozen voor het onderwerp Identificatie en Authenticatie, waaronder ook de waarborgen voor gegevensuitwisseling vallen, om een generieke afspraak voor I&A op te stellen voor zowel Nuts als AORTA, waar bij stelsels een hybride vorm van afhandeling van waarborgen zullen gaan bevatten.

Deze generieke afspraak voor I&A is een infrastructurele afspraak, dus onafhankelijk van welke zorgtoepassing dan ook.

4 Aanpak, fases en opzet

GtK
In dit document bedoelen we met een GtK de infrastructurele component. Als deze niet gevalideerd is op het moment van oplevering, dan is er vanuit LSP-perspectief sprake van een Goed Beheerde Connector (GBC).

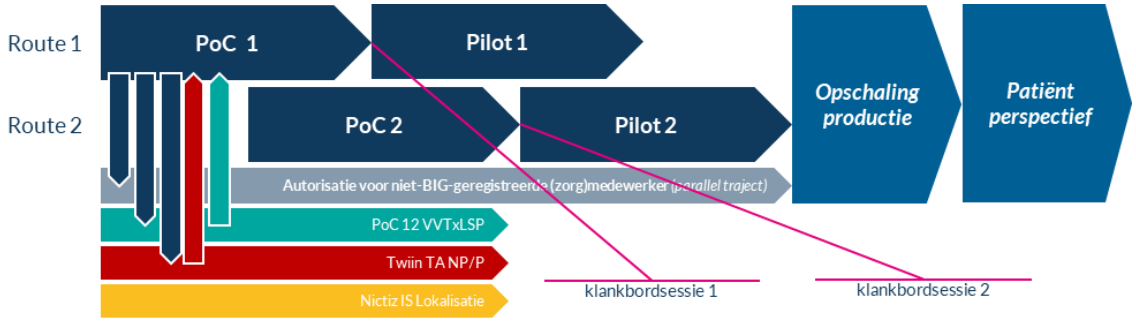
4.1 Aanpak

Tijdens de ontwikkeling van de koppeling is de stip op de horizon dat de communicatie via een Gevalideerd Twiin Knooppunt (GtK) verloopt. Daarom bouwen we vanuit het LSP boven op onze bestaande LSP-GtK. Nuts ontwikkelt aan haar open-source component waarbij deze onderdeel kan zijn van een Gevalideerd Twiin Knooppunt.

We specificeren en bouwen tegelijkertijd. Zowel aan de Nuts kant als aan de kant van het LSP. We werken kort cyclisch en directief. Sourcing partners zijn onderdeel van het ontwikkelteam. De realisatie van de koppeling tussen Nuts en LSP verloopt gefaseerd. Zo verhogen we stapsgewijs de volwassenheid van de oplossing. We hanteren twee routes voor de gegevensuitwisseling, en meerdere fases voor de uitvoering.

4.1.1 Routes & fasering

- Route 1: Nuts bevraagt LSP
- Route 2: LSP bevraagt Nuts



De uitvoering ziet er als volgt uit:

- Het voortbrengingsproces wordt gevolgd met behulp van expertsessies, klankbordgroep, PoC en Pilots.
- Het project kent de volgende fasen:
  - PoC 1 - NUTS bevraagt het LSP (in afronding)
  - Pilot 1 - NUTS bevraagt het LSP
  - PoC 2 – LSP bevraagt NUTS
  - Pilot 2 – LSP bevraagt het LSP
  - Vertrouwensmodel
  - Autorisatie niet-BIG geregistreerden
- Om tot een duurzame oplossing te komen wordt afstemming en aansluiting gezocht bij landelijke ontwikkelingen:
  - PoC 12 VVTxLSP
  - Twiin TA NP
  - Nictiz ontwikkeling informatiestandaard lokalisatie
- Fasen kunnen parallel verlopen. We streven ernaar dat hierdoor geen dubbel werk ontstaat.
- Als vervolg zien wij 1) opschaling naar productie en 2) uitbreiding van LSP+ om bevraging door de patiënt via het LSP mogelijk te maken.

4.2 Toelichting fases

De realisatie van de koppeling tussen Nuts en LSP verloopt gefaseerd. Zo verhogen we stapsgewijs de volwassenheid van de oplossing. Hiervoor passen we het Voortbrengingsproces toe.

4.2.1 Voortbrengingsproces (volwassenheidsmodel)

Om duurzame oplossingen te bouwen is het noodzakelijk die tijdens de verschillende fasen voor te leggen aan relevante stakeholders waaronder leveranciers, zorgaanbieders, koepels, VWS, Twiin etc. Wij hanteren de volgende methodiek:

- Expertsessies: tijdens het TPA bespreken we de ontwerpen met leveranciers;
- Klankbordsessies: een afspiegeling van relevante stakeholders geeft feedback op het functioneel en technisch ontwerp tijdens/na de PoC en Pilot fases.
- PoC's: beproeving van de koppeling in een referentieomgeving.
- Pilot: beproeving van de koppeling in een productieomgeving

4.2.2 Fase 1: PoC Nuts bevraagt LSP

In de PoC willen we de flow beproeven van het opvragen van een (medicatie) resource op het LSP door een XIS in een referentieomgeving. Nuts past haar open source component aan en het LSP past haar infrastructuur aan. Tijdens een aantal ontwerpsessies specificeren we de te ontwikkelen koppeling. Hoofdonderdelen zijn identificatie en authenticatie middels verifiable credentials.

4.2.3 Fase 2: PoC LSP bevraagt Nuts

We ontwikkelen en beproeven de flow waarbij Nuts wordt gevraagd vanuit het LSP voor een nog nader te bepalen zorgtoepassing/informatiestandaard. Hierbij moet het voor het LSP agnostisch zijn of een partij via Nuts of het LSP is aangesloten: we bieden dezelfde ervaring. Dit betekent dat in deze fase gemeenschappelijke voorzieningen waaronder I&A, toestemmingen, adressering en (lokalisatie) onderdeel zijn van de ontwikkeling

4.2.4 Fase 3: Pilot Nuts bevraagt LSP

We maken de PoC brengen deze naar productie. Hierbij werken we naast het vertrouwen ook de lokalisatie uit op basis van Mitz. Vervolgens beproeven we de koppeling in productie. Daarbij bevraagt het Nuts-netwerk het LSP voor een nader te bepalen zorgtoepassing. Het identificatiemiddel tijdens de pilot is de UZI-pas.
Deze fase begint met het ontwikkelen van de ontbrekende schakels om naar 'productie' te gaan met een GtK. Hiervoor ontbreekt nog een credential in de PoC1 fase. Ook zal de documentatie en testen op niveau worden gebracht om verantwoord in productie te gaan.

4.2.5 Fase 4: Pilot LSP bevraagt Nuts

We maken de PoC ontwikkelingen productierijp en brengen deze naar productie waar we de koppeling beproeven in een praktijksituatie in de vorm van een pilot.

4.2.6 Vertrouwensmodel

Ten behoeve van de uitwisseling is het noodzakelijk dat de uitwisseling plaats vindt onder vertrouwen wat op twee manieren realiseerbaar is: via Twiin en via AORTA. Het uitwisselen via Twiin is het doel. Mocht Twiin dit vertrouwen niet (tijdig) kunnen formaliseren in haar afsprakenstelsel, dan kiezen we voor een (al dan niet tijdelijke) invulling vanuit AORTA. Daarbij kiezen we zo veel mogelijk voor verwijzen naar Twiin en verschaffen we een aanvullend kader.

Twiin en AORTA zijn **de realisatie van het abstracte "issuer trusted by verifier" principe** in de praktijk. De cryptografie van VC/VP blijft hetzelfde; wat verandert, is **wie als vertrouwde issuer wordt erkend**.

4.2.7 Autorisatie niet-BIG geregistreerden

Voor zorgmedewerkers zonder BIG-registratie is geen autorisatieprofiel beschikbaar. Hierdoor beschikken zij niet over de benodigde BIG-gebaseerde rolcodes om bepaalde gegevens op te halen waarmee zij in staat zijn gerichte (medische) handelingen te verrichten. Dit komt veel voor in de VVT en gehandicaptenzorg, maar ook in andere sectoren. Voor de opschaling in (onder meer) de VVT is het noodzakelijk dat dat dit wel

geregeld is. We voorzien een oplossing waarbij zorgaanbieders zelf identiteiten en taak/rolcodes kan uitgeven.

5 Nuts x AORTA/LSP – IST

Leeswijzer hoofdstuk

5.1 Huidige situatie

De gegevensuitwisseling in de zorg is momenteel beperkt tot op zichzelf staande systemen en infrastructuren. Zorgaanbieders kunnen alleen gegevens uitwisselen met andere zorgaanbieders die van hetzelfde systeem of infrastructuur gebruikmaken. Er is geen overkoepelende infrastructuur die deze systemen en/of infrastructuren met elkaar verbindt.

In de huidige situatie zijn de gegevensuitwisselingen dus beperkt tot het systeem of de infrastructuur waarop de zorgaanbieders zijn aangesloten. Echter in het geval van de VVT-sector, is er behoefte om medicatieoverzichten van cliënten (patiënten) te kunnen inzien bij de apotheker en/of huisarts. Dit is momenteel niet mogelijk aangezien deze zorgaanbieders op verschillende infrastructuren zijn aangesloten.

5.1.1 Wet- & regelgeving

Ongeacht of de zorgaanbieders op dezelfde infrastructuur of op verschillende infrastructuren zijn aangesloten, moeten de opslag van medische gegevens en de gegevensuitwisselingen voldoen aan dezelfde wet- en regelgeving zoals:

- AVG / UAVG
  Bescherming van persoonsgegevens, rechtsgrond voor verwerking van bijzondere persoonsgegevens (gezondheidsgegevens), eisen aan toestemming, intrekking, dataminimalisatie, logging, DPIA.
- WGBO
  Patiënt heeft recht op inzage, toestemming en dossierbeheer; beroepsgeheim; wie mag gegevens inzien.
- Wabvpz
  Specifieke bepalingen voor elektronische uitwisseling; traceerbaarheid en logging; toestemming en audit van digitale gegevensuitwisseling.
- Wegiz + Regeling elektronische gegevensuitwisseling
  Verplicht elektronische uitwisseling bij aangewezen zorgaanbieders; aanwijzing van standaarden, gegevenssets en koppelingen; borgt interoperabiliteit.
- Wet BIG
  Toegang en bevoegdheid van zorgverleners, bepaalt wie welke medische gegevens mag verwerken.
- Wkkgz
  Kwaliteit en verantwoorde zorg; borgt correcte en veilige dossiervoering.
- Wbni / NIS2 implementatie
  Cybersecurity- en meldplicht; beheersmaatregelen voor vitale systemen.

5.1.2 Organisatie

De complexe en snel veranderende zorgsector vereist een naadloze, betrouwbare en veilige uitwisseling van medische gegevens. De aandachtspunten voor organisaties bij (elektronische) gegevensuitwisseling zijn:

- Identificatie: bepaald moet worden op basis van welke attributen organisaties en zorgverleners geïdentificeerd moeten worden, bijvoorbeeld aan de hand van een toegewezen rol of een nummer. Bij het vastleggen van patiëntgegevens (WID en SBV-Z gecontroleerd) en bij gegevensuitwisse–lingen in Nederland is het verplicht om patiënten te identificeren op basis van het BSN. Bij de uitwisseling van medische gegevens is het van belang dat er afspraken zijn over hoe personen, organisaties en bijvoorbeeld systemen worden geduid.

- Authenticatie: bij gegevensuitwisseling zijn afspraken nodig op basis waarvan authenticatie van personen en organisaties plaatsvindt. Het type uit te wisselen gegevens bepaalt de eisen die aan de betrouwbaarheid van het authenticatiemiddel wordt gesteld (leidend hierin is eIDAS).
- Autorisatie: voor uitwisselingen tussen zorgaanbieders moeten autorisatieafspraken worden gemaakt. De afspraken leggen vast (met) welke (rol een) zorgverlener toegang heeft tot bepaalde informatie. Gegevensuitwisselingen moeten proportioneel zijn en een bepaald doel hebben. Autorisatieafspraken geven hier invulling aan, zodat vastgesteld kan worden wie de autorisaties bepaalt (raadplegende zorgaanbieder, dossierhoudende zorgaanbieder of via landelijke afspraken) en waar deze autorisaties worden gecontroleerd (bij de raadplegende zorgaanbieder, bij dossierhoudende zorgaanbieder, regionaal of via een centrale voorziening).
- Behandelrelatie: een zorgverlener mag alleen toegang hebben tot (medische) gegevens, wanneer deze een behandelrelatie met de patiënt heeft. Dit geldt zowel voor zorgverleners die in hun eigen zorgorganisatie een dossier benaderen als voor zorgverleners die gegevens raadplegen bij een andere zorgaanbieder, via bijvoorbeeld een uitwisselingssysteem.
- Patiënttoestemming: bij elektronische uitwisseling van medische gegevens geldt dat de patiënt toestemming moet geven voor het beschikbaar stellen van zijn gegevens voor mogelijke raadpleging door een andere zorgaanbieder in de toekomst.
- Logging: logging maakt het mogelijk het beheer van uitwisselingen goed in te richten. Wanneer er technische problemen zijn bij het tot stand brengen van de uitwisseling kan via de logging nagegaan worden waar het probleem in de keten ligt. De andere functie van logging is dat logging van transacties het mogelijk maakt om te controleren of de uitwisselingen volgens de afspraken plaatsvinden. Dit betreft altijd controle achteraf.
- Transparantie: transparantie omvat afspraken over hoe zorgaanbieders, zorgverleners en patiënten kunnen weten wat de afspraken over de waarborgen in het vertrouwensmodel zijn. Zorgverleners moeten op de hoogte zijn van het beleid op de waarborgen van het vertrouwensmodel, zowel intern als bij uitwisseling tussen zorgaanbieders. Voordat een zorgaanbieder uitwisselt met andere zorgaanbieders, moet deze op de hoogte zijn van de vastgelegde afspraken hierover. De zorgaanbieder zal, net als de andere deelnemende zorgaanbieders, aan de afspraken moeten voldoen.
- Lokalisatie: waarborgen ten aanzien van lokalisatie zijn nodig in het geval gegevens ongericht beschikbaar gesteld zijn voor opvragen. Ongericht beschikbaar stellen van gegevens houdt in dat gegevens na toestemming van de patiënt beschikbaar worden gesteld aan andere zorgorganisaties, zonder dat vooraf bekend is welke zorgorganisatie de gegevens op welk moment zal opvragen.
- Adressering: adressering is zowel noodzakelijk bij het ongericht beschikbaar stellen als bij het gericht versturen van informatie. Bij het gericht versturen van gegevens worden gegevens vanuit het systeem van de brondossierhouder direct naar een bekende ontvanger gestuurd. Hier geeft adressering antwoordt op de vraag, wat het “digitale adres” van de ontvanger is. Bij het ongericht beschikbaar stellen van gegevens geeft adressering de opvragende zorgaanbieder antwoord op de vraag wat het “digitale adres” van de bron is.
- Verantwoordelijkheden leveranciers: afspraken over SLA’s, beveiliging en naleving van wettelijke verplichtingen.
- Audit en compliance: interne controles, incidentmeldingen en documentatie voor toezichthouders (IGJ, AP).

Voor zorgaanbieders op het LSP zijn al deze punten geborgd in het AORTA-afsprakenstelsel en de architectuur van het LSP.

In de Nuts-architectuur worden de meeste van deze punten ook ingevuld, zoals de patiënttoestemming die vaak lokaal wordt vastgelegd.

5.1.3 Zorgproces

Wanneer in het zorgproces medische gegevens benodigd zijn van zorgaanbieders die aangesloten zijn op een andere infrastructuur, dan is het momenteel niet mogelijk om deze gegevens direct op een elektronische manier in het XIS te ontvangen.

In het geval dat een VVT-organisatie medicatiegegevens wil ontvangen van een zorgaanbieder op het LSP (of andersom), dan is het momenteel niet mogelijk om deze gegevens (automatisch) elektronisch uit te wisselen. Hierdoor wordt het zorgproces vertraagd en kan het mogelijk de patiëntveiligheid in gevaar brengen omdat de benodigde medicatiegegevens te laat of niet volledig beschikbaar zijn.

5.1.4 Informatie

Om te zorgen dat de gegevensuitwisseling kan plaatsvinden en dat deze gegevens opgeslagen kunnen worden in het XIS, moeten er afspraken worden gemaakt aan welke standaarden moeten worden voldaan.

Voor de huidige productie-omgeving van het LSP geldt dat de standaard voor medicatiegegevens MP6.12 is, waarbij de ondersteuning van en overgang naar MP9 wel in gang is gezet. Voor het LSP geldt dat beide standaarden worden ondersteund, maar omdat voor de meeste medicatiegegevens nog MP6.12 wordt gebruikt, wordt dit, indien nodig, getransformeerd naar MP9 en vice versa.

Binnen de Nuts-infrastructuur is volledige ondersteuning van de MP9-standaard.

5.1.5 Applicatie

De zorgaanbieder gebruikt voor de administratie van patiëntgegevens en het bijbehorende dossier een XIS. Het XIS moet alle (type) gegevens die bij de behandeling behoren kunnen opslaan. Ook moet het XIS deze gegevens beschikbaar kunnen stellen aan andere zorgaanbieders (indien de patiënt daar toestemming voor heeft gegeven) en/of de gewenste gegevens kunnen ontvangen van andere zorgaanbieders.
Het XIS moet dus alle (informatie)standaarden en formaten, die bij deze gegevensuitwisselingen behoren, ondersteunen. Daarnaast moet het XIS de functionaliteiten hebben om op de desbetreffende infrastructuur te kunnen communiceren.

Voor de zorgaanbieders die op het LSP zijn aangesloten geldt dat de meeste XIS'en de MP6.12 standaard wordt gebruikt. Leveranciers zijn bezig om de functionaliteit van de MP9-standaard in te bouwen, maar het is nog onbekend wat het tijdspad hiervoor is.

De Nuts-infrastructuur ondersteunt de MP9-standaard, maar de meeste XIS'en van de VVT moeten deze ondersteuning nog inbouwen.

5.1.6 Infrastructuur

In het huidige zorgveld bestaan verschillende systemen en infrastructuren waar medische gegevens worden uitgewisseld, maar deze systemen en infrastructuren staan over het algemeen op zichzelf. Dit betekent dat deze medische gegevens alleen binnen het desbetreffende systeem of infrastructuur beschikbaar zijn en dus niet beschikbaar zijn voor zorgaanbieders die op een andere infrastructuur zijn aangesloten.

5.1.7 Beveiliging

Medische gegevens zijn bijzondere persoonsgegevens. Daarom moet de bescherming van deze gegevens aan de hoogste beveiligingseisen voldoen. Dit geldt zowel voor het XIS als voor de gebruikte infrastructuur. Leidend voor de beveiliging zijn de wetgeving en normen waar alle onderdelen in de keten van gegevensuitwisseling aan moeten voldoen.

5.2 Huidige technische architectuur

Although both AORTA and Nuts support healthcare data exchange, they differ fundamentally in their architectural assumptions:

- **AORTA / LSP** is based on:
  - centrally governed **business identifiers** (e.g. URA, ~~AGB~~, UZI),
  - **PKI-based trust** (X.509 certificates),
  - and **transaction-bound authorization**, traditionally conveyed via SAML assertions and tokens.
  - SAML-tokens based on IHE XUA structure (not validated via Connectathons).
- **Nuts** is based on:
  - **decentralized technical identifiers (DIDs) voor het opvragen van sleutelmateriaal.**
  - **Verifiable Credentials** as portable, cryptographically verifiable statements of identity, role, and authorization,

- and a clear separation between **credential issuance** and **credential presentation**.

Because of these differences, **direct coupling between a Nuts Node and the LSP is neither desirable nor feasible**. ~~The GtK provides the necessary mediation layer to bridge these architectural models in a controlled and auditable manner.~~

5.3 Knelpunten en beperkingen

5.3.1 Algemeen

5.3.2 Per fase

5.3.2.1 Fase 1: Nuts bevraagt LSP

Vertaling van credentials naar assertion, naar toegangstoken.

In een credential mis je de context, dit is waar een (SAML) assertion token zich onderscheidt.

- **Credentials leggen rechten vast**
- **Assertions oefenen die rechten uit**

5.3.2.2 Fase 2: LSP bevraagt Nuts

Hoe vindt ik bij Nuts, de juiste zorgaanbieder (nuts) node

6 Nuts x AORTA/LSP – SOLL

Leeswijzer hoofdstuk

6.1 Gewenste situatie

De meeste zorgaanbieders hebben geen kennis van de verschillende systemen en infrastructuren. Zorgaanbieders willen wel gegevens van hun patiënt kunnen raadplegen wanneer dit nodig is ongeacht waar deze gegevens zich bevinden. Dit betekent dat het mogelijk moet zijn om de op zichzelf staande systemen en infrastructuren met een overkoepelende infrastructuur te verbinden, zodat het mogelijk wordt om gegevens uit te wisselen ongeacht het systeem of infrastructuur dat wordt gebruikt.

Daarvoor is deze use case als volgt gedefinieerd:

> *"**Als** raadplegende zorgaanbieder (RPZA), die niet op dezelfde infrastructuur*
> *is aangesloten als de dossierhoudende zorgaanbieder (DHZA),*
> ***wil** ik dat een DHZA (aangesloten op een andere infrastructuur dan de RPZA)*
> *gegevens van mijn patiënt beschikbaar stelt aan mij,*
> ***zodat** ik mijn patiënt beter kan diagnosticeren en/of behandelen."*

Specifieke invulling van deze use case is de wens van VVT-zorgaanbieders en zorgaanbieders die aangesloten zijn op het LSP om medicatiegegevens met elkaar uit te wisselen. Dit wordt verder uitgewerkt in dit document en kan als blauwdruk dienen voor de landelijk infrastructuur en het bijbehorende afsprakenstelsel.

6.1.1 Wet- & regelgeving

Ongeacht of de zorgaanbieders op dezelfde infrastructuur of op verschillende infrastructuren zijn aangesloten, moeten de opslag van medische gegevens en de gegevensuitwisselingen voldoen aan dezelfde wet- en regelgeving zoals beschreven in paragraaf 5.1.1.

6.1.2 Organisatie

Medische gegevens zijn bijzondere persoonsgegevens waaraan de hoogste privacy – en beveiligingseisen worden gesteld voor opslag, toegang en uitwisseling van deze gegevens. Om dit te borgen, naast een zo hoog mogelijke kwaliteit en continuïteit, moeten naast (technische) eisen ook gezamenlijke afspraken, processen en procedures worden gemaakt. Alle betrokken partijen in deze keten die gebruik maken van deze overkoepelende infrastructuur, moeten aan deze(lfde) afspraken en eisen voldoen voordat gegevensuitwisseling kan plaatsvinden. Aangezien het gaat over zorgaanbieders die op verschillende systemen en/of infrastructuren zijn aangesloten, is een landelijke infrastructuur en afsprakenstelsel benodigd.

Voor een landelijke infrastructuur en afsprakenstelsel zijn gezamenlijke eisen, afspraken, processen en procedures benodigd, waarbij de onderstaande punten in ieder geval terug moeten komen:

- Identificatie
  De identificatie van organisaties en personen en welke attributen hiervoor benodigd zijn moet voor alle partijen op dezelfde manier worden ingevuld. De meeste onderwerpen zullen door wetgeving worden ingevuld en waar dit ontbreekt, moeten deze onderwerpen in het afsprakenstelsel en architectuur worden uitgewerkt.
- Authenticatie: bij gegevensuitwisseling zijn afspraken nodig op basis waarvan authenticatie van personen en organisaties plaatsvindt. Het type uit te wisselen gegevens bepaalt de eisen die aan de betrouwbaarheid van het authenticatiemiddel wordt gesteld (leidend hierin is eIDAS).

- Autorisatie: voor uitwisselingen tussen zorgaanbieders moeten autorisatieafspraken worden gemaakt. De afspraken leggen vast (met) welke (rol een) zorgverlener toegang heeft tot bepaalde informatie. Gegevensuitwisselingen moeten proportioneel zijn en een bepaald doel hebben. Autorisatieafspraken geven hier invulling aan, zodat vastgesteld kan worden wie de autorisaties bepaalt (raadplegende zorgaanbieder, dossierhoudende zorgaanbieder of via landelijke afspraken) en waar deze autorisaties worden gecontroleerd (bij de raadplegende zorgaanbieder, bij dossierhoudende zorgaanbieder, regionaal of via een centrale voorziening).
- Behandelrelatie: een zorgverlener mag alleen toegang hebben tot (medische) gegevens, wanneer deze een behandelrelatie met de patiënt heeft. Dit geldt zowel voor zorgverleners die in hun eigen zorgorganisatie een dossier benaderen als voor zorgverleners die gegevens raadplegen bij een andere zorgaanbieder, via bijvoorbeeld een uitwisselingssysteem.
- Patiënttoestemming: bij elektronische uitwisseling van medische gegevens geldt dat de patiënt toestemming moet geven voor het beschikbaar stellen van zijn gegevens voor mogelijke raadpleging door een andere zorgaanbieder in de toekomst.
- Logging: logging maakt het mogelijk het beheer van uitwisselingen goed in te richten. Wanneer er technische problemen zijn bij het tot stand brengen van de uitwisseling kan via de logging nagegaan worden waar het probleem in de keten ligt. De andere functie van logging is dat logging van transacties het mogelijk maakt om te controleren of de uitwisselingen volgens de afspraken plaatsvinden. Dit betreft altijd controle achteraf.
- Transparantie: transparantie omvat afspraken over hoe zorgaanbieders, zorgverleners en patiënten kunnen weten wat de afspraken over de waarborgen in het vertrouwensmodel zijn. Zorgverleners moeten op de hoogte zijn van het beleid op de waarborgen van het vertrouwensmodel, zowel intern als bij uitwisseling tussen zorgaanbieders. Voordat een zorgaanbieder uitwisselt met andere zorgaanbieders, moet deze op de hoogte zijn van de vastgelegde afspraken hierover. De zorgaanbieder zal, net als de andere deelnemende zorgaanbieders, aan de afspraken moeten voldoen.
- Lokalisatie: waarborgen ten aanzien van lokalisatie zijn nodig in het geval gegevens ongericht beschikbaar gesteld zijn voor opvragen. Ongericht beschikbaar stellen van gegevens houdt in dat gegevens na toestemming van de patiënt beschikbaar worden gesteld aan andere zorgorganisaties, zonder dat vooraf bekend is welke zorgorganisatie de gegevens op welk moment zal opvragen.
- Adressering: adressering is zowel noodzakelijk bij het ongericht beschikbaar stellen als bij het gericht versturen van informatie. Bij het gericht versturen van gegevens worden gegevens vanuit het systeem van de brondossierhouder direct naar een bekende ontvanger gestuurd. Hier geeft adressering antwoordt op de vraag, wat het “digitale adres” van de ontvanger is. Bij het ongericht beschikbaar stellen van gegevens geeft adressering de opvragende zorgaanbieder antwoord op de vraag wat het “digitale adres” van de bron is.
- Verantwoordelijkheden leveranciers: afspraken over SLA’s, beveiliging en naleving van wettelijke verplichtingen.
- Audit en compliance: interne controles, incidentmeldingen en documentatie voor toezichthouders (IGJ, AP).

Voor zorgaanbieders op het LSP zijn al deze punten geborgd in het AORTA-afsprakenstelsel en de architectuur van het LSP.

In de Nuts-architectuur worden de meeste van deze punten ook ingevuld.

6.1.3 Zorgproces

Wanneer in het zorgproces medische gegevens benodigd zijn van zorgaanbieders die aangesloten zijn op een andere infrastructuur, dan is het momenteel niet mogelijk om deze gegevens direct op een elektronische manier in het XIS te ontvangen.

In het geval dat een VVT-organisatie medicatiegegevens wil ontvangen van een zorgaanbieder op het LSP (of andersom), dan is het momenteel niet mogelijk om deze gegevens (automatisch) elektronisch uit te wisselen. Hierdoor wordt het zorgproces vertraagd en kan het mogelijk de patiëntveiligheid in gevaar brengen omdat de benodigde medicatiegegevens te laat of niet volledig beschikbaar zijn.

6.1.4 Informatie

Om te zorgen dat de gegevensuitwisseling kan plaatsvinden en dat deze gegevens opgeslagen kunnen worden in het XIS, moeten er afspraken worden gemaakt aan welke standaarden moeten worden voldaan.

Voor de huidige productie-omgeving van het LSP geldt dat de standaard voor medicatiegegevens MP6.12 is, waarbij de ondersteuning van en overgang naar MP9 wel in gang is gezet. Voor het LSP geldt dat beide standaarden worden ondersteund, maar omdat voor de meeste medicatiegegevens nog MP6.12 wordt gebruikt, wordt dit, indien nodig, getransformeerd naar MP9 en vice versa.

Binnen de Nuts-infrastructuur is volledige ondersteuning van de MP9-standaard.

6.1.5 Applicatie

De zorgaanbieder gebruikt voor de administratie van patiëntgegevens en het bijbehorende dossier een XIS. Het XIS moet alle (type) gegevens die bij de behandeling behoren kunnen opslaan. Ook moet het XIS deze gegevens beschikbaar kunnen stellen aan andere zorgaanbieders (indien de patiënt daar toestemming voor heeft gegeven) en/of de gewenste gegevens kunnen ontvangen van andere zorgaanbieders.
Het XIS moet dus alle (informatie)standaarden en formaten, die bij deze gegevensuitwisselingen behoren, ondersteunen. Daarnaast moet het XIS de functionaliteiten hebben om op de desbetreffende infrastructuur te kunnen communiceren.

Voor de zorgaanbieders die op het LSP zijn aangesloten geldt dat de meeste XIS'en de MP6.12 standaard wordt gebruikt. Leveranciers zijn bezig om de functionaliteit van de MP9-standaard in te bouwen, maar het is nog onbekend wat het tijdspad hiervoor is.

De Nuts-infrastructuur ondersteunt de MP9-standaard, maar de meeste XIS'en van de VVT moeten deze ondersteuning nog inbouwen.

6.1.6 Infrastructuur

In het huidige zorgveld bestaan verschillende systemen en infrastructuren waar medische gegevens worden uitgewisseld, maar deze systemen en infrastructuren staan over het algemeen op zichzelf. Dit betekent dat deze medische gegevens alleen binnen het desbetreffende systeem of infrastructuur beschikbaar zijn en dus niet beschikbaar zijn voor zorgaanbieders die op een andere infrastructuur zijn aangesloten.

6.1.7 Beveiliging

Medische gegevens zijn bijzondere persoonsgegevens. Daarom moet de bescherming van deze gegevens aan de hoogste beveiligingseisen voldoen. Dit geldt zowel voor het XIS als voor de gebruikte infrastructuur. Leidend voor de beveiliging zijn de wetgeving en normen waar alle onderdelen in de keten van gegevensuitwisseling aan moeten voldoen.

6.2 Use case

De use case van een landelijk dekkend netwerk is als volgt:

> ***Als*** *RPZA (die niet op dezelfde infrastructuur is aangesloten als de DHZA)*
> ***wil*** *ik dat een DHZA (aangesloten op een andere infrastructuur dan de RPZA)*
> *gegevens van mijn patiënt beschikbaar stelt aan mij,*
> ***zodat*** *ik mijn patiënt beter kan diagnosticeren en/of behandelen.*

6.3 Toekomstige situatie

<wijzigingen t.o.v. huidige situatie>

This document describes the technical standards and architectural principles for the secure exchange of healthcare data between the **Nuts ecosystem** and the **LSP (Landelijk Schakelpunt)** within the **AORTA architecture**, using **Verifiable Credentials (VCs)**, **Verifiable Presentations (VPs)**, OAuth-based authorization, and **FHIR** for clinical data exchange.

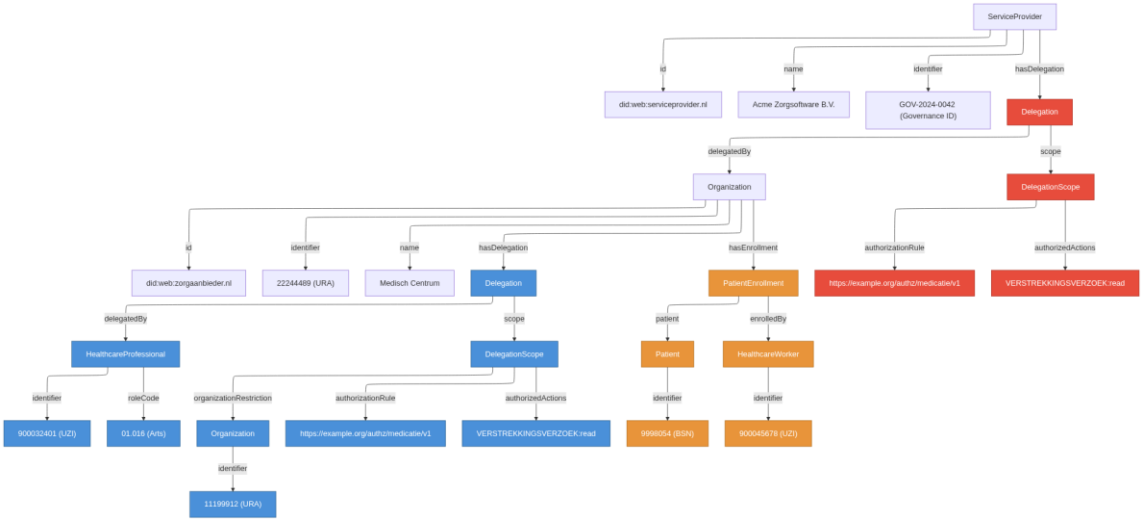
To ensure secure, interoperable, and policy-compliant cross-domain communication, **all interactions between the Nuts and AORTA/LSP ecosystems are routed through a GtK (Gevalideerd Twiin Knooppunt)**.

The GtK functions as a controlled trust boundary that decouples the internal identity, authorization, and protocol models of each ecosystem from external consumers and providers of healthcare data.

The GtK represents the **intended convergence point** for validated cross-domain trust. Formal validation of the GtK concept can only take place once these specifications are implemented and assessed within the Twiin framework. Until that time, references to the GtK denote the **infrastructural and architectural component**, without implying formal Twiin qualification. During the PoC phase, the trust basis is defined within the AORTA framework.

6.3.1 Ontologie

// Ik weet niet waar deze thuishoort, maar bij deze even in de SOLL gezet



De ontologie beschrijft het domeinmodel met de entiteiten en relaties die worden geïdentificeerd en geverifieerd tijdens het authenticatieproces bij gegevensuitwisseling in de IST-situatie. Centraal staan vijf entiteiten: **Organization** (zorgaanbieder), **HealthcareProfessional** (zorgverlener), **HealthcareWorker** (medewerker), **Patient** en **ServiceProvider** (softwareleverancier).

Zorgmedewerkers kunnen via een **Delegation** namens een zorgverlener handelen, waarbij een **DelegationScope** vastlegt welke autorisatieregels en acties zijn toegestaan. Patiëntinschrijvingen worden gemodelleerd als een expliciet **PatientEnrollment**-object, zodat vastgelegd wordt welke medewerker de inschrijving heeft uitgevoerd. Dezelfde delegatiestructuur wordt hergebruikt voor de mandatering van softwareleveranciers door zorgaanbieders zodat softwareleveranciers met de relatie t.o.v. de organisatie zichtbaar zijn in de transactie en kunnen handelen namens de organisatie.

De kleuren groeperen eigenschappen die samen over een entiteit worden beweerd.

- **Blauw** — de delegatie van zorgverlener aan organisatie (HealthcareProfessional, Delegation, DelegationScope met organizationRestriction)
- **Oranje** — de patiëntinschrijving (PatientEnrollment, Patient, HealthcareWorker)
- **Rood** — de delegatie van organisatie aan softwareleverancier (Delegation, DelegationScope vanuit ServiceProvider)

6.4 Probleemomschrijving (Herbruikbaar vanuit Soll voor Generieke Use-Case)

Hieronder in eenvoudige taal wat de Use-Cases zijn in relatie tussen Raadpleger en Dossierhouder. In geel gemarkeerd de vragen die erbij opkomen. Dit is gebaseerd op Verifiable Credential (VC) plan dat uit de PoC gekomen is.

Er zijn 3 communicatiepatronen waarop de Request for Information gesteld kan worden.

- Geïndexeerde bevraging (ongericht beschikbaar stellen)
- Gerichte Bevraging (ongericht beschikbaar stellen)
- Notified Pull (gericht beschikbaar stellen)

Er zijn 5 Verifiable Credentials die gebruikt worden om alle attributen te waarborgen bij Index Versie.

- HealthcareOrganisationVC
- HealthcareProfessionalDelegationVC
- PatientEnrollmentVC
- ServiceProviderVC
- ServiceProviderDelegationVC

Zijn er nog meer VC's of andere attributen nodig voor de Gerichte Bevraging of Notified Pull?

ZA-Raadpleger Vraagstelling

Use-Case: Heeft iemand een Dossier van deze patient voor mij?

- Ik heb een behandelovereenkomst met deze Patiënt:

>> PatientEnrollmentVC (Inschrijftoken) = ID-ZA, ID-PAT, ID-VZ (UZI-Pas)

- Ik ben deze Behandelaar bij een zorgaanbieder en ik heb deze Rolcode (Data die ik mag opvragen).

>> HealthcareProfessionalVC (Zorgverlener) = ID-ZA, ID-VZ (UZI-Pas), ID-Rolcode (Type Data die ik mag bevragen)

\\ Kan mijn ID-ZA hier afwijken van de ID-ZA van de pas? Dat is noodzakelijk. Nodig voor VC samenhang.

\\ Hoe ben ik als Behandelaar beschermd dat een ZA niet in mijn naam opvraagt zonder mijn handelen? Is dat al standaard afgevangen door zorgovereenkomsten? Moet dat in een afsprakenstelsel? Dit is een lokale verantwoordelijkheid binnen de zorgorganisatie.

- Ik maak het verzoek vanaf dit systeem.

>> HealthcareOrganizationVC = ID-ZA, ~~ID-Zorgaanbiedertype (tbv toestemmingen)~~

- Ik geef toestemming aan de GtK om mijn verzoek door te zetten.

>> ServiceProviderDelegationVC = ID-ZA, ID-GtK (GtK met verwerkersovereenkomst)

- Hoe stuur ik Verzoek naar Dossierhouder (via GtK?)

\\ Hoe weet ik dat deze 3 of 4 VCs bij elkaar horen? Allemaal zelfde ID-ZA zorgt voor samenhang.

\\ Is dat uberhaupt relevant? Ze moeten er allemaal in staan om een volledig verzoek te kunnen maken.

\\ Wat moet ik allemaal controleren? (|Zie verderop)

\\ Hoe doe ik die controle? (zie verderop)

\\ Wie zijn Issuer, Verifier, Holder van de VCs? (Dat lijkt de crux op controle op verschillende plekken)

Holder: GtK
Issuer: Er zijn er meerdere (zie inleiding VCs)
Verifier: het ontvangende GtK (i.c. LSP in PiLot1)

De Holder van een VP kan ook de ZA zijn in het geval van communicatie met het GtK. Hiermee kunnen de VC's doorgegeven worden aan het GtK.

Routering Vraag (GtK's)

Use-Case: Ik krijg een open vraag van Raadpleger voor een Dossier.

- Heb ik toestemming om dit op te vragen volgens Raadpleger?
Is functie van het ontvanger (zie verderop) De toestemmingsvraag is generiek en niet binnen de context van dit project te controleren. Natuurlijk is dit wel een onderdeel van het LSP.,

- Mag deze Raadpleger dit opvragen? Dit is ook een functie van de ontvanger. De MAP (medisch autorisatie protocol) van het LSP regelt dit.

- Is er een Dossier van deze patiënt (overeenkomende met Rolcode)? Dit is eveneens een functie van de ontvanger. Deze gebruikt zijn/haar verwijsindex (icm met de localisatie?) om dit de controleren.

- Waar is dit Dossier? Dit is een lokale functie van het afsprakenstelsel (VWI)

\\ Wat moet ik allemaal controleren? Is onderdeel van de VC's verifier sectie (zie verderop)

\\ Hoe doe ik die controle? Is onderdeel van de VC's verifier sectie (zie verderop)

ZA-Dossierhouder controles

Use-Case: Ik krijg een vraag van een collega zorgaanbieder voor dossierdata van patiënt.

- Heb ik dossier van deze patient? Dit is een lokale functie van het afsprakenstelsel (AORTA: VWI)

- Heeft de patient toestemming gegeven aan mij om gegevens beschikbaar te stellen? (Mitz)

- Is er Toestemming van Patient voor uitwisseling tussen dit type Zorgaanbieder (Lokaal/Mitz)?

- Wat voor ZorgAanbieder ben ik, en de opvrager? Dit is niet nodig voor uitwisseling. De MAP is gebaseerd op Rolcode. De toestemming is wel op typezorgaanbieder gebaseerd.

- Welke Data wordt er opgevraagd (Rolcode)? Zie de implementatie van de MAP

- Hoe stuur ik Data naar Raadpleger (of connector). Zie Twiin / AORTA / Nuts

\\ Wat moet ik allemaal controleren? Zie Verifier (zie verderop)

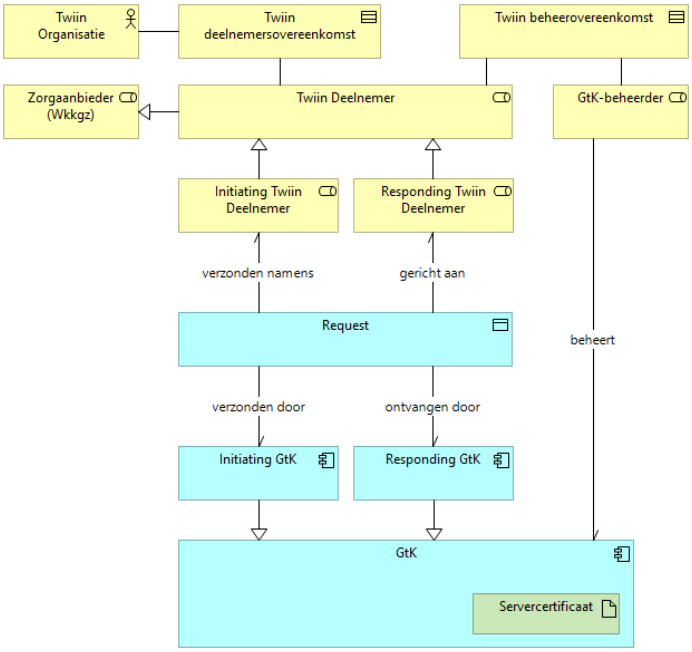
\\ Hoe doe ik die controle? Zie Verifier (zie verderop)

6.4.1 Context: Twiin as Framework

- **Twiin is an overarching interoperability and trust framework** that defines the **normative architectural principles, standards, and governance rules** for cross-domain healthcare data exchange.
- Twiin specifies:
  - mandatory architectural patterns (such as the use of GtKs),
  - applicable standards (e.g. FHIR R4),
  - Trust and authorization principles,
  - and the separation of responsibilities between participating domains.
- **GtKs (Validated Twiin Nodes)** are **concrete, validated implementations** operating under the Twiin framework, and **MUST comply** with Twiin-defined functional, security, and governance requirements.
- Twiin itself does **not provide a runtime network or services**; it provides the **framework within which networks such as AORTA/LSP and Nuts can interoperate**.
- Standards, protocols, and profiles used by GtKs are **derived from and governed by the Twiin framework**, ensuring consistency, auditability, and future extensibility.

Twiin does not replace existing healthcare networks; it governs how they securely and consistently connect.

The picture below positions the Initiating GtK and the Responding GtK.



A Twiin Deelnemer Overeenkomst exists between a Twiin Deelnemer (Zorgaanbieder or Healthcare Organization) and the Twiin Organization. A Twinn beheerovereenkomst exists between a Twinn Deelnemer and its GtK-beheerder (Organization), which describes the operation of the Twinn Deelnemer GtK by the GtK-beheerder.

An Initiating Twiin Deelnemer may send a Request to a Responding Twinn Deelnemer. Such a Request is sent from an Initiating GtK to a Responding GtK.

To establish trust between the Initiating Twiin Deelnemer and the Responding Twinn Deelnemer, the following requirements have to be met.

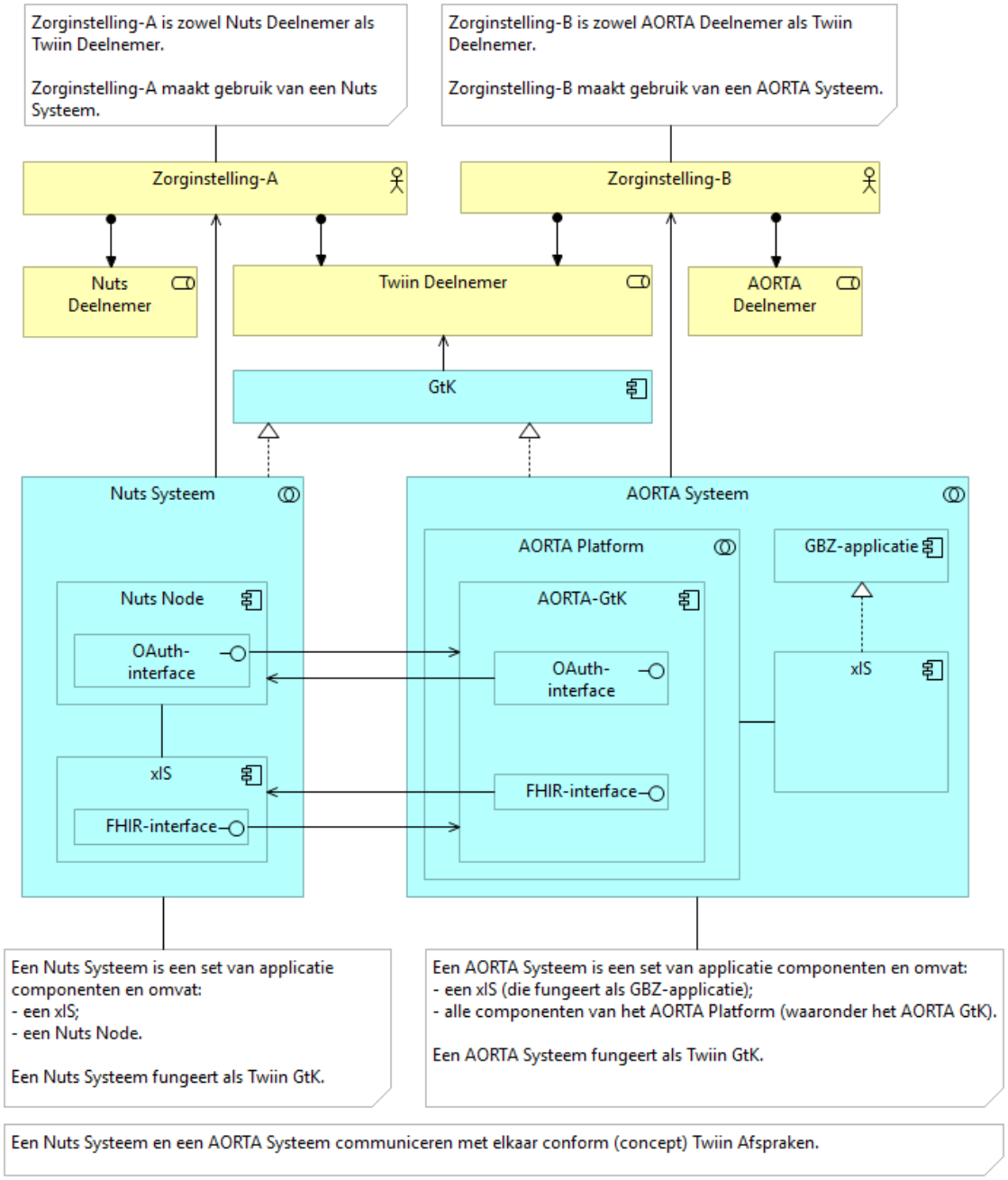
When an Initiating GtK intends to send a request, it must be able to establish:

1. that the receiving Organization is a Healthcare Organization;
2. that the receiving Organization is a Twiin Deelnemer;
3. which GtK-beheerder and GtK are authorized by the Responding Twiin Deelnemer to process the request;
4. that the receiving system is indeed the GtK in question;
5. that the Responding GtK and GtK-beheerder have been qualified by Twiin to receive this specific request.

When a Responding GtK receives a request, it must be able to establish:

1. from which system it is receiving the request, and that the sending system is a GtK;
2. which GtK-beheerder manages the Initiating GtK;
3. that the Initiating GtK and GtK-beheerder have been qualified by Twiin to send this request;
4. on behalf of which Organization the request has been sent, and that this Organization is a Healthcare Organization and a Twiin Deelnemer;
5. that the Initiating Twiin Deelnemer authorizes the GtK-beheerder and Initiating GtK to send this message on its behalf.

The picture below shows the mapping of Twiin concepts on the solution to be developed.



6.4.2 Twiin: Proof of AORTA – Nuts

In the Nuts–AORTA architecture, identity is no longer asserted by the transport layer but proven by cryptographic possession of credentials issued under an authoritative trust framework.

6.4.3 Trust Framework and Governance

Authoritative Issuers and Lifecycle Management

- Verifiable Credentials containing business identifiers MUST be issued by ***authoritative issuers***.
- The authoritative issuer MUST:
  - Register DID bindings,
  - Manage lifecycle (issuance, update, revocation, expiry),

- Expose revocation/status information.

This role is functionally equivalent to the UZI-register, certificate management, and CRL/OCSP mechanisms in AORTA.

6.4.4 Organisatie en juridische aspecten

Zorgaanbieders zijn verantwoordelijk voor dossierbeheer en goede uitwisseling (NEN75xx).

Zorgverleners zijn inhoudelijk verantwoordelijk.

ICT-dienstverleners, derde partijen, zullen namens deze verantwoordelijkheden handelingen gaan verrichten, zodat de aansprakelijkheid duidelijk is.

6.4.5 Zorgproces

Het zorgproces 'merkt' feitelijk niet dat er een overgang wordt gemaakt over de verschillende afsprakenstelsels heen. De systemen ondersteunen de verschillende technische implementaties via adapters (GtKs) en andere ondersteunende software binnen het eigen platform.

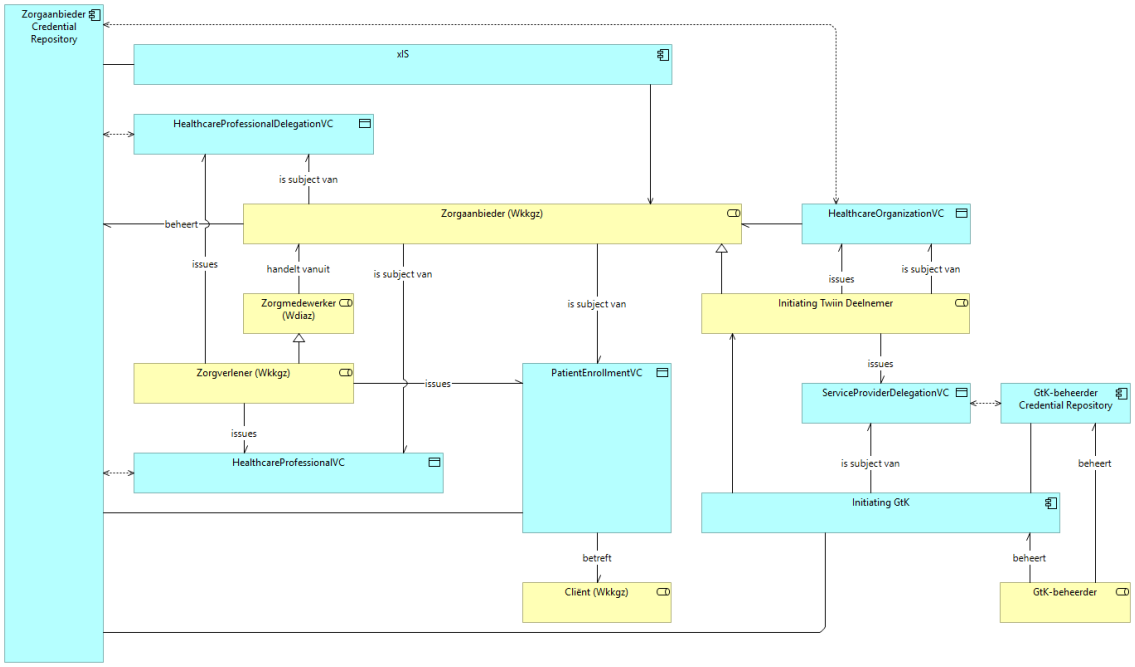
Door gebruik te maken van gemeenschappelijke voorzieningen (implementatie van generieke functies van VWS) wordt meer en meer een uniforme wijze van adressering, lokalisatie, verwijsindex, logging, mogelijk.

Ook zal de patiënt binnen dit stelsel volledig worden ondersteund (MedMij etc.)

6.4.6 Informatie

...

The picture below shows the Verifiable Credentials required by an Initiating Twiin Deelnemer (including the Initiating GtK and its GtK-beheerder).



With respect to verifiable credentials, the following definitions apply (see also W3C).

1. Entity: anything that can be referenced in statements as an abstract or concrete noun. Entities include but are not limited to people, organizations, physical things. Any entity might perform roles in the ecosystem.
2. Issuer: a role an entity can perform by asserting claims about one or more subjects, creating a verifiable credential from these claims, and transmitting the verifiable credential to a holder.
3. Subject: a thing about which claims are made.
4. Holder: a role an entity might perform by possessing one or more verifiable credentials and generating verifiable presentations from them. A holder is often, but not always, a subject of the verifiable credentials they are holding. Holders store their credentials in credential repositories.
5. Credential repository: software, such as a file system, storage vault, or personal verifiable credential wallet, that stores and protects access to holders' verifiable credentials.
6. Verifiable credential: a tamper-evident credential whose authorship can be cryptographically verified. Verifiable credentials can be used to build verifiable presentations, which can also be cryptographically verifiable.
7. Verifiable presentation: a tamper-evident presentation of information encoded in such a way that authorship of the data can be trusted after a process of cryptographic verification. Certain types of verifiable presentations might contain data that is synthesized from, but does not contain, the original verifiable credentials (for example, zero-knowledge proofs).

Besluiten (te verwerken)

- 2 VP's, ongenest
    - VP1-client assertion: Acceptance/ClientCredential (deelname aan bepaald stelsel) + ServiceProviderDelegation
    - VP2-assertion: PatientEnrollment + HealthcareProfessionalDelegation + HealthcareOrganization
- Proces Ron in H7.1.6 hoeft niet aangepast te worden
- Belangrijk om scherp te krijgen wat de compositie tussen wallet en VC betekent:
    - ~~Het leeft hier (cache, opslag etc)~~
    - Subject == wallet-did
    - ~~Holder == wallet-did~~

HealthcareProfessionalDelegationVC's and PatientEnrollmentVC's are issued by a healthcare professional and are stored in a Zorgaanbieder Credential Repository.

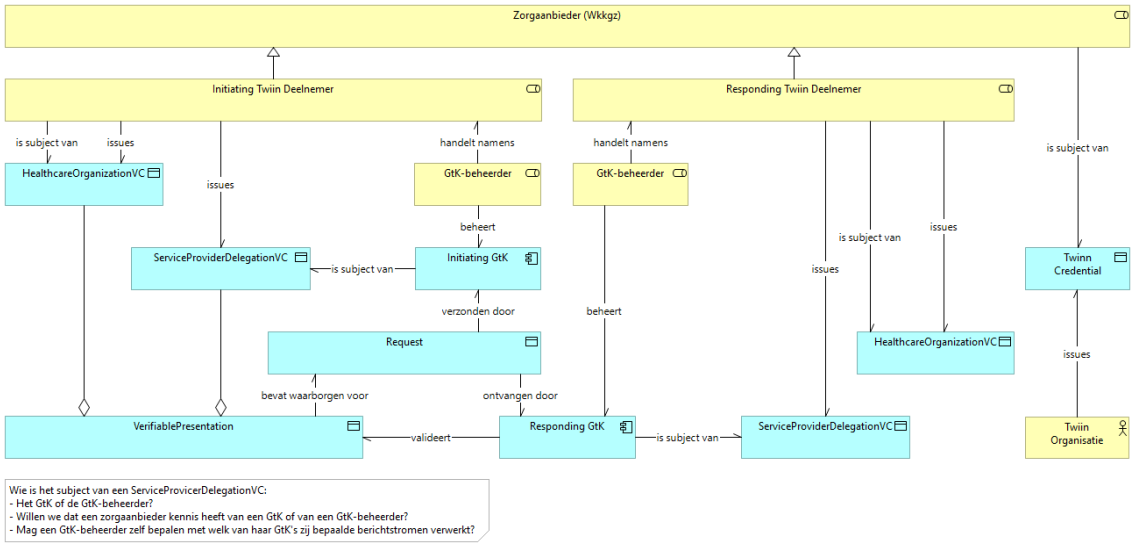
A HealthcareProfessionalDelegationVC contains claims about a delegation performed by a healthcare professional. A PatientEnrollmentVC proofs that a given patient was registered at a given healthcare provider.

HealthcareOrganizationVC's and ServiceProviderDelegationVC are issued by a healthcare organization. The SereviceProviderDelegationVC is stored in a GtK-beheerder Credential Repository. The HealthcareOrganizationVC is stored in a Zorgaanbieder Credential Repository.

A HealthcareOrganizationVC proofs that a given healthcare organization exists and the URA that was assigned to it as an identifier. A ServiceProviderDelegationVC proofs that the healthcare organization has delegated the responsibility for certain actions to an identified GtK, and that this GtK is allowed to present the required Verifiable Credentials on behalf of the delegating healthcare organization.

An Initiating GtK is able to retrieve Verifiable Credentials from both Credential Repositories and by adding its ServiceProviderDelegationVC it is allowed to present these credentials to a Responding GtK.

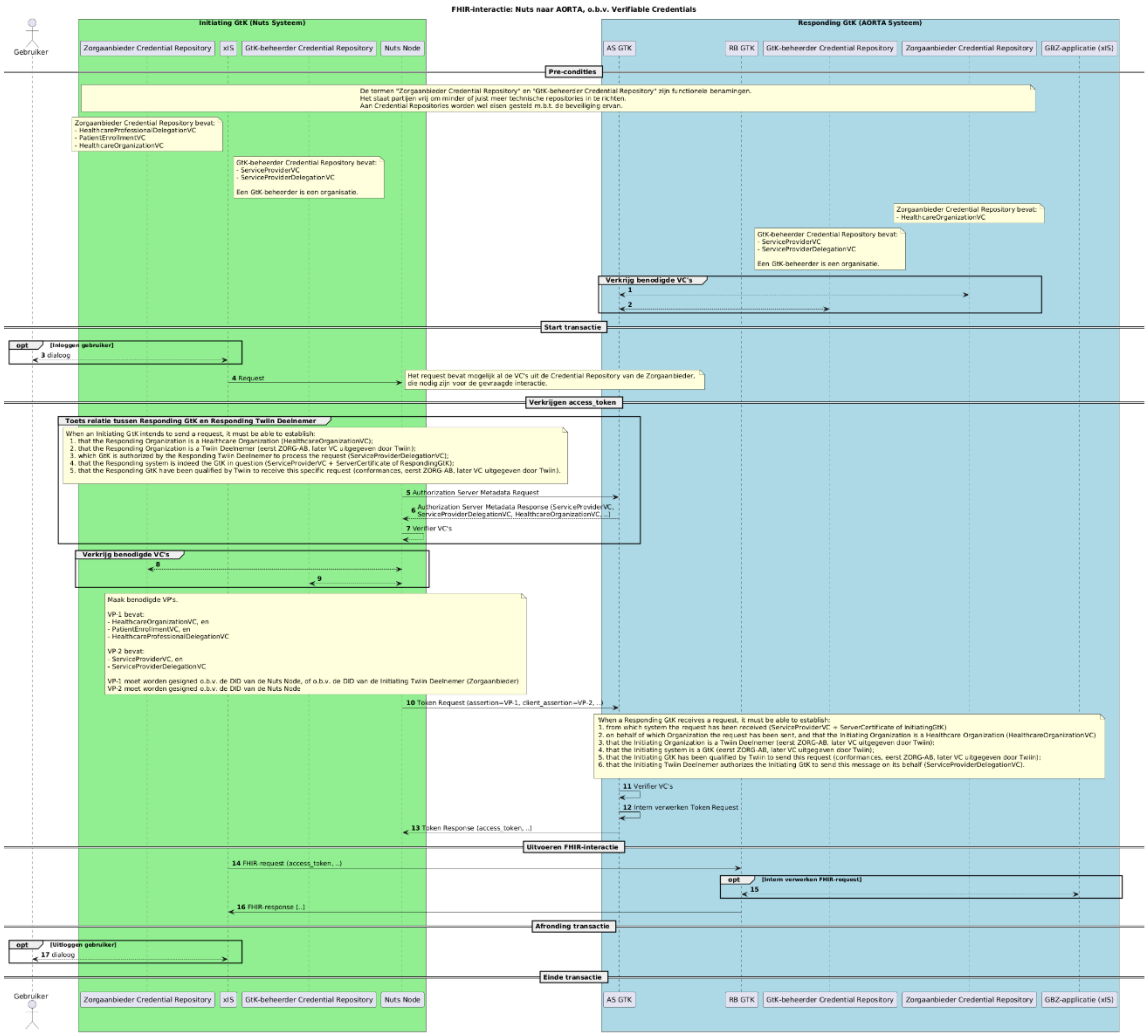
The picture below shows the Verifiable Credentials required by GtK-beheerders. Note that the Credentials shown partially overlap with the total set of Credentials required by an Initiating Twiin Deelnemer.



As mentioned before, the Initiating GtK has to proof that it's allowed to operate on behalf of the Initiating Twiin Deelnemer by presenting two VerifiableCredentials to a Responding GtK.

The other way around, a Responding GtK has to proof to an Initiating GtK that it's allowed to operate on behalf of the Responding Twiin Deelnemer. For this purpose, the Responding GtK also uses a HealthcareOrganizationVC and a ServiceProviderDelegationVC.

The high-level flow of requests and information is shown in the picture below.



Background information regarding the high-level flow

The OAuth flow between the Initiating GtK and the Responding GtK is based on RFC 7521 and RFC 7523.

RFC 7521 provides a general framework, on top of OAuth 2.0, for the use of assertions:

- For client authentication. In this situation the subject of a so called client_assertion identifies the client to the authorization server using the value of the "client_id" of the OAuth client.
- As authorization grants. In this case the subject of an assertion identifies an authorized accessor for which the access token is being requested (typically, the resource owner or an authorized delegate). An authorization grant represents the authorization granted by the resource owner (or by a privileged administrator).

An assertion is a package of information that allows identity and security information to be shared across security domains.

The intention is:

- to provide an alternative client authentication mechanism and
- to facilitate the use of OAuth 2.0 in client-server scenarios, where the end user may not be present.

The use of assertions for client authentication is orthogonal to and separable from using assertions as an authorization grant. They can be used either in combination or separately.

When using RFC 7521 for exchanging information between Twinn Deelnemers via GtK's:

- The client_assertion contains the identity of the Initiating GtK. The Initiating GtK acts as an OAuth Client to the Responding GtK.
- The assertion identifies the party for which an access_token is being requested. This party has been authorized by the Initiating Twiin Deelnemer to initiate requests on its behalf.

The client_assertion therefore is a Verifiable Presentation containing the following Verifiable Credentials:

- ServiceProviderVC ??
- ServiceProviderDelegationVC, containing the delegation of one or more activities by the Initiating Twiin Deelnemer (healthcare provider) to the Initiating GtK. Subject of the ServiceProviderDelegationVC is the Initiating GtK, identified by its OAuth client_id. As a result, the ServiceProviderDelegationVC contains the identity of the Initiating GtK.

The assertion is a Verifiable Presentation that contains the following Verifiable Credentials:

- HealthcareOrganizationVC, which carries the identity of the Initiating Twiin Deelnemer.
- HealthcareProfessionalVC (in case a healthcare professional initiates a request herself).
- HealthcareProfessionalDelegationVC (in case delegation by a healthcare professional to another person or to a system is applicable).
- PatientEnrollmentVC, which states that the patient was registered at the healthcare organization. The PatientEnrollmentVC is added to the Verifiable Presentation to proof to the Responding Twiin Deelnemer, that the patient that is the subject of the information exchange, actually has a relationship with the Initiating Twiin Deelnemer. Addition of the PatientEnrollmentVC to the presentation also limits the impact of a successful hack on the Initiating GtK.

The ServiceProviderDelegationVC contained in the client_assertion proofs to the Responding GtK that the Initiating GtK is allowed to present the set of Verifiable Credentials that is included in the assertion.

RFC's

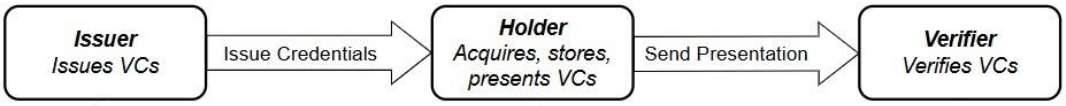
Besluit: optie 2 (stap 5/6)

6.4.7 Applicatie
6.4.8 Infrastructuur
6.4.9 Beveiliging
6.4.10 Wet- & regelgeving

6.5 Gewenste procesinrichting

6.5.1 Actors

- **Issuers.** One or more trusted parties that issue Verifiable Credentials (VCs), each asserting specific facts or authorizations (e.g. organization identity, role, delegation).
- **Holder.** A single entity that receives, stores, manages, and presents credentials issued by multiple issuers. The Holder acts on its own behalf or on behalf of another party based on the credentials it possesses.
- **Verifier.** A relying party that receives a Verifiable Presentation (VP) and evaluates the presented credentials to make an authorization or access decision.



6.5.2 Process Overview

6.5.2.1 Credential Issuance

Each Issuer independently issues one or more Verifiable Credentials to the Holder.

- Credentials are cryptographically signed by the Issuer.
- Each credential has its own:
  - issuer
  - subject
  - validity period
  - scope and constraints
- Credentials are ***context-independent*** and **reusable across use cases**.

Examples:

- An Organization VC issued by a healthcare provider
- A Delegation VC issued by a healthcare provider authorizing the Holder to act on its behalf
- A Role or Attribute VC issued by a trusted authority

6.5.2.2 Credential Storage and Management

The Holder:

- Retrieves credentials from multiple issuers
- Securely stores credentials in a wallet or secure storage
- Manages lifecycle aspects such as:
  - validity
  - revocation status
  - renewal

The Holder is responsible for selecting which credentials are relevant for a given interaction.

6.5.2.3 Presentation Preparation

When interacting with a Verifier, the Holder:

- Selects the required credentials based on:
  - the requested service
  - the intended action
  - verifier requirements and policy
- Validates the selected credentials prior to use
- Constructs a **Verifiable Presentation (VP)** that:
  - contains one or more credentials
  - adds runtime context (audience, purpose, scope, transaction)
  - expresses the Holder's intent and action

The VP represents a **moment-specific assertion**, derived from long-lived credentials.

6.5.2.4 Presentation and Proof

The Holder presents the VP to the Verifier and:

- Cryptographically signs the presentation
- Proves control over the Holder identifier and keys
- Optionally applies selective disclosure or minimization

The signature on the VP establishes:

- accountability of the Holder
- non-repudiation of the presented assertion

6.5.2.5 Verification and Enforcement

The Verifier:

- Verifies the VP signature
- Validates each included credential:
  - issuer trust
  - signature validity

    - validity period
    - revocation status
- Evaluates delegation chains and authorization scope
- Applies local policy to determine whether the requested action is allowed

Authorization decisions are based on **verifiable evidence**, not on implicit trust in the Holder.

6.5.3 Key Architectural Principles

- Credentials are **issued once** and **used many times**
- Assertions are **created per interaction**
- Issuers do not participate in runtime transactions
- The Holder is the active party and accountable for actions
- The Verifier makes an independent trust decision

6.5.4 Consolidated Identity and Trust Model

This model establishes a clear separation between **credential issuance**, **holding**, **presentation**, and **verification**, ensuring that trust establishment, control and reuse of credentials, contextual assertion, and policy-based enforcement are handled independently.

This separation enables scalable, interoperable, and auditable delegation and authorization across organizational boundaries.

To support interoperability between AORTA and Nuts (in either direction), the identification of a healthcare provider SHALL be explicitly split into two layers:

- a **technical identifier** (e.g. a DID) used solely for cryptographic key ownership and proof of control; and
- one or more **Verifiable Credentials** that express the authoritative **business identity**, such as URA, AGB, role, or mandate.

A technical identifier SHALL NOT be used on its own as the identification of a healthcare provider.

Each DID used in the PoC SHALL be bound, via a Verifiable Credential issued by an authoritative source, to at least one business identifier equivalent to those used within AORTA.
A Verifiable Credential that lacks such an authoritative DID–business-identifier binding SHALL be considered an unmanaged claim and MUST NOT be treated as a normative identity.

Verifiers SHALL NOT assign any semantic meaning to a technical identifier (DID) beyond what can be derived from validated Verifiable Credentials.

6.5.5 Role of the GtK

The GtK provides the necessary mediation layer to bridge architectural and trust-model differences between domains in a controlled and auditable manner.
The GtK acts as a standardized access interface that:

- shields each ecosystem from the internal complexity of the other,
- enforces domain-specific trust and authorization policies, and
- translates identifiers, credentials, and protocols where required.

The GtK acts as a technical service provider and MAY act as the Holder of Verifiable Credentials issued for a healthcare provider, based on explicit delegation as defined in Chapter XXX.

Two distinct GtKs exist, each aligned with the trust model and governance of its respective domain.

6.5.5.1 GtK-Nuts

The **GtK-Nuts** interfaces with one or more Nuts Nodes and:

- Provides secure inbound and outbound communication for participants in the **Nuts ecosystem**.
- Interprets and enforces authorization based on:
  - **Verifiable Credentials**,
  - **DID-based subject identification**, and
  - the attribute and delegation models defined within Nuts.
- Acts as the **policy enforcement point** for Nuts-originated requests that cross the domain boundary.
- Translates external requests and responses into the appropriate **Nuts protocols, DID references, and FHIR resources**.

From the Nuts perspective, the GtK-Nuts is a trusted verifier and gateway that externalizes Nuts interactions without exposing internal node-to-node trust mechanisms.

6.5.5.2 GtK-AORTA

The **GtK-AORTA** provides the standardized entry point into the **LSP/AORTA infrastructure** and:

- Validates authentication and authorization metadata according to **AORTA/LSP trust frameworks**, including:
  - X.509 certificates,
  - UZI-based identities,
  - SAML tokens or equivalent authorization artefacts.
- Verifies that externally presented credentials (including VCs) are:
  - issued by trusted authorities,
  - correctly bound to recognized business identifiers,
  - and compliant with LSP policy and scope of constraints.
- Ensures consistent routing to the appropriate LSP services, such as:
  - medication services,
  - Professional or patiënt recordservices,
  - Consent and registration services.

From the AORTA perspective, the GtK-AORTA ensures that **new credential models (VCs/DIDs)** can be consumed without altering the core LSP trust assumptions.

6.5.6 End-to-end bridge architecture

By placing a GtK on each side, **both ecosystems can evolve independently** while maintaining a stable, auditable, and secure interface for cross-domain data exchange.

The **Nuts–LSP bridge therefore consists of**:

- a **Verifiable Credential–based authorization model**,
- **FHIR-based clinical data structures**, and
- **Two GtKs** that mediate, validate, and convert communication flows between the two trust domains.

This approach ensures that **trust, authorization, and interoperability remain consistent across the entire end-to-end exchange path**, regardless of which ecosystem initiates the interaction.

6.5.7 Technical Identifiers and DID Methods

Within the Nuts–LSP bridge, decentralized identifiers (DIDs) are used solely as **technical identifiers** for cryptographic key ownership and verification.

A DID is a technical identifier that represents cryptographic control by an entity, but does not by itself convey legal, organizational, or authorization semantics.

Business identity, roles, mandates, and authorizations are expressed through Verifiable Credentials issued by authoritative issuers.

Depending on the context, a DID may represent a healthcare organization (e.g. cryptographically bound to a URA), a service (GtK), or an individual user, with its actual meaning and trust derived from the associated credentials.

The following DID methods are used in this PoC:

did:web
This method binds a DID to control over a DNS domain and an HTTPS endpoint. It is used to associate cryptographic keys with an organization in a way that aligns with existing web and operational security practices.

did:x509
This method derives a DID from an existing X.509 certificate or certificate chain. It enables reuse of established PKI trust anchors, such as UZI certificates, and supports a controlled transition from certificate-based identification (AORTA) to credential-based authorization (Nuts).

DID resolution and key validation are performed by the GtKs to establish cryptographic control. Trust decisions are based on the validation of Verifiable Credentials and **their cryptographic binding to the relevant DIDs**, not on the DID method itself.

Metadata and Token Token Endpoints

In the Nuts–LSP Proof of Concept, metadata endpoints are used to enable **interoperable and trustworthy exchange of Verifiable Credentials (VCs)** between participating systems.

Metadata provides machine-readable information about the technical capabilities of an Authorization Server or Issuer, including available token endpoints, supported authentication mechanisms, accepted VC and VP formats, and supported cryptographic algorithms. This allows parties to dynamically determine how to interact, without relying on static or bilateral configuration.

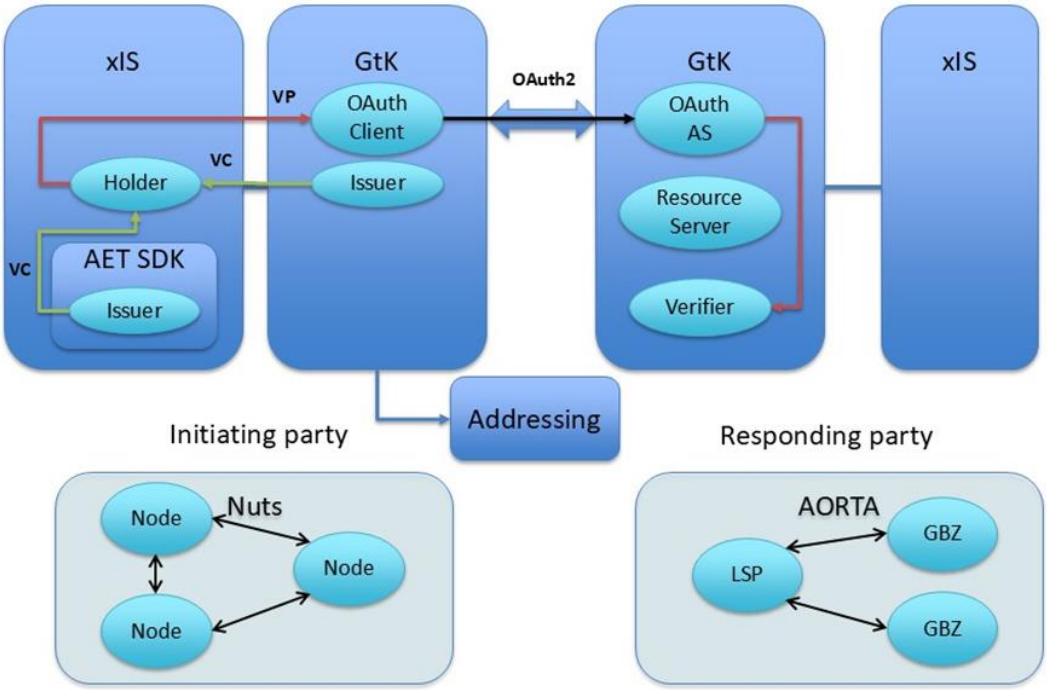
The PoC uses OAuth 2.0–based metadata, extended with VC-related capabilities as defined in the OIDC4VC family of specifications. In this setup, token endpoints support **asymmetric, certificate- or key-based authentication** (e.g. JWT bearer grants), which aligns with existing healthcare trust models and enables system-to-system and unattended interactions.

Metadata plays a key role in the use of Verifiable Credentials by defining in advance which credential formats, signatures, and identifier methods are accepted. Without this information, a credential may be cryptographically valid but still incompatible with the receiving system.

Within the Nuts–LSP architecture, metadata endpoints function as **enabling trust infrastructure**. They support dynamic interoperability between Nuts participants and provide the foundation for secure VC issuance and verification, without becoming part of the healthcare business process itself.

6.6 Juridische uitgangspunten

Credential flow and trust chain (diagram explanation)



The diagram is positioned primarily on the **application layer**, describing the technical credential, verification, and authorization flow between systems.
Actors such as healthcare providers, GtKs, and trust frameworks (e.g. Twiin) are treated as **business-layer roles** that are realized by application-layer components.

The healthcare provider remains the business subject of all business-related Verifiable Credentials, even when these credentials are held and presented by a delegated GtK (see Chapter 14).

The AET SDK is a **reusable application component** that may be embedded in systems participating at different points in the chain; it is not an actor in itself.

While the AET SDK is not an actor, it may technically perform credential issuance and signing functions on behalf of an issuing trust authority. In such cases, the SDK invokes a smartcard, HSM, or remote signing service to produce the cryptographic signature that is embedded in the issued Verifiable Credential. The issuer role and trust responsibility remain with the issuing authority, while the SDK acts as an implementation component realizing this function.

6.6.1 Defined interaction chain

The credential and authorization chain is defined as follows:

1. **Initiating xIS**
   Backend system of a healthcare provider acting as (logical) **holder** of business-related credentials.
2. **Initiating GtK**
   Acts as OAuth Client on behalf of the healthcare provider. The GtK acts as a technical service provider and may act as holder of Verifiable Credentials issued for a healthcare provider, based on explicit delegation as described in Chapter 14.
3. **Responding GtK**
   Acts in the roles of:
   a. OAuth Authorization Server

b. Verifier (of VPs and underlying VCs)
c. Resource Server

4. **Responding xIS**
   Backend system providing the protected healthcare service.

The **AET SDK** may be used by either an xIS or a GtK to support credential issuance, presentation, or verification, depending on the use case.

6.6.2 Credential issuance and binding

- Verifiable Credentials are issued under the authority of existing UZI trust anchors, including:
  - UZI server certificates
  - UZI personal certificates (UZI-card)

  The AET SDK may technically realize the credential issuance and signing process on behalf of the issuing trust authority, invoking a smartcard, HSM, or remote signing service.

- These Verifiable Credentials:
  - carry the **business identity, roles, and mandates** (e.g. healthcare provider, professional role, service authorization),
  - are cryptographically bound to a **DID** used as a technical identifier.
- The DID functions solely as a **cryptographic binding mechanism**; it does not replace or redefine the business identity expressed in the Verifiable Credentials.

6.6.3 Verifiable Presentation and OAuth flow

- For OAuth-based access:
  - A **Verifiable Presentation (VP)** is constructed and signed by the holder and passed to the **OAuth Client**, the **Initiating GtK**.
  - This VP is included in the OAuth token request (e.g. JWT bearer grant).
- The **Responding GtK**:
  - verifies the VP,
  - validates the included VCs,
  - evaluates them against Twiin trust, policy, and authorization rules,
  - and issues an **OAuth Access Token** if all conditions are met.

Applications use this access token to access protected resources via REST APIs.

6.6.4 Trust boundaries and qualified nodes

- Trust decisions are made exclusively by **qualified nodes**:
  - GtKs,
  - and other explicitly trusted VC issuers (e.g. Twiin, DEZI).
- All verification traffic (including VC and VP validation) is intended to occur **between GtKs**, shielding underlying xIS implementations from direct exposure.
- An xIS is only visible in the trust chain if:
  - it is explicitly defined as part of a GtK,
  - and included in the corresponding qualification and compliance scope.

6.7 Objectives

- Ensure interoperability with existing holders, issuers, and verifiers.
- Avoid the creation of a proprietary “Nuts–LSP VC format” by aligning with recognized international standards.
- Preserve the authoritative role of existing registers and trust frameworks.
- Prepare for future implementations and evolutions, such as **DEZI**.

7 Requirements & onderzoeksvragen

7.1 Inleiding

Dit hoofdstuk beschrijft de requirements en onderzoeksvragen voor de harmonisatie van de vertrouwensmodellen van het Nuts-netwerk en de AORTA-infrastructuur van VZVZ. Het doel is om tot een gedeeld authenticatie- en identificatieframework te komen waarbinnen beide infrastructuren kunnen samenwerken, zonder dat de bestaande werking van het LSP of het Nuts-netwerk wordt aangetast.

De requirements zijn opgebouwd van generiek naar specifiek. We beginnen met overkoepelende harmonisatie-eisen die gelden ongeacht de gekozen technische oplossing. Vervolgens worden per VWS Generieke Functie — lokalisatie, identificatie, authenticatie en adressering — de specifieke eisen beschreven. Voor lokalisatie en adressering stellen we hoog over eisen op en verwijzen we grotendeels naar bestaande uitwerkingen. Identificatie en authenticatie vormen de kern van dit hoofdstuk, omdat de vertrouwensmodellen van beide infrastructuren hier op elkaar gelegd moeten worden.

Het hoofdstuk sluit af met een overzicht van open onderzoeksvragen en designkeuzes waar de requirements nog niet eenduidig zijn. Bij elke onderzoeksvraag wordt beschreven welke impact de mogelijke keuzes hebben op de oplossing als geheel.

7.2 Uitgangspunten en scope

7.2.1 Scope

Dit hoofdstuk behandelt de VWS Generieke Functies lokalisatie, identificatie, authenticatie en adressering. Autorisatie en toestemming vallen buiten scope. Voor lokalisatie en adressering zijn reeds uitwerkingen beschikbaar, dit hoofdstuk stelt alleen generieke eisen relevant voor de harmonisatie. Identificatie en authenticatie vormen de kern van dit hoofdstuk.

7.2.2 Stip op de horizon

De ambitie is een geharmoniseerd vertrouwensmodel waarin:

- Alle deelnemende partijen identificeerbaar en authenticeerbaar zijn ongeacht het netwerk waaruit ze afkomstig zijn
- Deelname mogelijk is zonder afhankelijkheid van specifieke hardware-tokens zoals de UZI-pas
- Nieuwe partijen en netwerken kunnen toetreden zonder dat bestaande deelnemers aanpassingen hoeven te doen

7.2.3 Huidig vertrekpunt

Niet alle ambities zijn op dit moment realiseerbaar. De requirements maken daarom onderscheid tussen wat nu haalbaar is (MOET) en wat op termijn gewenst is (ZOU MOETEN). Dit initiatief opereert binnen de bredere landelijke transitie van afsprakenstelsels. Hoewel het een geïsoleerd initiatief betreft, zoekt het aansluiting bij landelijke ontwikkelingen en streeft het ernaar als koploper richting te geven.

7.3 Eisen aan de Harmonisatie

Overkoepelend (interoperabiliteit, backward compatibility, governance)

ID	Requirement	Rationale
1	De huidige Nuts- en LSP-toepassingen MOETEN ongestoord blijven functioneren tijdens en na de harmonisatie	Continuïteit van zorg mag niet in gevaar komen door infrastructuurwijzigingen
2	Bestaande autorisatierichtlijnen en het huidige trust framework MOETEN ongewijzigd blijven	De harmonisatie richt zich op de authenticatielaag, niet op het aanpassen van bestaande autorisatieafspraken

3	Nuts-nodes MOETEN als zelfstandig (Twiin-)knooppunt functioneren, waarmee het Nuts-netwerk decentraal wordt ontsloten	Het decentrale karakter van het Nuts-netwerk moet behouden blijven binnen de geharmoniseerde infrastructuur
4	De geharmoniseerde afspraken MOETEN passen binnen het landelijke GIS en opneembaar zijn in afsprakenstelsels zoals Twiin	Het doel is een landelijke infrastructuur, niet een 1-op-1 koppeling
5	De oplossing ZOU bruikbaar MOETEN zijn zonder dat zorgmedewerkers (met name in de VVT-sector) verplicht een UZI-pas nodig hebben	Veel Nuts-partijen in de VVT beschikken momenteel niet over UZI-passen. Dit is op dit moment nog niet mogelijk, maar is een wens om adoptie niet te blokkeren
6	Partijen MOETEN gefaseerd kunnen aansluiten zonder dat alle deelnemers gelijktijdig moeten overstappen	Een gelijktijdige overgang is niet realistisch bij landelijke schaal met diverse partijen
7	De implementatiedrempel voor toetreding ZOU minimaal MOETEN zijn, met name voor kleinere organisaties en leveranciers	De VVT- en eerstelijnssector kennen veel kleinere organisaties met beperkte IT-capaciteit
8	De oplossing MOET geen vendor lock-in creëren en open standaarden gebruiken	Interoperabiliteit en keuzevrijheid zijn kernprincipes van zowel Nuts als het bredere Twiin-stelsel
9	Het LSP MOET LSP-deelnemers transparant via een (Twiin-)knooppunt toegang bieden tot het landelijk netwerk, zonder dat deelnemers hiervan kennis hoeven te hebben of aanpassingen hoeven te doen	Transparantie voor achterliggende partijen verlaagt de adoptiedrempel en voorkomt dat de harmonisatie doorwerkt in bestaande implementaties
10	Deelnemers aan het ene netwerk ZOUDEN NIET verplicht MOETEN worden een (verwerkers)overeenkomst aan te gaan met een knooppunt of infrastructuurpartij van het andere netwerk om gegevens te kunnen uitwisselen	Partijen moeten kunnen deelnemen aan gegevensuitwisseling zonder juridische afhankelijkheid van infrastructuurpartijen waarmee zij geen directe relatie hebben
11	De oplossing ZOU zoveel mogelijk gebruik MOETEN maken van de landelijke generieke functies.	VWS ontwikkeld samen met het veld generieke functies voor vertrouwen. Deze zijn echter nog in ontwikkeling en niet allemaal al beschikbaar. Een eventuele tijdelijke oplossing probeert zoveel mogelijk in lijn met deze landelijke ontwikkelingen te zijn.

7.4 Eisen aan Lokalisatie

De lokalisatiefunctie maakt indien beschikbaar gebruik van de Nationale Verwijs Index (NVI) zoals is beschreven in de Generieke Functies Lokalisatie specificatie (nog in ontwikkeling). De NVI stelt zorgverleners in staat om te ontdekken welke organisaties relevante patiëntgegevens van een bepaald type beschikbaar hebben. Onderstaande requirements beschrijven de eisen die de harmonisatie stelt aan deze lokalisatiefunctie.

ID	Requirement	Rationale
LOK-01	Zowel partijen aangesloten via het LSP als via het Nuts-netwerk MOETEN lokalisatierecords kunnen registreren bij de NVI	Beide netwerken moeten gelijkwaardig kunnen deelnemen aan de nationale verwijsindex
LOK-02	Zowel partijen aangesloten via het LSP als via het Nuts-netwerk MOETEN de NVI kunnen bevragen om datahouders voor een specifieke patiënt en gegevenstype te vinden	De lokalisatiefunctie moet netwerkagnostisch bruikbaar zijn
LOK-03	Het LSP MOET lokalisatierecords namens haar achterliggende systemen kunnen registreren en beheren, zonder dat die systemen hier zelf actie voor hoeven te ondernemen	Consistent met HAR-010; het LSP fungeert als knooppunt en abstraheert de complexiteit voor achterliggende partijen

LOK-04	De authenticatie-attributen die de NVI vereist (URA, organisatietype, UZI/DEZI, rolcode) MOETEN afleidbaar zijn uit het geharmoniseerde authenticatiemodel	De NVI stelt eisen aan de identiteit van de bevragende partij, het authenticatiemodel moet deze attributen kunnen leveren, ongeacht het netwerk van herkomst

7.5 Eisen aan Identificatie

7.5.1 Partijen en rollen

Deze sectie beschrijft welke entiteiten deelnemen aan gegevensuitwisseling en aan welke eisen hun identificatie moet voldoen. Het gaat hier om de partijen zelf en de wijze waarop zij eenduidig herkenbaar zijn binnen het geharmoniseerde model. De relaties tussen deze partijen worden behandeld in sectie 5.2 en 5.3.

ID	Requirement	Rationale
IDENT-001	Zorginstellingen MOETEN identificeerbaar zijn aan de hand van het URA-nummer, uitgegeven door het CIBG (LRZa)	Het URA-nummer is de landelijk erkende identifier voor zorginstellingen
IDENT-002	Niet-zorginstellingen (zoals dienstverleners en softwareleveranciers) MOETEN identificeerbaar zijn aan de hand van het KVK-nummer	Dienstverleners zijn niet geregistreerd in zorgspecifieke registers; het Handelsregister is de autoritatieve bron
IDENT-003	Zorgverleners MOETEN identificeerbaar zijn aan de hand van het UZI/DEZI-nummer, uitgegeven door het CIBG	Het UZI/DEZI-nummer is de landelijk erkende identifier voor zorgprofessionals
IDENT-004	Patiënten MOETEN identificeerbaar zijn aan de hand van het BSN, met de BRP als autoritatieve bron	Het BSN is de wettelijk verplichte identifier voor patiënten in de Nederlandse zorg
IDENT-005	Zorginstellingen MOETEN classificeerbaar zijn op basis van organisatietype aan de hand van een gestandaardiseerd classificatiesysteem	Verschillende toepassingen vereisen kennis van het type organisatie (ziekenhuis, huisartsenpraktijk, apotheek, etc.) voor beleids- en autorisatiebeslissingen
IDENT-006	Sub-organisatorische eenheden (afdelingen, locaties, zorgdiensten) MOETEN identificeerbaar zijn via lokaal toegekende identifiers, met een aantoonbare relatie tot de bovenliggende organisatie (URA)	Het URA-register dekt geen sub-organisatorische eenheden, maar deze moeten wel herleidbaar zijn tot de verantwoordelijke organisatie
IDENT-007	Elke identiteitsclaim MOET afkomstig zijn van de autoritatieve bron die verantwoordelijk is voor het betreffende attribuut	Elke identiteitseigenschap (professionele kwalificatie, organisatieregistratie, rolbenoeming) heeft een aangewezen autoritatieve bron. Claims van andere partijen kunnen niet vertrouwd worden
IDENT-008	Het identificatieframework MOET pseudonimisering van patiëntidentificatie ondersteunen waar dit vereist is	Privacywetgeving en specifieke toepassingen kunnen vereisen dat het BSN niet direct wordt uitgewisseld
IDENT-009	Het MOET mogelijk zijn om nieuwe typen claims en autoritatieve bronnen toe te voegen zonder wijzigingen aan	De zorgsector ontwikkelt continu nieuwe uitwisselingsscenario's; het model moet uitbreidbaar zijn zonder bestaande partijen te raken

	bestaande infrastructuur of implementaties	

7.5.2 Verhoudingen tussen partijen

Deze sectie beschrijft de fundamentele relaties tussen de partijen uit sectie 5.1. Het gaat hier om de structurele verhoudingen: welke partijen namens welke andere partijen mogen handelen, hoe verantwoordelijkheid is belegd, en welke principes gelden voor het identiteitsmodel als geheel. De concrete eisen aan hoe deze verhoudingen worden ingericht, beheerd en gecontroleerd — met name op het gebied van delegatie — worden uitgewerkt in sectie 5.3.

ID	Requirement	Rationale
IDENT-010	Een zorginstelling MOET bevoegdheden kunnen toekennen aan een derde partij om namens haar te handelen in het digitale domein	Zorginstellingen besteden IT-dienstverlening uit aan dienstverleners (EPD-leveranciers, MSPs). Dit moet expliciet gemodelleerd zijn
IDENT-011	Een dienstverlener MOET meerdere zorginstellingen kunnen bedienen	Dienstverleners opereren doorgaans als multi-tenant; het model moet dit ondersteunen
IDENT-012	Een zorginstelling KAN uitsluitend bevoegdheden delegeren die zij zelf bezit	Subdelegatie van bevoegdheden die de zorginstelling zelf niet heeft, is niet toegestaan
IDENT-013	Delegatie van handelingsbevoegdheid MAG NIET worden geïnterpreteerd als overdracht van verantwoordelijkheid; de zorginstelling blijft verantwoordelijk	De wettelijke en inhoudelijke verantwoordelijkheid blijft bij de zorginstelling, ook wanneer een dienstverlener namens haar handelt
IDENT-014	Een claim MOET altijd betrekking hebben op de partij die er het onderwerp van is; de presenterende partij en het onderwerp van de claim MOGEN verschillend zijn	Zonder dit onderscheid is delegatie niet mogelijk. De semantiek moet correct blijven: een claim over een zorginstelling blijft een claim over die zorginstelling, ook als een dienstverlener deze presenteert

7.5.3 Delegatie

Sectie 5.2 beschrijft dat partijen namens elkaar kunnen handelen en welke principes daarbij gelden. Deze sectie werkt uit welke eisen gesteld worden aan de delegatie zelf: hoe bevoegdheden worden toegekend en afgebakend, hoe delegaties controleerbaar en intrekbaar zijn, en welke eigenschappen een delegatiebewijs moet hebben. Eisen aan de verificatie en presentatie van delegatiebewijzen — het technische proces van aantonen en controleren — worden behandeld in sectie 6 (Authenticatie).

ID	Requirement	Rationale
IDENT-015	De toegekende bevoegdheden MOETEN duidelijk en expliciet afgebakend zijn	Onbegrensde delegatie creëert onacceptabele risico's. De scope (toepassingen, handelingen, diensten) moet eenduidig zijn
IDENT-016	Een zorginstelling MOET meerdere delegaties parallel kunnen afgeven aan verschillende dienstverleners	Zorginstellingen werken vaak met meerdere leveranciers (EPD, beeldvorming, lab). Elke relatie moet onafhankelijk beheerbaar zijn
IDENT-017	Delegaties MOETEN zowel tijdelijk als structureel kunnen zijn	Sommige relaties zijn projectmatig of tijdelijk; andere zijn langlopend
IDENT-018	Het MOET ondubbelzinnig vaststelbaar zijn welke dienstverlener namens welke zorginstelling handelt	Regelgeving (NEN 7510, AVG/GDPR) vereist herleidbare verantwoordelijkheid. De relatie moet onweerlegbaar zijn

IDENT-019	De zorginstelling MOET een delegatie direct kunnen intrekken	Zorginstellingen moeten de controle behouden over wie namens hen handelt
IDENT-020	Delegaties MOETEN onafhankelijk controleerbaar zijn door derden, zonder tussenkomst van de betrokken partijen op het moment van controle	Een verifiërende partij moet op het moment van een transactie de geldigheid van een delegatie kunnen vaststellen zonder afhankelijk te zijn van de beschikbaarheid van de delegerende of gedelegeerde partij
IDENT-021	Het gebruik van delegaties MOET auditeerbaar zijn	Voor compliance en verantwoording moet vastgelegd kunnen worden wanneer en hoe delegaties zijn gebruikt
IDENT-022	Wanneer een partij een claim presenteert over een andere partij, MOET hiervoor een expliciete en verifieerbare autorisatie bestaan	Het presenteren van claims namens een ander zonder aantoonbare toestemming ondermijnt het vertrouwensmodel
IDENT-023	Het delegatiebewijs MOET expliciet vastleggen dat de zorginstelling de dienstverlener autoriseert om namens haar te handelen	Impliciete delegatie (bv. via gedeelde certificaten of technische authenticatierelaties) ondermijnt de verantwoording
IDENT-024	Het delegatiebewijs MOET expliciet vastleggen dat de dienstverlener geautoriseerd is om claims over de zorginstelling te presenteren	Autorisatie om te handelen en autorisatie om claims te presenteren zijn twee verschillende bevoegdheden die beide expliciet moeten zijn
IDENT-025	Het delegatiemodel MOET onafhankelijke intrekking van delegatiebewijzen ondersteunen	Gecompromitteerde of ingetrokken delegaties moeten beëindigd kunnen worden. De controle hierover ligt bij de zorginstelling (zie IDENT-019)
IDENT-026	Dienstverleners MOETEN aantoonbaar zijn toegelaten tot het stelsel waarbinnen zij opereren, op basis van door het stelsel gestelde eisen (bv. certificeringen, kwalificaties)	Alleen gekwalificeerde partijen mogen deelnemen aan gegevensuitwisseling. Toelating is een voorwaarde voor het verkrijgen van delegaties

7.6 Eisen aan Authenticatie

7.6.1 Generieke authenticatie-eisen

Deze sectie beschrijft de overkoepelende eisen aan het authenticatieproces. Het gaat om functionele en beveiligingseisen die gelden ongeacht de gekozen technische implementatie. Specifieke eisen aan sleutelmateriaal, verificatie van delegatie, wallets, presentatie en het OAuth-profiel worden in de volgende secties behandeld.

ID	Requirement	Rationale
AUTH-001	Het MOET mogelijk zijn om claims van verschillende autoritatieve bronnen te combineren in een enkele transactie	Een interactie kan bewijs vereisen van organisatie-identiteit (URA-register), professionele kwalificatie (BIG-register) en rolbenoeming (werkgever) -- alle van verschillende bronnen
AUTH-002	Een verifiërende partij MOET de volledige vertrouwensketen kunnen valideren zonder op het moment van verificatie contact te hoeven maken met de uitgever van de claim	Runtime-afhankelijkheden van externe systemen creëren beschikbaarheids- en prestatierisico's

AUTH-003	Alleen de claims die noodzakelijk zijn voor een specifieke transactie MOGEN gedeeld worden met de verifiërende partij. Dit geldt zowel per transactie als per bronhouder	Privacywetgeving (AVG/GDPR) vereist dataminimalisatie. Een bronhouder mag alleen de claims ontvangen die relevant zijn voor de interactie met die specifieke bronhouder
AUTH-004	Authenticatiestromen MOETEN zowel interacties met als zonder directe betrokkenheid van een eindgebruiker ondersteunen	De zorgsector vereist zowel door zorgverleners geïnitieerde toegang als geautomatiseerde systeem-naar-systeem communicatie (labresultaten, notificaties)
AUTH-005	Authenticatie MOET gebruiksvriendelijk zijn voor zorgverleners; herhaalde authenticatie per transactie MOET vermeden worden	Zorgverleners werken onder tijdsdruk. Herhaalde authenticatie verstoort het klinische werkproces en verlaagt adoptie
AUTH-006	Het authenticatieframework MOET flexibel omgaan met veranderende identificatiemiddelen en -voorzieningen	Er zal altijd een huidige en een volgende generatie identificatiemiddelen naast elkaar bestaan (bv. UZI-passen, servercertificaten, DEZI, DigiD). De oplossing mag niet gekoppeld zijn aan één specifiek middel of voorziening
AUTH-007	Het authenticatieframework MOET meerdere deployment-modellen ondersteunen (geïntegreerde systemen, managed services, cloudoplossingen) zonder wijzigingen aan de specificatie	Organisaties hebben uiteenlopende technische volwassenheid en leveranciersrelaties. De specificatie definieert interoperabiliteit op de grens, niet interne implementatiekeuzes
AUTH-008	Authenticatie tussen twee partijen MAG NIET afhankelijk zijn van de runtime-beschikbaarheid van derde partijen	Landelijke zorginfrastructuur kan niet afhankelijk zijn van componenten waarvan de uitval authenticatie zou blokkeren

7.6.2 Sleutelmateriaal & PKI

Deze sectie beschrijft de eisen aan digitale handtekeningen, sleutelbeheer en de publieke sleutelinfrastructuur. Het betreft de fundamenten waarop het authenticatieproces is gebouwd: hoe partijen cryptografisch bewijzen wie ze zijn en hoe sleutelmateriaal wordt beheerd.

ID	Requirement	Rationale
AUTH-009	Deelnemers aan het netwerk (issuers, verifiers, dienstverleners, zorginstellingen) MOETEN claims kunnen ondertekenen met digitale handtekeningen	Vertrouwen tussen partijen wordt gevestigd via cryptografisch bewijs. Digitale handtekeningen stellen partijen in staat verifieerbare uitspraken te doen
AUTH-010	Er MOET een publieke sleutelinfrastructuur bestaan waarmee elke partij het sleutelmateriaal van een andere partij kan achterhalen	Verifiers moeten publieke sleutels kunnen verkrijgen om handtekeningen op claims en assertions te valideren. Dit mag niet afhankelijk zijn van de beschikbaarheid van de ondertekende partij op het moment van verificatie
AUTH-011	Elke deelnemer aan het netwerk MOET een unieke technische identifier hebben die herleidbaar is naar het bijbehorende sleutelmateriaal	Om een handtekening te verifiëren moet de verifier de publieke sleutel van de ondertekenaar kunnen opzoeken via een stabiele technische identifier
AUTH-012	Technische identifiers MOETEN gescheiden zijn van business identifiers (zoals URA, KVK, UZI)	Business identifiers dienen andere doeleinden (wettelijke registratie, professionele kwalificatie) en hebben een andere levenscyclus en governance. Koppeling creëert afhankelijkheden en beperkingen

AUTH-013	De resolutie van identifiers naar sleutelmateriaal MOET beveiligd zijn tegen manipulatie en impersonatie, en de binding tussen een technische identifier en het bijbehorende sleutelmateriaal MOET cryptografisch verifieerbaar zijn	Deze resolutie staat aan de basis van het vertrouwen in het stelsel. De beveiliging moet proportioneel zijn aan de rol van de partij in het stelsel
AUTH-014	Elke partij is juridisch eigenaar van het eigen sleutelmateriaal; sleutels en certificaten MOGEN NIET gedeeld worden tussen organisaties. Het operationele beheer van sleutelmateriaal MAG worden uitbesteed, mits dit expliciet is geautoriseerd	Juridisch eigenaarschap waarborgt verantwoordelijkheid en aansprakelijkheid. Dit is fundamenteel anders dan de huidige situatie waarin private keys van certificaten vaak verspreid zijn over partijen die het certificaat technisch nodig hebben. Uitbesteding van operationeel beheer is toegestaan, maar het eigenaarschap en de verantwoordelijkheid blijven bij de organisatie
AUTH-015	Organisaties MOETEN meerdere sleutels kunnen beheren voor verschillende doeleinden (bv. ondertekenen van credentials vs. ondertekenen van presentaties). Het beoogde gebruik van elke sleutel MOET vastgelegd zijn in metadata. Hergebruik van één sleutel voor meerdere doeleinden of vertrouwensdomeinen is NIET TOEGESTAAN	Scheiding van sleutels beperkt de impact van compromittering en maakt fijnmazige delegatie mogelijk. Een partij die geautoriseerd is om presentaties te ondertekenen mag niet automatisch credentials kunnen uitgeven
AUTH-016	Elke cryptografische sleutel MOET één expliciete juridische eigenaar hebben; delegatie van gebruik is niet gelijk aan delegatie van eigenaarschap	Nodig voor aansprakelijkheid, incidentafhandeling en intrekking
AUTH-017	Sleutelmateriaal MOET vervangbaar zijn zonder wijziging van de bijbehorende technische identifier, waar de situatie dit vereist	Voor sommige rollen in het stelsel (bv. issuers) is sleutelrotatie essentieel vanwege de langdurige geldigheid van uitgegeven claims. Voor andere rollen (bv. holders met kortlopende presentaties) is de noodzaak minder groot. De identifier moet stabiel kunnen blijven om referenties en audithistorie te behouden, maar niet elke technische identifier-methode ondersteunt dit (bv. did:key)
AUTH-018	Intrekking van sleutels die bedoeld zijn voor het ondertekenen van claims MOET mogelijk zijn per individuele sleutel en MOET direct detecteerbaar zijn door verifiërende partijen	Gecompromitteerde signing-sleutels hebben de grootste impact omdat de claims die ermee ondertekend zijn langdurig geldig kunnen zijn. De eisen aan intrekking van sleutels voor andere doeleinden (bv. presentaties) vereisen nader onderzoek (zie OV-013)

7.6.3 Verificatie & presentatie van delegatie

Sectie 5.3 beschrijft de inhoudelijke eisen aan het delegatiemodel. Deze sectie beschrijft hoe delegaties en claims worden gepresenteerd en geverifieerd als onderdeel van het authenticatieproces.

ID	Requirement	Rationale
AUTH-019	De rollen zorgaanbieder en dienstverlener MOETEN altijd als apart identificeerbare entiteiten zichtbaar zijn	Ongeacht wie technisch welke sleutels beheert of hoe de operationele inrichting eruitziet, moeten beide rollen en hun relatie expliciet zijn. Dit geldt

	in het authenticatieproces, en er MOET altijd een expliciete delegatie tussen hen bestaan	ook wanneer een zorginstelling haar eigen dienstverlener is
AUTH-020	Claims die in een enkele presentatie worden gecombineerd MOETEN altijd betrekking hebben op hetzelfde subject (dezelfde organisatie)	Het combineren van claims over verschillende subjecten in één presentatie leidt tot complexe validatieregels en vergroot het risico op fouten bij verificatie
AUTH-021	Een verifiërende partij MOET het delegatiebewijs controleren voordat zij claims of beschermde gegevens accepteert	Gevoelige informatie mag niet gelekt worden aan ongeautoriseerde partijen. Verificatie moet plaatsvinden vóór de inhoudelijke uitwisseling
AUTH-022	Verifiërende partijen MOETEN de intrekkingsstatus van delegatiebewijzen kunnen vaststellen zonder synchrone calls naar de uitgever	Intrekking van een delegatie heeft een cascade-effect op alle claims die eronder vallen, wat het anders maakt dan intrekking van een individuele claim. Statusinformatie moet asynchroon opvraagbaar en cacheable zijn
AUTH-023	Dienstverleners die namens zorginstellingen opereren MOETEN verifieerbare delegatiebewijzen publiceren op een vindbare locatie	Verifiërende partijen moeten delegatiebewijzen kunnen verkrijgen en controleren vóór het initiëren van een authenticatieverzoek
AUTH-024	Verifiërende partijen MOETEN de delegatie van een zorginstelling aan een dienstverlener kunnen verifiëren voordat zij identiteitsclaims of beschermde gegevens versturen	Partijen mogen geen gevoelige data lekken aan ongeautoriseerde partijen. Delegatieverificatie moet plaatsvinden voordat de verifiërende partij claims of patiëntdata verstuurt

7.6.4 Wallet-beheer

In de context van dit document is een wallet de plek waar een partij sleutels, claims en delegaties beheert. Deze sectie beschrijft de eisen aan het beheer van wallets. De vraag wie welke wallet beheert heeft directe gevolgen voor de operationele last, beveiliging en autonomie van de betrokken partijen.

ID	Requirement	Rationale
AUTH-025	Elke partij (zorginstelling, dienstverlener) MOET in staat zijn een eigen wallet te beheren	Autonomie en onafhankelijkheid zijn essentieel; partijen mogen niet gedwongen worden hun claims en sleutels door een andere partij te laten beheren
AUTH-026	Het MOET voor een verifiërende partij niet uitmaken wie het operationele beheer van een wallet voert, mits de presentatie cryptografisch geldig is en de delegatiebewijzen correct zijn	De verificatielogica moet gebaseerd zijn op cryptografische validiteit, niet op kennis van de interne organisatie van de presenterende partij

7.6.5 Presentatie-model

Deze sectie beschrijft de eisen aan hoe claims worden aangeboden aan een verifiërende partij. In dit hoofdstuk gebruiken we de term "claim" voor een verifieerbare uitspraak over een subject, en "presentatie" voor het geheel aan claims dat in een transactie wordt aangeboden. Hiermee wordt geen specifieke technologie (zoals W3C Verifiable Credentials) voorgeschreven.

ID	Requirement	Rationale
AUTH-027	Het presentatie-model MOET een duidelijke scheiding aanbrengen tussen de identiteit van de dienstverlener en de identiteit van de zorginstelling namens wie gehandeld wordt	Voor audit en compliance moet ondubbelzinnig zijn wie de handeling uitvoert en namens wie (zie IDENT-018)

AUTH-028	Het presentatie-model MOET ondersteunen dat claims over zowel de dienstverlener als de zorginstelling in dezelfde transactie worden overgedragen	Een verifiërende partij heeft in één transactie informatie nodig over zowel de handelende partij als de verantwoordelijke organisatie
AUTH-029	Claims die in een presentatie zijn opgenomen MOETEN cryptografisch gebonden zijn aan de presentatie, zodat ze niet herbruikbaar zijn buiten de context van die presentatie	Losse claims die buiten een presentatie hergebruikt kunnen worden, creëren risico's op replay-aanvallen en ongeautoriseerd gebruik

7.6.6 OAuth-profiel

Het OAuth 2.0-framework wordt gebruikt als basis voor het authenticatieprotocol. In OAuth zijn de volgende rollen relevant:

- **Client**: het systeem dat namens een gebruiker of organisatie toegang vraagt tot beschermde gegevens. In de context van dit stelsel is de client doorgaans het systeem van de dienstverlener.
- **Authorization Server (AS)**: het systeem dat de identiteit en bevoegdheden van de client vaststelt en een access token uitgeeft. De AS opereert namens de bronhouder (de zorginstelling die de gegevens beheert).
- **Resource Server (RS)**: het systeem dat de beschermde gegevens beheert en toegang verleent op basis van een geldig access token. De RS opereert eveneens namens de bronhouder.
- **Relying Party**: de partij die vertrouwt op de informatie in het access token om autorisatiebeslissingen te nemen. In de praktijk is dit doorgaans de resource server.

De belangrijkste interactie is het token request: de client stuurt claims over zichzelf en de partijen namens wie het handelt naar de authorization server, die na verificatie een access token uitgeeft. Dit access token wordt vervolgens gebruikt bij de resource server om toegang te krijgen tot gegevens.

Belangrijk: OAuth authenticert niet alleen de eindgebruiker maar ook de client zelf. In dit stelsel betekent dat dat de dienstverlener zich als client identificeert en authenticeert bij de authorization server, op dezelfde wijze als andere deelnemers in het stelsel: via verifieerbare claims uitgegeven door autoritatieve bronnen.

ID	Requirement	Rationale
OAUTH-001	Het OAuth-profiel MAG NIET vereisen dat clients vooraf geregistreerd of geconfigureerd worden bij elke authorization server, noch dat authorization servers lijsten van goedgekeurde partijen bijhouden	Traditionele OAuth-clientregistratie en onderhouden lijsten schalen niet wanneer veel clients met veel authorization servers moeten communiceren. Clienttoelating moet worden bepaald op basis van verifieerbare claims die at runtime worden gepresenteerd
OAUTH-002	Clients MOETEN verifieerbare claims over hun identiteit en kwalificaties kunnen meesturen als onderdeel van het token request. Hierbij MOET onderscheid gemaakt worden tussen de technische identifier van de client en de business identifiers van de partijen namens wie het handelt	Autorisatiebeslissingen kunnen afhangen van clienteigenschappen (bv. NEN 7510-certificering). De scheiding tussen technische en business identifiers voorkomt ongewenste koppeling en waarborgt flexibiliteit
OAUTH-003	Een vertrouwde autoriteit MOET verifieerbare claims kunnen uitgeven over de identiteit en capaciteiten van een client (bv. softwarecertificering, netwerklidmaatschap)	Authorization servers hebben zekerheid nodig dat clients aan bepaalde standaarden voldoen. Een netwerkautoriteit of certificeringsinstantie kan verifieerbare

		claims leveren zonder bilaterale registratie
OAUTH-004	Het OAuth-profiel MOET een back-channel token request flow ondersteunen (zonder user-agent redirect)	Veel zorginteracties zijn systeem-naar-systeem zonder gebruikersbetrokkenheid (AUTH-004). Back-channel flows verbeteren ook de gebruikerservaring door herhaalde browser-redirects te vermijden (AUTH-005)
OAUTH-005	Het token request MOET ondersteunen dat de client claims presenteert over twee subjecten: de zorginstelling namens wie gehandeld wordt en de dienstverlener die de handeling uitvoert. Claims over een medewerker van de zorginstelling vallen onder het subject van de zorginstelling	Een verifiërende partij moet in één transactie kunnen vaststellen wie de verantwoordelijke organisatie is en wie de handeling uitvoert. De medewerker ondertekent niet zelf (zie AUTH-005), maar wordt vertegenwoordigd via een delegatie aan de zorginstelling
OAUTH-006	Het token request MOET een duidelijk onderscheid maken tussen de partij die het token aanvraagt (client) en de partijen namens wie toegang wordt gevraagd (subjecten)	Delegatiescenario's vereisen expliciete identificatie van alle betrokken partijen (IDENT-018). Clientauthenticatie en de autorisatie-grant dienen verschillende doelen
OAUTH-007	Claims die in het token request worden gepresenteerd MOETEN cryptografisch ondertekend zijn door de juiste partij	De verifier moet kunnen valideren dat claims afkomstig zijn van de geclaimde uitgever en gepresenteerd worden door de legitieme houder
OAUTH-008	Access tokens MOETEN gebonden zijn aan de business identifier (URA) van de zorginstelling waarvoor het token is uitgegeven. De AS is per URA adresseerbaar via een identifier in het token endpoint path	Een authorization server kan namens meerdere zorginstellingen opereren. Het token moet ondubbelzinnig de verantwoordelijke zorginstelling identificeren. De URA als audience voorkomt dat tokens bruikbaar zijn buiten de beoogde context
OAUTH-009	Het OAuth-profiel MOET scope-gebaseerde toegangscontrole ondersteunen, afgestemd op use-case-specifieke eisen	Verschillende toepassingen vereisen verschillende toegangsniveaus. Scope-gebaseerde toegangscontrole is vereist voor compatibiliteit met SMART-on-FHIR en andere zorg-OAuth-profielen
OAUTH-010	Access tokens MOETEN cryptografisch gebonden zijn aan de client, en de client MOET deze binding aantoonbaar maken bij elk gebruik van het token. Dit mechanisme MOET replay-bescherming bevatten	Bearer tokens kunnen gestolen en hergebruikt worden. Cryptografische token binding waarborgt dat alleen de legitieme client het token kan gebruiken. Replay-bescherming voorkomt dat onderschepte bewijzen hergebruikt worden
OAUTH-011	Het OAuth-profiel MOET ondersteunen dat eindgebruiker-authenticatie losgekoppeld is van de token request flow, zodat een gebruiker eenmaal per sessie authenticeert en het resultaat herbruikbaar is in daaropvolgende back-channel verzoeken. Wanneer interactieve authenticatie vereist is (bv. initiële login, step-up) MOET een front-channel flow beschikbaar zijn	Zorgverleners moeten eenmaal per sessie authenticeren (AUTH-005). Een front-channel flow is nodig voor scenario's waar interactie met de gebruiker vereist is, bv. via een Identity Provider

OAUTH-012	Het OAuth-profiel MOET authorization servers ondersteunen die namens meerdere zorginstellingen opereren (multi-tenant)	Veel zorginstellingen maken gebruik van gedeelde infrastructuur of managed services. Het token request moet de specifieke organisatiecontext identificeren
OAUTH-013	Authorization servers MOETEN de delegatierelaties met de zorginstellingen waarvoor zij opereren publiceren op een vindbare locatie, en deze MOETEN cryptografisch verifieerbaar zijn met het sleutelmateriaal van de zorginstelling zonder runtime-contact met de zorginstelling	Clients moeten delegatie-informatie kunnen verkrijgen en verifiëren voordat zij identiteitsclaims versturen (AUTH-024). Onondertekende of zelfverklaarde delegatieclaims kunnen niet vertrouwd worden
OAUTH-014	Access tokens MOETEN opaque zijn voor clients	Clients mogen tokeninhoud niet parsen of ervan afhankelijk zijn. Dit ontkoppelt de clientimplementatie van het interne tokenformaat van de authorization server
OAUTH-015	Resource servers MOETEN access tokens kunnen valideren en identiteitsclaims kunnen extraheren	Resource servers hebben identiteitsinformatie nodig voor autorisatiebeslissingen en auditlogging
OAUTH-016	Het OAuth-profiel MOET intrekking van claims die in token requests worden gebruikt ondersteunen. Intrekkingsstatus MOET controleerbaar zijn zonder synchrone calls naar de uitgever	Gecompromitteerde of ingetrokken claims moeten detecteerbaar zijn. Intrekkingscontroles mogen geen runtime-afhankelijkheden creëren
OAUTH-017	Token requests MOETEN minimale disclosure ondersteunen -- alleen de claims die noodzakelijk zijn voor de specifieke transactie MOGEN worden opgenomen	Privacy-by-design vereist dat verifiers alleen de informatie ontvangen die nodig is voor hun autorisatiebeslissing (AUTH-003)
OAUTH-018	Het OAuth-profiel MOET sleutelrotatie ondersteunen zonder wijzigingen aan identifiers of configuratie bij andere partijen	Operationele beveiliging vereist periodieke sleutelvervanging. De token request flow moet bijgewerkt sleutelmateriaal accommoderen zonder bestaande relaties te verstoren (AUTH-017)

7.7 Eisen aan Adressering

De adresseringsfunctie is gebaseerd op het IHE mCSD-profiel en uitgewerkt in de Care Services Directory IG. Onderstaande requirements beschrijven de eisen die de harmonisatie stelt aan (de inrichting van) deze adresseringsfunctie.

ID	Requirement	Rationale
1	Technische endpoints moeten op basis van een URA vindbaar zijn	Partijen uit beide netwerken moeten elkaars systemen kunnen vinden zonder voorkennis van de technische infrastructuur
2	Het LSP MOET de endpoints van haar achterliggende systemen kunnen publiceren in de Care Services Directory, zonder dat die achterliggende systemen hier zelf actie voor hoeven te ondernemen	Het LSP fungeert als knooppunt; achterliggende partijen mogen niet belast worden met de harmonisatie.
3	Nuts-nodes MOETEN hun eigen endpoints publiceren in de Care Services Directory	Elke Nuts-node functioneert als zelfstandig knooppunt en is verantwoordelijk voor de eigen registratie

4	Een zoekend systeem MOET op basis van een URA-nummer en een toepassing of data-type het juiste endpoint kunnen vinden, ongeacht achter welk knooppunt dit endpoint zich bevindt	Het maakt voor de zoekende partij niet uit via welk knooppunt een zorginstelling bereikbaar is
5	De relatie tussen een knooppunt en de zorginstellingen waarvoor het endpoints publiceert MOET verifieerbaar zijn	Voorkomen dat ongeautoriseerde partijen endpoints registreren namens een zorginstelling
6	De adresseringsfunctie MOET nieuwe knooppunten en netwerken kunnen accommoderen zonder wijzigingen aan de bestaande registraties	Schaalbaarheid en toekomstbestendigheid
7	Endpoints MOETEN vindbaar zijn op basis van het type dienst (of data type) dat zij ondersteunen	Een zoekend systeem moet kunnen filteren op het type gegevensuitwisseling dat het wil doen, ongeacht via welk knooppunt

7.8 Open onderzoeksvragen & impactanalyse

- Deze sectie bevat een overzicht van de openstaande designkeuzes en onderzoeksvragen die voortkomen uit de requirements in de voorgaande secties. Bij elke vraag wordt beschreven welke impact de mogelijke keuzes hebben op de oplossing als geheel.

7.8.1 Credential-model

ID	Vraag	Referenties	Impact
OV-001	Moet een Verifiable Credential over een zorginstelling los staan van de dienstverlener die het gebruikt, of wordt de holder opgenomen in het VC?	AUTH-004, AUTH-006	Bij een los VC hoeft een zorginstelling per issuer maar één VC te ontvangen, ongeacht het aantal dienstverleners. Bij opname van de holder in het VC ontstaan er meerdere variaties van hetzelfde VC bij meerdere dienstverleners. Dit raakt schaalbaarheid en beheerslast
OV-002	Wie initieert het ophalen van VCs bij issuers: de dienstverlener (GTK) via een delegation, of een tekenbevoegd persoon van de zorginstelling zelf?	AUTH-005, ID-001	Dit bepaalt of een dienstverlener zelfstandig credentials kan verwerven of dat de zorginstelling hier altijd bij betrokken moet zijn. Raakt de operationele last voor zorginstellingen en de autonomie van dienstverleners
OV-003	Moet het subject.id in een VC altijd verwijzen naar de partij waar het VC over gaat?	AUTH-001	Dit is een semantische eis die bepaalt hoe VCs gestructureerd worden. Afwijking hiervan kan leiden tot interpretatieverschillen bij verifiers

7.8.2 Presentatie-model

ID	Vraag	Referenties	Impact
OV-004	Levert een initiërende holder (GTK) één VP op (met daarin alle benodigde VCs), of twee aparte VPs (één van zichzelf en één namens de zorginstelling)?	AUTH-001, AUTH-008	Bij één VP moeten er niet-standaard business rules worden geïntroduceerd omdat niet alle VCs als subject de issuer van de VP hebben. Twee VPs maken de scheiding tussen partijen expliciet en volgen het standaardmodel, maar verhogen de complexiteit van de transactie. Dit raakt het OAuth-profiel en de token request flow

7.8.3 Wallet-beheer

ID	Vraag	Referenties	Impact
OV-005	Beheert de dienstverlener zowel de wallet van de	AUTH-006, AUTH-012	Gedeeld beheer is operationeel eenvoudiger maar creëert afhankelijkheid en risico bij de

	zorginstelling als van zichzelf, of beheren zij elk hun eigen wallet?		dienstverlener. Gescheiden beheer is veiliger maar vereist meer technische volwassenheid bij zorginstellingen, met name in de VVT-sector
OV-006	Moet het voor de verifier uitmaken wie het beheer over een wallet heeft?	AUTH-003, AUTH-005	Als de verifier dit onderscheid niet hoeft te maken, vereenvoudigt dit de verificatielogica. Maar het kan gevolgen hebben voor de audittrail en verantwoording

7.8.4 Adressering

ID	Vraag	Referenties	Impact
OV-007	Hoe wordt de routering ingericht wanneer een zorginstelling via meerdere knooppunten bereikbaar is en een zoekend systeem op basis van URA en toepassing het juiste endpoint moet vinden?	ADR-004, ADR-005	Dit bepaalt de complexiteit van de Care Services Directory en heeft gevolgen voor de lookup-logica bij zoekende systemen

7.8.5 Lokalisatie

ID	Vraag	Referenties	Impact
OV-008	Hoe worden de authenticatie-attributen die de NVI vereist (URA, organisatietype, UZI/DEZI, rolcode) afgeleid uit het geharmoniseerde authenticatiemodel voor partijen die geen UZI-pas hebben?	LOK-004, HAR-005	Zonder oplossing hiervoor kunnen VVT-partijen de NVI niet bevragen. Dit is een directe blokkade voor gelijkwaardige deelname

7.8.6 Sleutelmateriaal & beveiliging

ID	Vraag	Referenties	Impact
OV-009	In hoeverre is hardware-gebaseerde sleutelgeneratie en -opslag (HSM, smartcard, secure enclave) vereist, gegeven dat dit de toetredingsdrempel verhoogt voor met name de VVT-sector?	NFR 2, NFR 3, HAR-005, HAR-007	Een harde hardware-eis blokkeert mogelijk partijen die nu geen toegang hebben tot dergelijke middelen. Zonder hardware-eis ontstaan risico's rondom sleutelcompromittering
OV-010	Is sterke gebruikersauthenticatie (2FA) vóór sleutelgebruik vereist, en hoe verhoudt dit zich tot geautomatiseerde systemen zonder eindgebruiker?	NFR 5, AUTH-004	Een 2FA-eis voorkomt ongeautoriseerd signing maar maakt machine-to-machine communicatie complexer of onmogelijk
OV-011	Moeten er vertrouwensniveaus worden gedefinieerd waarbinnen verschillende eisen gelden voor sleutelbeheer, intrekking en beveiliging, afhankelijk van de rol van de sleutel in het stelsel?	AUTH-013, AUTH-015, AUTH-017, AUTH-018	Signing-sleutels voor langlopende credentials hebben een ander risicoprofiel dan sleutels voor kortdurende presentaties. Uniforme eisen kunnen ofwel te streng zijn voor lichtgewicht rollen, ofwel te soepel voor kritieke rollen

7.8.7 Dienstverlener delegatie

ID	Vraag	Referenties	Impact
OV-012	Moet er een centraal register van toepassingen/diensten komen, en wie beheert dit?	OAUTH-009, IDENT-015	Bepaalt hoe de dienstenlijst in het ServiceProviderCredential wordt samengesteld en bijgehouden. Raakt de rol van de stelselhouder
OV-13	Hoe verhouden de scope-identifiers in credentials zich tot SMART-on-FHIR scopes en NVI data types? Is een uniforme	OAUTH-009, LOK-004	Bepaalt de complexiteit van scope-validatie bij de authorization server en de

	taxonomie haalbaar, of is een mapping tussen bestaande concepten realistischer?		inspanning die nodig is om bestaande systemen aan te sluiten
OV-14	Kunnen deelnemers onderling toepassingen afspreken buiten de stelselhouder om, en hoe wordt dit in de credentials uitgedrukt?	IDENT-015, HAR-011	Raakt de balans tussen centrale governance en decentrale autonomie. Bij een strikt centraal model moet elke nieuwe toepassing langs de stelselhouder; bij een decentraal model ontstaat het risico op fragmentatie

8 Oplossingsrichtingen

8.1 Inleiding

Dit hoofdstuk beschrijft de oplossingsrichting voor de harmonisatie van de vertrouwensmodellen van Nuts en AORTA. Het bouwt voort op de requirements uit de voorgaande hoofdstukken en beschrijft per onderwerp de gekozen richting. Waar de requirements beschrijven *wat* de oplossing moet kunnen, beschrijft dit hoofdstuk *hoe* dat wordt ingevuld.

De oplossing is gebaseerd op W3C Verifiable Credentials en Decentralized Identifiers als fundament voor het identiteits- en authenticatiemodel, gecombineerd met een OAuth 2.0-profiel voor de technische authenticatiestroom. Deze keuze maakt het mogelijk om de bestaande certificaatinfrastructuur te hergebruiken en tegelijkertijd een flexibel en toekomstbestendig model neer te zetten.

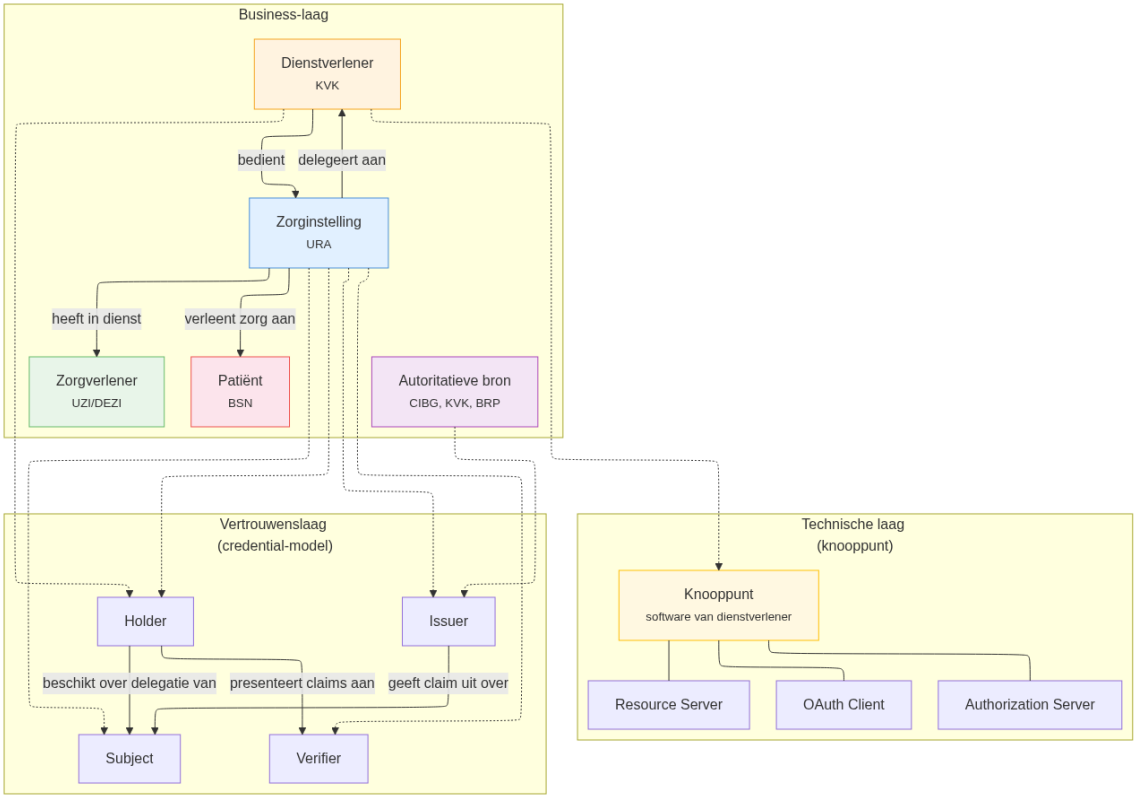
Dit hoofdstuk begint met een ontologie die de partijen, rollen en relaties in het model visueel en tekstueel beschrijft (8.2). Vervolgens wordt het identiteitsmodel uitgewerkt: welke DID-methoden worden gebruikt en welke credentials er bestaan (8.3). Daarna wordt beschreven hoe credentials worden gepresenteerd en geverifieerd (8.4), hoe het OAuth-profiel is ingericht (8.5) en hoe het sleutelmateriaal wordt beheerd (8.6). Het hoofdstuk sluit af met de oplossingsrichting voor adressering (8.7) en lokalisatie (8.8).

Waar nog geen consensus is of waar designkeuzes nog open staan, wordt verwezen naar de onderzoeksvragen in sectie 7. Bij een aantal van deze vragen wordt in dit hoofdstuk wel een voorkeursrichting beschreven.

8.2 Ontologie: partijen, rollen en relaties

Dit onderdeel beschrijft de entiteiten, rollen en relaties die centraal staan in het geharmoniseerde model. Het dient als referentiemodel voor de rest van dit hoofdstuk en de technische specificaties in hoofdstuk 10. Het model is opgebouwd in drie lagen: de business-laag (wie zijn de partijen), de vertrouwenslaag (welke rollen spelen zij in het credential-model) en de technische laag (welke componenten zijn er).

8.2.1 Overzicht



8.2.2 Business-laag

De business-laag beschrijft de partijen die deelnemen aan gegevensuitwisseling en hun onderlinge relaties.

Zorginstelling

De organisatie die verantwoordelijk is voor de zorgverlening en de gegevens van patiënten. Geïdentificeerd door een URA-nummer (IDENT-001). Een zorginstelling kan bevoegdheden delegeren aan een of meerdere dienstverleners (IDENT-010, IDENT-016), maar blijft altijd zelf verantwoordelijk (IDENT-013). Een zorginstelling kan ook haar eigen dienstverlener zijn; in dat geval vervult dezelfde organisatie beide rollen.

Dienstverlener

De partij die namens een zorginstelling handelt in het digitale domein. Geïdentificeerd door een KVK-nummer (IDENT-002). Een dienstverlener kan meerdere zorginstellingen bedienen (IDENT-011). De dienstverlener biedt een knooppunt aan waarmee de technische ontsluiting plaatsvindt.

Zorgverlener

De natuurlijke persoon die zorg verleent, in dienst van een zorginstelling. Geïdentificeerd door een UZI/DEZI-nummer (IDENT-003). In het authenticatiemodel ondertekent de zorgverlener niet zelf; de zorgverlener wordt vertegenwoordigd via de zorginstelling (AUTH-005).

Patiënt

De persoon die zorg ontvangt. Geïdentificeerd door het BSN (IDENT-004). Het BSN wordt waar nodig gepseudonimiseerd (IDENT-008).

Autoritatieve bron

Een register of instantie die verantwoordelijk is voor het uitgeven van identiteitsclaims over een specifiek attribuut (IDENT-007). Voorbeelden: CIBG (URA, UZI/DEZI), KVK (Handelsregister), BRP (BSN).

8.2.3 Vertrouwenslaag (credential-model)

De vertrouwenslaag beschrijft welke rollen de partijen uit de business-laag vervullen in het credential-model. Een partij kan meerdere rollen tegelijk vervullen.

Issuer

De partij die een verifieerbare claim uitgeeft over een subject. Autoritatieve bronnen (CIBG, KVK, BRP) zijn issuers van identiteitsclaims. Een zorginstelling is issuer van DelegationVCs waarmee zij bevoegdheden delegeert aan een dienstverlener.

Subject

De partij waar een claim betrekking op heeft. De zorginstelling is doorgaans het subject van organisatie-gerelateerde claims (URA, organisatietype, certificeringen). De presenterende partij en het subject mogen verschillend zijn (IDENT-014).

Holder

De partij die claims beheert in een wallet. De zorginstelling is juridisch altijd holder van haar eigen claims en beheert haar eigen wallet (AUTH-025). Het operationele beheer van de wallet kan worden uitbesteed aan een dienstverlener. De dienstverlener kan via een expliciet delegatiebewijs namens de zorginstelling optreden en claims aanbieden aan een verifier (IDENT-022, AUTH-022). Voor de verifier maakt het niet uit wie het operationele beheer voert, mits de cryptografische validiteit en delegatiebewijzen correct zijn (AUTH-026).

Verifier

De partij die aangeboden claims controleert voordat zij toegang verleent tot beschermde gegevens. De zorginstelling (als bronhouder, via haar dienstverlener) vervult deze rol wanneer zij toegangsverzoeken ontvangt.

8.2.4 Technische laag (knooppunt)

De technische laag beschrijft de softwarecomponenten waarmee de rollen uit de vertrouwenslaag worden gerealiseerd.

Knooppunt

Het knooppunt is de software die door de dienstverlener wordt aangeboden en beheerd. Het knooppunt bevat de volgende OAuth-componenten:

OAuth Client: Het component dat namens de dienstverlener (en de zorginstelling waarvoor deze handelt) toegang vraagt tot beschermde gegevens bij een andere partij. De client presenteert claims en delegatiebewijzen in het token request (OAUTH-002, OAUTH-005).

Authorization Server (AS): Het component dat namens de bronhouder (zorginstelling) de identiteit en bevoegdheden van een inkomende client vaststelt en een access token uitgeeft. De AS is per URA adresseerbaar (OAUTH-008) en publiceert de delegatierelatie met de zorginstelling (OAUTH-013).

Resource Server (RS): Het component dat namens de bronhouder beschermde gegevens beheert en toegang verleent op basis van een geldig access token (OAUTH-015).

Een knooppunt kan namens meerdere zorginstellingen opereren (multi-tenant, OAUTH-012). Het LSP-Gtk en Nuts-nodes zijn beide voorbeelden van knooppunten; zij verschillen in architectuur (centraal vs. decentraal) maar vervullen dezelfde rollen.

8.2.5 Rolcombinaties

De rollen in de vertrouwenslaag en technische laag zijn onafhankelijk van de business-laag. De volgende combinaties zijn mogelijk:

Scenario	Zorginstelling	Dienstverlener	Knooppunt
Zorginstelling met externe dienstverlener	Subject, Issuer (DelegationVC), Holder (juridisch), Verifier	Holder (operationeel), Client, AS/RS-beheerder	Beheerd door dienstverlener
Zorginstelling is eigen dienstverlener	Subject, Issuer (DelegationVC), Holder, Verifier	Niet van toepassing (zelfde organisatie)	Beheerd door zorginstelling
Dienstverlener bedient meerdere zorginstellingen	Per zorginstelling: Subject, Issuer, Holder (juridisch)	Holder (operationeel) voor meerdere zorginstellingen	Multi-tenant knooppunt

In alle scenario's bestaan de rollen zorginstelling en dienstverlener expliciet, en is er altijd een delegatiebewijs, ook wanneer dezelfde organisatie beide rollen vervult (AUTH-019). De zorginstelling is in alle scenario's juridisch holder van haar eigen wallet; het operationele beheer kan worden uitbesteed aan de dienstverlener.

8.3 Identiteitsmodel

8.3.1 DID-methode en identifier-strategie

Elke deelnemer in het stelsel heeft een technische identifier nodig die herleidbaar is naar sleutelmateriaal (AUTH-011), maar gescheiden is van business identifiers zoals URA en KVK (AUTH-012). Hiervoor wordt gebruik gemaakt van Decentralized Identifiers (DIDs). Een DID is een globally unieke identifier die de eigenaar zelf beheert en die resolveert naar een DID-document met daarin het publieke sleutelmateriaal van die partij.

In het geharmoniseerde model worden twee DID-methoden ingezet, elk met een eigen rol:

did:web is de primaire DID-methode voor deelnemers aan het stelsel. Een did:web identifier is gekoppeld aan een webdomein dat de deelnemer beheert (bv. did:web:example-ziekenhuis.nl). Het bijbehorende DID-document wordt gepubliceerd op een well-known URL onder dat domein en bevat het publieke sleutelmateriaal van de deelnemer. did:web ondersteunt sleutelrotatie zonder wijziging van de identifier (AUTH-017), meerdere sleutels voor verschillende doeleinden (AUTH-015), en is vindbaar zonder centrale

infrastructuur. Dienstverleners en zorginstellingen gebruiken did:web als hun technische identifier voor het ondertekenen van presentaties, het uitgeven van DelegationVCs en het publiceren van OAuth-metadata.

did:x509 wordt ingezet als brug naar de bestaande X.509 certificaatinfrastructuur. Deze methode maakt het mogelijk om attributen uit een X.509 certificaat (zoals een URA-nummer of organisatienaam) te gebruiken als basis voor het uitgeven van Verifiable Credentials, zonder dat de issuer een aparte DID-infrastructuur hoeft op te zetten. De did:x509 identifier is afgeleid van eigenschappen in de certificaatketen en kan door een verifier lokaal geresolveerd worden op basis van de meegeleverde certificaatketen. Dit is met name relevant voor autoritatieve bronnen die al over X.509 certificaten beschikken (bv. via PKIoverheid) en hiermee VCs kunnen uitgeven over organisaties in het stelsel. Zo wordt voldaan aan AUTH-006: het stelsel kan flexibel omgaan met zowel de huidige generatie certificaten als toekomstige identificatiemiddelen.

De combinatie van beide methoden zorgt ervoor dat het stelsel voortbouwt op de bestaande PKI-infrastructuur (AUTH-006) zonder er volledig van afhankelijk te zijn, en dat nieuwe deelnemers kunnen toetreden met een lichtgewicht DID-methode.

8.3.2 Credential structuur

Het geharmoniseerde model kent een beperkte set Verifiable Credentials waarmee de identiteit van partijen en hun onderlinge relaties worden vastgelegd. Elk credential heeft een specifiek doel en een duidelijke issuer-subject relatie. De credentials zijn onderverdeeld in identificerende credentials (wie ben je?) en delegatie-credentials (namens wie mag je handelen?).

Identificerende credentials

HealthcareOrganizationCredential Uitgegeven via did:x509 op basis van een certificaat dat het URA-nummer van de zorginstelling bevat. Dit credential bewijst de identiteit van de zorginstelling als erkende zorgaanbieder. Het vormt de basis waarop delegaties worden gebouwd: zonder een geldig HealthcareOrganizationCredential kan een zorginstelling geen delegaties uitgeven.

- Issuer: autoritatieve bron (via did:x509, certificaatketen)
- Subject: zorginstelling (did:web)
- Belangrijkste claims: URA-nummer, organisatienaam

PatientEnrollmentCredential Uitgegeven via did:x509, bedoeld om de inschrijving van een patiënt bij een zorginstelling aantoonbaar te maken. Dit credential maakt het mogelijk om het access token te binden aan een specifieke patiënt, zodat de bronhouder kan vaststellen dat de raadplegende partij een behandelrelatie heeft met de betreffende patiënt.

- Issuer: autoritatieve bron (via did:x509, certificaatketen)
- Subject: zorginstelling (did:web)
- Belangrijkste claims: patiëntidentificatie (BSN, optioneel gepseudonimiseerd), zorginstelling (URA)

ServiceProviderCredential Uitgegeven door een stelselhouder, bevat de identiteit van de dienstverlener en de diensten die de dienstverlener mag leveren binnen het stelsel. Dit credential geeft de OAuth client de autorisatie om verbinding te mogen maken met een authorization server. Het fungeert als bewijs dat de dienstverlener is toegelaten tot het stelsel.

- Issuer: stelselhouder
- Subject: dienstverlener (did:web)
- Belangrijkste claims: KVK-nummer, naam dienstverlener, stelseltoelating, lijst van toegestane diensten

Opmerking: momenteel is er nog geen operationele stelselhouder die dit credential kan uitgeven. Als tijdelijke oplossing kunnen certificaten van een hoog vertrouwensniveau (bv. PKIoverheid) worden gebruikt, eventueel aangevuld met een allow-list tijdens kleinschalige pilots.

Delegatie-credentials

HealthcareProfessionalDelegationCredential Dit credential legt vast dat een zorgverlener met een UZI-registratie (en daarmee een rolcode) de verantwoordelijkheid voor specifieke handelingen delegeert aan een afdeling of organisatie. Hierdoor kan de organisatie namens deze behandelaar handelen zonder dat de zorgverlener zelf bij elke transactie hoeft te authenticeren (AUTH-005). Dit is essentieel voor de gebruiksvriendelijkheid in het klinische werkproces.

Dit credential wordt altijd uitgegeven aan de eigen werkgever van de zorgverlener. De werkrelatie tussen zorgverlener en zorginstelling is niet technisch verifieerbaar uit het UZI-certificaat; dit is een governance-aanname. De kans dat een zorgverlener een niet-werkgever mandateert is verwaarloosbaar klein.

- Issuer: zorgverlener (via did:x509, UZI-certificaat)
- Subject: zorginstelling of afdeling (did:web)
- Belangrijkste claims: UZI/DEZI-nummer, rolcode, scope van de delegatie

ServiceProviderDelegationCredential Dit credential maakt de delegatie van de zorginstelling naar de dienstverlener expliciet (IDENT-023, IDENT-024). Het legt vast dat de dienstverlener handelingsbevoegdheid heeft namens de zorginstelling, gescoped tot specifieke diensten of toepassingen (IDENT-015). De scope in dit credential bevat een set of subset van de diensten die zijn opgenomen in het ServiceProviderCredential van de dienstverlener. Dit is het credential dat de verifier controleert voordat hij claims of beschermde gegevens accepteert (AUTH-021).

- Issuer: zorginstelling (via did:web)
- Subject: dienstverlener (did:web)
- Belangrijkste claims: zorginstelling (URA), dienstverlener (KVK), scope (diensten/toepassingen), geldigheidsperiode

Overzicht

Credential	Type	Issuer	Subject	Doel
HealthcareOrganization-Credential	Identificerend	UZI Server certificaat (did:x509)	Zorginstelling (did:web)	Identiteit van de zorginstelling
PatientEnrollment-Credential	Identificerend	Medewerker (did:x509)	Zorginstelling (did:web)	Aantonen behandelrelatie met patiënt
ServiceProvider-Credential	Identificerend	Stelselhouder	Dienstverlener (did:web)	Toelating dienstverlener tot het stelsel
HealthcareProfessional-DelegationCredential	Delegatie	Zorgverlener (did:x509)	Zorginstelling (did:web)	Handelen namens behandelaar zonder per-transactie authenticatie
ServiceProviderDelegationCredential	Delegatie	Zorginstelling (did:web)	Dienstverlener (did:web)	Handelingsbevoegdheid dienstverlener namens zorginstelling

Relatie tussen credentials

De credentials vormen samen een vertrouwensketen:

1. De **HealthcareOrganizationCredential** bewijst de identiteit van de zorginstelling
2. De **ServiceProviderCredential** bewijst de toelating van de dienstverlener tot het stelsel en definieert welke diensten deze mag leveren
3. De **ServiceProviderDelegationCredential** verbindt deze twee: de zorginstelling delegeert specifieke bevoegdheden aan de dienstverlener, gescoped tot een subset van de diensten uit het ServiceProviderCredential
4. De **HealthcareProfessionalDelegationCredential** voegt de zorgverlener-context toe: een behandelaar delegeert verantwoordelijkheid aan de organisatie
5. De **PatientEnrollmentCredential** bindt de transactie aan een specifieke patiënt

8.4 Presentatie en verificatie

8.4.1 8.4.1 Presentatie-model

In het geharmoniseerde model presenteert de dienstverlener (als OAuth client) twee Verifiable Presentations in het token request, gegroepeerd op subject:

VP 1: Zorginstelling Bevat alle credentials die betrekking hebben op de zorginstelling als subject:

- HealthcareOrganizationCredential (identiteit)
- PatientEnrollmentCredential (behandelrelatie)
- HealthcareProfessionalDelegationCredential (mandaat van behandelaar)

VP 2: Dienstverlener Bevat alle credentials die betrekking hebben op de dienstverlener als subject:

- ServiceProviderCredential (stelseltoelating)
- ServiceProviderDelegationCredential (delegatie van zorginstelling)

De keuze voor twee VPs volgt uit AUTH-020: claims in een enkele presentatie moeten altijd betrekking hebben op hetzelfde subject. Door te groeperen op subject wordt het standaard VP-model gevolgd, waarbij de issuer van de VP (de ondertekenaar) overeenkomt met het subject van de ingesloten credentials. Dit voorkomt niet-standaard business rules bij de verificatie.

De twee VPs samen bieden de verifier in één transactie alle informatie die nodig is om vast te stellen wie de handeling uitvoert (dienstverlener), namens wie (zorginstelling), op basis van welk mandaat (delegatie), voor welke patiënt (enrollment) en met welke professionele verantwoordelijkheid (behandelaar).

8.4.2 Wallet-architectuur

De zorginstelling is juridisch altijd eigenaar van haar eigen wallet (AUTH-025). Het operationele beheer kan worden uitbesteed aan de dienstverlener. Voor de verifier maakt dit geen verschil: de verificatie is gebaseerd op cryptografische validiteit en correcte delegatiebewijzen, niet op kennis van wie de wallet operationeel beheert (AUTH-026).

In de huidige situatie zal de dienstverlener in veel gevallen het operationele beheer van de wallet van de zorginstelling op zich nemen. Dit is een pragmatische startsituatie, maar niet de gewenste eindsituatie. Naarmate het stelsel volwassener wordt, is het wenselijk dat zorginstellingen hun eigen wallet beheren. Dit wordt met name relevant wanneer een zorginstelling met meerdere dienstverleners werkt (IDENT-016): een eigen wallet voorkomt dat credentials en sleutelmateriaal bij meerdere dienstverleners moeten worden beheerd of gedupliceerd. De zorginstelling beheert dan centraal haar eigen identiteit en geeft aan elke dienstverlener een ServiceProviderDelegationCredential met de juiste scope.

Ongeacht wie het operationele beheer voert: VP 1 (zorginstelling) wordt altijd ondertekend met sleutelmateriaal van de zorginstelling, VP 2 (dienstverlener) met sleutelmateriaal van de dienstverlener (AUTH-015).

8.4.3 Verificatieproces

De verifier (authorization server van de bronhouder) voert de volgende controles uit bij ontvangst van een token request:

1. **Stelseltoelating**: is de dienstverlener toegelaten tot het stelsel? (ServiceProviderCredential)
2. **Delegatie**: heeft de dienstverlener handelingsbevoegdheid namens de zorginstelling, en valt de gevraagde dienst binnen de scope? (ServiceProviderDelegationCredential)
3. **Identiteit zorginstelling**: is de zorginstelling een erkende zorgaanbieder? (HealthcareOrganizationCredential)
4. **Behandelrelatie**: heeft de zorginstelling een behandelrelatie met de betreffende patiënt? (PatientEnrollmentCredential)
5. **Professionele verantwoordelijkheid**: is er een mandaat van een behandelaar met de juiste rolcode? (HealthcareProfessionalDelegationCredential)
6. **Cryptografische validiteit**: zijn beide VPs correct ondertekend, zijn de credentials niet verlopen en niet ingetrokken?

De volgorde is bewust zo gekozen dat de meest gevoelige informatie (patiëntidentificatie) pas wordt geaccepteerd nadat de identiteit en bevoegdheid van de raadplegende partij is vastgesteld (AUTH-021, AUTH-024).

8.5 OAuth-profiel

8.5.1 Overzicht

Het OAuth-profiel implementeert de authenticatie-requirements door het token request te gebruiken als het moment waarop de dienstverlener alle benodigde claims en delegatiebewijzen presenteert aan de authorization server van de bronhouder. Het profiel is gebaseerd op RFC 7523 (JSON Web Token Profile for OAuth 2.0 Client Authentication and Authorization Grants), uitgebreid met Verifiable Presentations.

Het token request bevat twee aspecten:

- **Client authenticatie**: de VP met claims waar de dienstverlener zich identificeert en authenticeert als OAuth client
- **Authorization grant**: de VP met claims over de zorginstelling worden gepresenteerd als authorization grant conform RFC 7523

Hiermee wordt het onderscheid tussen de partij die het token aanvraagt (client/dienstverlener) en de partij namens wie toegang wordt gevraagd (subject/zorginstelling) expliciet gemaakt (OAUTH-006).

8.5.2 Token request flow

De token request flow verloopt als volgt:

1. De client (knooppunt van de dienstverlener) resolveert het token endpoint van de authorization server via de Care Services Directory, op basis van de URA van de bronhouder en het gewenste type gegevensuitwisseling (ADR-004)
2. De client stelt twee VPs samen zoals beschreven in sectie 8.4.1
3. De client stuurt een token request naar het token endpoint, met daarin:
    a. VP 1 (zorginstelling) als authorization grant

   b. VP 2 (dienstverlener) als client assertion
   c. De gewenste scope
   d. Een DPoP proof (zie 8.5.4)
4. De authorization server voert het verificatieproces uit zoals beschreven in sectie 8.4.3
5. Bij succesvolle verificatie geeft de AS een access token uit, gebonden aan de URA van de bronhouder (OAUTH-008) en aan de DPoP-sleutel van de client (OAUTH-010)
6. De client gebruikt het access token bij de resource server, vergezeld van een verse DPoP proof

Dit is een volledig back-channel flow zonder user-agent redirect (OAUTH-004), wat past bij zowel door gebruikers geinitieerde als geautomatiseerde interacties (AUTH-004).

8.5.3 Multi-tenancy en AS-discovery

Een dienstverlener kan namens meerdere zorginstellingen een authorization server draaien (OAUTH-012). Elke zorginstelling waarvoor de AS opereert wordt geidentificeerd door een eigen issuer identifier, waarin de URA is opgenomen. De AS-metadata wordt gepubliceerd conform RFC 8414.

Voorbeeld: een dienstverlener beheert de AS voor een zorginstelling met URA 12345678. De issuer identifier voor deze zorginstelling is:

```
https://as.dienstverlener.nl/ura/12345678
```

Conform RFC 8414 wordt het metadata-document gevonden door /.well-known/oauth-authorization-server in te voegen tussen het host-deel en het pad-deel van de issuer identifier:

```
https://as.dienstverlener.nl/.well-known/oauth-authorization-
server/ura/12345678
```

Dit metadata-document bevat onder andere het token endpoint voor deze specifieke zorginstelling, bv.:

```
{
  "issuer": "https://as.dienstverlener.nl/ura/12345678",
  "token_endpoint":
"https://as.dienstverlener.nl/ura/12345678/oauth2/token",
  "grant_types_supported": [...],
  "scopes_supported": [...],
  ...
}
```

Daarnaast bevat het metadata-document de delegatierelatie met de zorginstelling, cryptografisch verifieerbaar met het sleutelmateriaal van de zorginstelling (OAUTH-013). Clients verifieren deze delegatierelatie voordat zij een token request initieren (OAUTH-025, AUTH-024). Hierdoor wordt voorkomen dat credentials worden verstuurd naar een ongeautoriseerde partij.

8.5.4 Token binding (DPoP)

Access tokens worden gebonden aan het sleutelmateriaal van de client via het DPoP-mechanisme (Demonstrating Proof-of-Possession, RFC 9449). Bij elk gebruik van het access token stuurt de client een verse DPoP proof mee, ondertekend met dezelfde sleutel waarmee het token werd aangevraagd. Dit voorkomt dat gestolen tokens door andere partijen kunnen worden gebruikt (OAUTH-010).

8.5.5 Scope en toegangscontrole

De scope in het token request bepaalt welk type gegevensuitwisseling wordt gevraagd. De authorization server controleert of de gevraagde scope past binnen:

- De diensten die de dienstverlener mag leveren (ServiceProviderCredential)
- De bevoegdheden die de zorginstelling aan de dienstverlener heeft gedelegeerd (ServiceProviderDelegationCredential)
- De rolcode van de behandelaar (HealthcareProfessionalDelegationCredential)

Scope-gebaseerde toegangscontrole is afgestemd op bestaande zorg-OAuth-profielen zoals SMART-on-FHIR (OAUTH-009).

8.6 Sleutelmateriaal en PKI

8.6.1 PKI-architectuur

Het geharmoniseerde model maakt gebruik van twee lagen van publieke sleutelinfrastructuur:

X.509 certificaten vormen de basis voor de did:x509 methode en voor de TLS-beveiliging van did:web endpoints. Voor TLS wordt gebruik gemaakt van certificaten uit het PKIoverheid-stelsel. Op termijn is de verwachting dat er een nieuwe certificaattak wordt ingericht binnen het GIS-VN (Gezondheidsinformatie Stelsel Veilig Netwerk), specifiek voor deelnemers aan het gezondheidsinformatiestelsel. Tot die tijd worden PKIoverheid-certificaten of certificaten van vergelijkbaar vertrouwensniveau gebruikt.

DID-documenten bevatten het publieke sleutelmateriaal waarmee VCs en VPs worden ondertekend en geverifieerd. Voor did:web wordt het DID-document gepubliceerd op het domein van de deelnemer, beveiligd met TLS op basis van bovengenoemde certificaten. Voor did:x509 wordt het sleutelmateriaal afgeleid uit de certificaatketen zelf.

De combinatie zorgt ervoor dat het vertrouwen in did:web uiteindelijk is verankerd in de PKI-infrastructuur (via TLS), terwijl did:x509 direct op de bestaande certificaatinfrastructuur voortbouwt.

8.6.2 Sleutelbeheer

Elke deelnemer beheert meerdere sleutels voor verschillende doeleinden (AUTH-015). In de praktijk betekent dit minimaal:

- **Signing key voor VCs**: gebruikt door issuers (zorginstellingen, autoritatieve bronnen) om credentials te ondertekenen. Deze sleutels hebben de hoogste vertrouwenseisen omdat de claims die ermee worden ondertekend langdurig geldig kunnen zijn.
- **Signing key voor VPs**: gebruikt door holders (zorginstellingen, dienstverleners) om presentaties te ondertekenen. Deze sleutels worden gebruikt bij elke transactie en hebben een korter risicoprofiel.
- **DPoP key**: gebruikt door de OAuth client om token binding te realiseren. Deze sleutel is gebonden aan de sessie of het knooppunt.

De scheiding tussen deze sleutels voorkomt dat compromittering van een transactiesleutel automatisch leidt tot het kunnen uitgeven van valse credentials (AUTH-015).

8.6.3 Sleutelrotatie en intrekking

Sleutelrotatie wordt ondersteund via het DID-document: een deelnemer kan sleutelmateriaal toevoegen en verwijderen zonder dat de DID zelf wijzigt (AUTH-017). Verifiers volgen het DID-document om actueel sleutelmateriaal op te halen.

Voor intrekking van credentials en delegatiebewijzen wordt een mechanisme gehanteerd waarmee verifiers de intrekkingsstatus kunnen vaststellen zonder synchrone calls naar de uitgever (AUTH-022, OAUTH-016). De exacte keuze voor een revocation-mechanisme wordt uitgewerkt in de technische specificaties (hoofdstuk 10).

8.6.4 Open punten

De eisen aan de beveiliging van sleutelmateriaal zijn niet voor alle sleutels gelijk. Signing keys voor langlopende credentials hebben een fundamenteel ander risicoprofiel dan sleutels voor kortdurende presentaties of DPoP proofs. De volgende vragen staan nog open:

- In hoeverre hardware-gebaseerde sleutelopslag (HSM, secure enclave) vereist is, en hoe dit zich verhoudt tot de toetredingsdrempel voor met name de VVT-sector (OV-009)
- Of sterke gebruikersauthenticatie voor sleutelgebruik vereist is bij geautomatiseerde systemen (OV-010)
- Of er vertrouwensniveaus gedefinieerd moeten worden met per niveau verschillende eisen aan sleutelbeheer, opslag en intrekking (OV-011)

8.7 Adressering

De landelijke generieke functie voor adressering is gebaseerd op een mobile Care Services Directory (mCSD), een IHE-profiel dat is uitgewerkt in de Generieke Functies specificatie. In het geharmoniseerde model moeten partijen uit beide netwerken elkaars endpoints kunnen vinden op basis van een URA-nummer en een toepassing of datatype, ongeacht achter welk knooppunt deze endpoints zich bevinden (ADR-004).

8.7.1 Topologie

De Care Services Directory kent een gedistribueerde opzet met meerdere Administration Directories die worden geaggregeerd in Query Directories:

- **Nuts-knooppunten** fungeren elk als een eigen Administration Directory en Query Directory. Elk Nuts-knooppunt publiceert de endpoints van de zorginstellingen waarvoor het opereert en aggregeert de directories van andere knooppunten.
- **Het LSP** registreert endpoints namens haar achterliggende systemen in een centrale Administration Directory, waarschijnlijk aangeboden via ZorgAB. Achterliggende partijen hoeven hier zelf geen actie voor te ondernemen (ADR-002, HAR-010).

Het LRZa (Landelijke Register Zorgaanbieders) fungeert als root Administration Directory: elke zorginstelling registreert daar het endpoint van haar Administration Directory. Update Clients gebruiken het LRZa om alle Administration Directories te ontdekken en de gegevens te consolideren in Query Directories.

8.7.2 Vindbaarheid van endpoints

Een zoekend systeem vindt het juiste endpoint via de volgende stappen:

1. Zoek in de Query Directory naar de organisatie op basis van het URA-nummer
2. Filter de beschikbare HealthcareServices op het gewenste type dienst of datatype
3. Selecteer het juiste Endpoint op basis van het payload type (ADR-007)

Omdat een zorginstelling via meerdere knooppunten bereikbaar kan zijn (bv. zowel via het LSP als via een Nuts-knooppunt), kan de Query Directory meerdere endpoints voor dezelfde combinatie van URA en toepassing bevatten. De exacte routeringslogica voor dit scenario is een open onderzoeksvraag (OV-007).

8.7.3 Relatie met OAuth-discovery

De Care Services Directory bevat naast de resource server endpoints ook de OAuth endpoints (authorization server, token endpoint) van elk knooppunt. Via de Endpoint-resources in de directory kan een zoekend systeem de issuer identifier van de authorization server vinden voor een specifieke URA, en daaruit het .well-known/oauth-authorization-server metadata-document resolven (zie 8.5.3). Hierdoor vormen adressering en authenticatie samen een sluitende keten: van URA naar endpoint, naar AS-metadata, naar token request.

8.7.4 Vertrouwen in registraties

De relatie tussen een knooppunt en de zorginstellingen waarvoor het endpoints publiceert moet verifieerbaar zijn (ADR-005). Dit wordt geborgd doordat:

- Het LRZa alleen registraties accepteert van zorginstellingen die hun eigen Administration Directory endpoint hebben vastgelegd
- Een Administration Directory alleen autoritatief is voor de zorginstellingen die er expliciet aan zijn gekoppeld via het LRZa
- De delegatierelatie tussen zorginstelling en dienstverlener cryptografisch verifieerbaar is via het ServiceProviderDelegationCredential (zie 8.3.2)

8.8 Lokalisatie

De lokalisatiefunctie stelt zorgverleners in staat om te ontdekken welke organisaties relevante patiëntgegevens van een bepaald type beschikbaar hebben. De landelijke voorziening hiervoor is de Nationale Verwijs Index (NVI). In het geharmoniseerde model moeten partijen uit beide netwerken lokalisatierecords kunnen registreren en bevragen bij de NVI (LOK-001, LOK-002).

8.8.1 Deelname aan de NVI

Zowel partijen aangesloten via het LSP als via Nuts-knooppunten nemen deel aan de NVI:

- **Het LSP** registreert en beheert lokalisatierecords namens haar achterliggende systemen, zonder dat die systemen hier zelf actie voor hoeven te ondernemen (LOK-003). Dit is consistent met de rol van het LSP als knooppunt (HAR-010).
- **Nuts-knooppunten** registreren lokalisatierecords voor de zorginstellingen waarvoor zij opereren. Elke zorginstelling is via haar knooppunt zelfstandig verantwoordelijk voor de juistheid van haar registraties.

8.8.2 Pseudonimisering

De NVI werkt met gepseudonimiseerde patiëntidentificatie om te voorkomen dat het BSN direct wordt uitgewisseld en de NVI een privacy hot-spot wordt. Partijen uit beide netwerken moeten toegang hebben tot de VWS pseudonimiseringsdienst (PRS) om lokalisatierecords te kunnen registreren en bevragen (LOK-005).

8.8.3 Authenticatie met de NVI en PRS

De NVI stelt eisen aan de identiteit van de bevragende partij, waaronder organisatie-identifier (URA), organisatietype, en mogelijk de identificatie van de zorgverlener (UZI/DEZI) en rolcode. De authenticatie tussen deelnemers en de NVI volgt een eigen mechaniek die wordt vastgesteld door VWS en niet noodzakelijk overeenkomt met het OAuth-profiel zoals beschreven in sectie 8.5.

De exacte authenticatie-eisen en -mechaniek voor de interactie met de NVI vallen buiten de scope van dit document. Hiervoor wordt verwezen naar de documentatie van VWS over de Generieke Functie Lokalisatie. Wel is het van belang dat de identiteitsattributen die de NVI vereist afleidbaar zijn uit het geharmoniseerde authenticatiemodel (LOK-004). Voor partijen die niet over een UZI-pas beschikken (met name in de VVT-sector) is dit nog een openstaand punt (OV-008).

Een specifiek aandachtspunt is het "device-id" dat VWS heeft geïntroduceerd voor de Generieke Functies. Dit is een identiteitsattribuut dat een combinatie van dienstverlener en zorginstelling vertegenwoordigt. Het device-id wordt tijdens authenticatie aangetoond en geeft de client autorisatie voor administratieve handelingen (aanmaken, opvragen en verwijderen) van lokalisatierecords die aan dat device-id zijn gekoppeld. Dit identiteitsattribuut bestaat uitsluitend binnen de VWS Generieke Functies en komt niet voor in het credential-model zoals beschreven in sectie 8.3.2. De wijze waarop het device-id wordt afgeleid uit of gemapt op de identiteitsattributen van het geharmoniseerde model (met name de combinatie van ServiceProviderCredential en HealthcareOrganizationCredential) vereist nadere uitwerking.

8.8.4 Toestemmingsmodel

Het is nog niet definitief vastgesteld of toestemming van de patiënt vereist is voordat lokalisatiegegevens worden gedeeld met een zoekende organisatie. Dit heeft directe gevolgen voor de oplossing:

- Indien toestemming vereist is, moet de NVI bij elke bevraging een consent-check kunnen uitvoeren richting de bronhouder (LOK-006). Dit vereist dat de identiteitsattributen van de zoekende partij voldoende zijn om deze check uit te voeren.
- Indien geen toestemming vereist is, kan de NVI volstaan met het verifiëren van de identiteit en bevoegdheid van de zoekende partij zonder een consent-check bij de bronhouder.

De keuze hierin wordt bepaald door VWS en valt buiten de scope van dit document. De gekozen oplossingsrichting voor het geharmoniseerde model moet beide scenario's kunnen accommoderen.

8.9 Beantwoording onderzoeksvragen

8.10 Route 1: Nuts bevraagt LSP

Deze routes in een los hoofdstuk zetten?

8.10.1 High-level flow

8.11 Route 2: LSP bevraagt Nuts

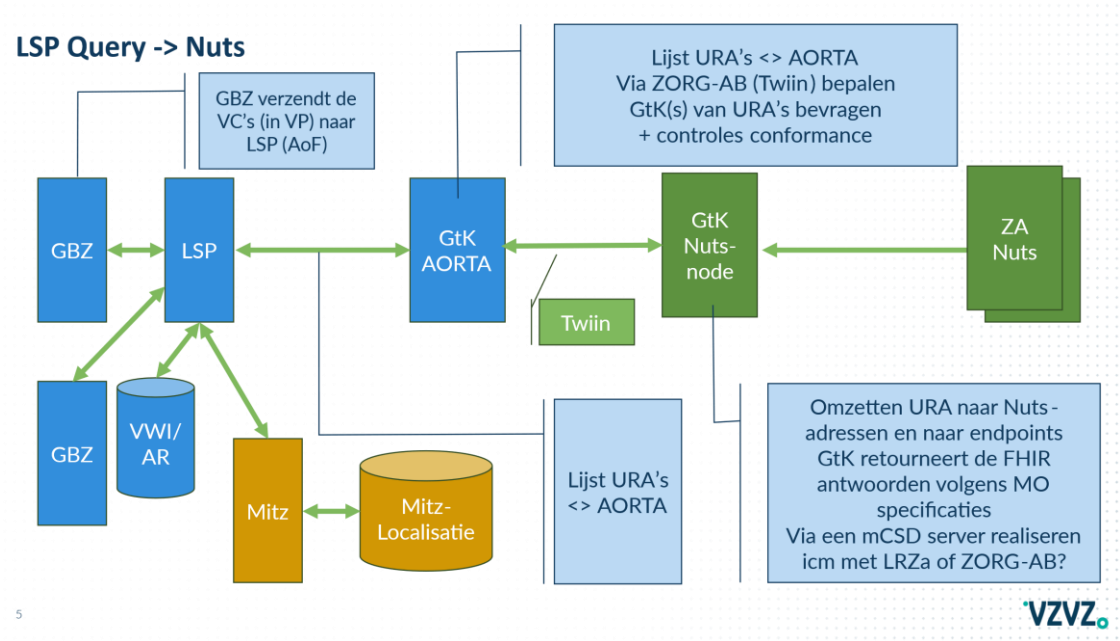
Doelstelling is om vanuit AORTA Nuts te kunnen bevragen zonder verschil te behoeven te maken of de bevraagde zorgaanbieder nu een AORTA-deelnemer is of een Nuts deelnemer.

Uitgangspunt is dat het ‘vragende’ systeem dan wel overstapt op de VC’s, die we gezamenlijk hebben vastgesteld. De VC’s worden immers ook bruikbaar voor het eigen AORTA-verkeer. ‘Vertalen’ van SAML2-

tokens naar VC's is niet mogelijk gezien de cryptografische borging van de VC's. Dit gaan omzetten middels een 'vertaler' is, net zoals we dat bij Nuts hebben gedaan, niet mogelijk.

Er is dus **impact** voor AORTA-deelnemers als zij ook buiten AORTA willen kunnen raadplegen.

Omdat het LSP ook de lokalisatie uitvoert voor de AORTA-deelnemers en de adressering van de aangesloten zorgaanbieders transparant heeft gemaakt middels 'AppID's' zal er een route moeten worden bepaald waarlangs de bevragingen lopen:



8.11.1 <oplossingsrichting>

8.12 Risico's en mitigaties

Kwetsbaarheid	kans	impact	risico	oplossing
				<nr met kruis-verwijzing>

BIA, PIA, DPIA?

9 Fasering van de oplossingen

Pilot 1

Nuts vraagt gegevens op bij een LSP partij.

Beschrijf hier hoe de architectuur exact er uit komt te zien aan de kant van Nuts en van het LSP:

Waar staan de organisatie VC Repo's? Hoe komen de VCs uit de org-VC-repo bij de SP client terecht?

Wat komt er in de services van de delegationCredential terecht?

Pilot 2

Pilot 1 + LSP partij die bij een Nuts partij iets op vraagt.

Beheer van de Credential-Repository in pilots:

Idealiter wordt dit allemaal door het LSP uitgevoerd, maar is het een goed idee om inschrijftokens en delegation tokens bij het LSP te leggen? Zo niet, kunnen we nu al vragen om zorginstellingen zelf een wallet te alten regelen in deze fase, dan wel aan LSP software leveranciers dit te implementeren?

10 Bijlage 1: Technische Specificaties

10.1 Inleiding

Doel van dit hoofdstuk: de technische keuzes vastleggen die specifiek zijn voor dit stelsel, zonder bestaande standaarden te herhalen. Dit hoofdstuk vormt de lijm tussen de normatieve referenties en beschrijft de stelsel-specifieke invullingen, profielen en extensies.

10.2 Normatieve referenties

Overzicht van alle gehanteerde standaarden met versie-pinning:

Standaard	Versie	Referentie
W3C Verifiable Credentials Data Model	1.1	https://www.w3.org/TR/2022/REC-vc-data-model-20220303/
W3C DID Core	1.0	https://www.w3.org/TR/did-core/
did:web Method Specification	(vast te pinnen)	https://w3c-ccg.github.io/did-method-web/
did:x509 Method Specification	(vast te pinnen)	ToIP / Microsoft
StatusList2021	(vast te pinnen)	W3C CCG
RFC 7515	-	JSON Web Signature (JWS)
RFC 7523	-	JWT Profile for OAuth 2.0 Client Authentication and Authorization Grants
RFC 8414	-	OAuth 2.0 Authorization Server Metadata
RFC 9449	-	OAuth 2.0 Demonstrating Proof of Possession (DPoP)
IHE mCSD	(vast te pinnen)	Mobile Care Services Discovery
Nuts RFC023	-	X509Credential (extensie san:otherName)

10.3 Cryptografische parameters

Deze sectie specificeert de toegestane cryptografische algoritmen, sleuteltypes en transportbeveiliging per context. De keuzes zijn afgestemd op de beperkingen van de gebruikte hardware (met name de UZI-pas) en de gangbare praktijk binnen PKIoverheid.

10.3.1 10.3.1 did:web context

Credentials en presentaties die worden ondertekend met sleutelmateriaal behorend bij een did:web identifier MOETEN een van de volgende algoritmen gebruiken:

JWS alg	Algoritme	Curve / sleutellengte	Status
ES256	ECDSA	P-256 (secp256r1)	Aanbevolen
ES384	ECDSA	P-384 (secp384r1)	Toegestaan
ES512	ECDSA	P-521 (secp521r1)	Toegestaan
PS256	RSASSA-PSS	RSA >= 2048 bits, SHA-256	Toegestaan

ES256 is de aanbevolen keuze vanwege de balans tussen veiligheid, prestaties en brede ondersteuning in libraries en hardware.

Het domein dat wordt gebruikt in een did:web identifier MOET een top-level domain (TLD) hebben met voldoende betrouwbaarheid en juridische afdwingbaarheid. Binnen dit stelsel is het gebruik van het .nl TLD verplicht. Dit waarborgt dat domeinnamen vallen onder Nederlands recht en dat de SIDN als registerhouder voldoende garanties biedt ten aanzien van eigenaarschap en geschilbeslechting.

DID-documenten voor did:web MOETEN worden gepubliceerd over TLS 1.2 of hoger. TLS 1.3 is aanbevolen. Het TLS-certificaat MOET afkomstig zijn van een vertrouwde certificaatautoriteit (zie sectie 8.6.1 voor de PKI-architectuur). Verdere eisen aan de structuur van het DID-document worden beschreven in sectie 10.4.

10.3.2 did:x509 context

Credentials die worden ondertekend met sleutelmateriaal behorend bij een did:x509 identifier zijn gebonden aan de mogelijkheden van het onderliggende X.509 certificaat en de bijbehorende hardware. De UZI-pas maakt gebruik van RSA-sleutels via de PKCS#11 interface.

De volgende algoritmen zijn toegestaan:

JWS alg	Algoritme	Sleutellengte	Status
PS256	RSASSA-PSS	RSA >= 2048 bits, SHA-256	Aanbevolen
RS256	RSASSA-PKCS1-v1_5	RSA >= 2048 bits, SHA-256	Toegestaan (legacy)

PS256 is de aanbevolen keuze omdat RSASSA-PSS een sterker beveiligingsprofiel biedt dan PKCS#1 v1.5. RS256 is toegestaan voor compatibiliteit met bestaande UZI-certificaten en hardware die RSASSA-PSS niet ondersteunt.

De certificaatketen MOET worden opgenomen in de x5c header parameter van het JWT conform RFC 7515 sectie 4.1.6. De certificaatketen MOET volledig zijn (van leaf tot root) en MOET gevalideerd worden volgens RFC 5280. De x5t#S256 header parameter MOET de SHA-256 thumbprint van het leaf-certificaat bevatten.

Opmerking: naarmate de UZI-pas en PKIoverheid-certificaten evolueren naar ECDSA-ondersteuning, kunnen de toegestane algoritmen voor did:x509 worden uitgebreid. De specificatie voorziet in deze mogelijkheid doordat het sleuteltype wordt bepaald door het certificaat zelf.

10.3.3 DPoP

DPoP proofs (RFC 9449) MOETEN worden ondertekend met ES256 (ECDSA met P-256). De DPoP-sleutel is een ephemeral sleutel die door de OAuth client wordt gegenereerd en is niet gebonden aan een specifiek certificaat of DID. Er wordt bewust slechts een enkel algoritme voorgeschreven om de implementatielast te beperken.

10.3.4 Overzicht per context

Context	Aanbevolen	Toegestaan	Niet toegestaan
did:web (VCs, VPs)	ES256	ES384, ES512, PS256	RS256, RS384, RS512
did:x509 (VCs)	PS256	RS256 (legacy)	Alle overige
DPoP proofs	ES256	-	Alle overige
TLS	TLS 1.3	TLS 1.2	TLS 1.1 en lager

Alle algoritmen die niet in de kolom "Aanbevolen" of "Toegestaan" staan, zijn NIET TOEGESTAAN. Implementaties MOETEN alle aanbevolen algoritmen ondersteunen en ZOUDEN alle toegestane algoritmen MOETEN ondersteunen. Verifiers MOETEN alle aanbevolen en toegestane algoritmen accepteren.

10.4 DID-documenten

Een DID-document is het machine-leesbare document dat hoort bij een Decentralized Identifier (DID). Het bevat het publieke sleutelmateriaal van de eigenaar van de DID en beschrijft waarvoor elke sleutel mag worden gebruikt. Een verifier resolveert het DID-document om de publieke sleutel op te halen waarmee een handtekening kan worden geverifieerd. Hoe het DID-document wordt gepubliceerd en geresolveerd verschilt per DID-methode.

10.4.1 did:web

Resolutie

Het DID-document voor een did:web identifier wordt gepubliceerd op het domein van de deelnemer conform de did:web method specification. Het document MOET beschikbaar zijn op het pad `/.well-known/did.json` (voor domeinniveau DIDs) of op het overeenkomstige pad voor DIDs met een subpad.

Structuur

Het DID-document MOET minimaal de volgende velden bevatten:

- **id**: de did:web identifier van de deelnemer
- **verificationMethod** (optioneel): een lijst van publieke sleutels die eigendom zijn van deze DID, uitgedrukt als JWK (JSON Web Key, RFC 7517). Elke sleutel MOET een unieke id hebben (opgebouwd als `did:web:example.nl#key-1`) en een type van *JsonWebKey2020*
- **assertionMethod**: verwijzing(en) naar sleutel(s) die worden gebruikt voor het ondertekenen van Verifiable Credentials. Alleen partijen die de issuer-rol vervullen (zorginstellingen voor DelegationVCs, stelselhouder voor ServiceProviderCredentials) hoeven deze relationship op te nemen
- **authentication**: verwijzing(en) naar sleutel(s) die worden gebruikt voor het ondertekenen van Verifiable Presentations

Verwijzingen in assertionMethod en authentication MOGEN verwijzen naar verification methods in hetzelfde DID-document, maar MOGEN ook verwijzen naar verification methods in andere DID-documenten. De verificationMethod sectie MAG daarom leeg zijn indien alle sleutels elders zijn gedefinieerd.

De sleutels waarnaar assertionMethod en authentication verwijzen MOETEN verschillend zijn (AUTH-015). Dit beperkt de impact van compromittering: een sleutel waarmee presentaties worden ondertekend mag niet kunnen worden gebruikt om credentials uit te geven.

Sleutelrotatie

Bij sleutelrotatie (AUTH-017) wordt een nieuwe sleutel toegevoegd aan het DID-document. De oude sleutel hoeft niet direct te worden verwijderd: zolang er nog geldige credentials in omloop zijn die met de oude sleutel zijn ondertekend, en de sleutel niet is ingetrokken, MAG deze in het DID-document blijven staan. De oude sleutel MOET worden verwijderd zodra het laatste credential dat ermee is ondertekend is verlopen, of wanneer de sleutel wordt ingetrokken.

Verifiers MOETEN het DID-document ophalen bij verificatie en MOGEN het cachen conform de HTTP cache headers die het document meelevert.

10.4.2 did:x509

Een did:x509 identifier wordt **niet gepubliceerd als DID-document op een server**. Het DID-document wordt **lokaal afgeleid** (geresolved) op basis van de certificaatketen die wordt meegeleverd in de x5c header van het JWT (RFC 7515 sectie 4.1.6). Na resolutie is het certificaat als concept niet meer relevant: alle verdere validatie werkt uitsluitend op het DID-document en de daarin opgenomen keys en attributen.

Resolutie

De resolver voert de volgende stappen uit conform de did:x509 method specification:

1. Decodeer de certificaatketen uit de x5c header parameter
2. Valideer de certificaatketen conform RFC 5280 (handtekeningen, geldigheidsperiode, basic constraints)
3. Controleer dat de keten een geaccepteerde trust anchor bevat (sectie 10.4.2 trust anchors)
4. Controleer de revocation status van alle certificaten in de keten via CRL
5. Match de attributen in de DID-identifier tegen de velden in het certificaat
6. Construeer het DID-document

Let op: Een ingetrokken certificaat kan nog steeds een valide DID-document opleveren. Zie 10.4.3 over key-resolutie.

Structuur

Het resulterende DID-document bevat minimaal:

- `id`: de did:x509 identifier, inclusief alle attributen uit de DID policies
- `verificationMethod`: een of meerdere keys van type JsonWebKey2020, waarbij:
  - De publieke sleutel afkomstig is uit het leaf-certificaat
  - Het veld `expires` overeenkomt met de `notAfter` datum van het certificaat
  - Het veld `revoked` wordt gezet indien het certificaat op de CRL staat, met als waarde de revocation-datum

De DID-identifier zelf draagt de identificerende attributen (URA-nummer, organisatienaam, UZI-nummer, rolcode) via de DID policies. Na resolutie zijn deze attributen beschikbaar als onderdeel van de DID, niet als certificaatvelden.

Trust anchors

De ca-fingerprint in de did:x509 identifier bepaalt welke certificaatautoriteit wordt vertrouwd. De resolver MOET controleren dat de ca-fingerprint voorkomt in de lijst van geaccepteerde trust anchors voor het stelsel. De geaccepteerde trust anchors zijn intermediate CA-certificaten:

- PKIoverheid intermediate CA-certificaten die worden gebruikt voor de uitgifte van UZI-certificaten
- Toekomstige GIS-VN intermediate CA-certificaten

De exacte lijst van geaccepteerde ca-fingerprint waarden wordt beheerd als operationele configuratie en gepubliceerd door de stelselhouder. De set geaccepteerde trust anchors kan per credential type verschillen.

san:otherName extensie

De did:x509 method specification definieert een aantal DID policies waarmee attributen uit het certificaat worden opgenomen in de DID-identifier: subject, san (Subject Alternative Name) en eku (Extended Key Usage).

Nederlandse zorgcertificaten (UZI) bevatten identificerende attributen in het SubjectAlternativeName veld als otherName. Dit attribuut is niet standaard opgenomen in de did:x509 specificatie. Dit stelsel breidt de san DID policy uit met het otherName attribuut, conform Nuts RFC023 sectie 3.5.

Het otherName veld in UZI-certificaten is opgebouwd als `<versie-nr>-<UZI-nr>-<pastype>-<Abonnee-nr>-<rol>-<AGB-code>`. De relevante velden hieruit worden als afzonderlijke attributen opgenomen in de DID-identifier. Voorbeeld:

```
did:x509:0:sha256:WE4P5dd8DnLHSkyHaIjhp4udlkF9LqoKwCvu9gl38jk::subject:O:Zieken
huis%20Voorbeeld::san:otherName:12345678
```

Hierbij is 12345678 het URA-nummer.

10.4.3 Key-resolutie

Naast DID-resolutie (het ophalen van het DID-document) kent dit stelsel het concept key-resolutie: het selecteren van de juiste publieke sleutel uit een DID-document op basis van een referentietijdstip.

Bij verificatie van een credential is het referentietijdstip de issuanceDate van het credential, niet het huidige tijdstip. Dit is essentieel omdat:

- Een sleutel die na uitgifte van het credential is ingetrokken of verlopen, ten tijde van uitgifte geldig was. De handtekening is dan nog steeds geldig.
- Bij sleutelrotatie (sectie 10.4.1) kunnen meerdere sleutels in een DID-document staan. De juiste sleutel wordt geselecteerd op basis van het tijdstip.

De key-resolutie werkt als volgt:

1. Selecteer de verification method die overeenkomt met de kid in de JWT header
2. Controleer dat de key geldig was op het referentietijdstip:
    a. Het referentietijdstip MOET voor de expires datum van de key liggen (indien aanwezig)
    b. De key MAG NIET als revoked gemarkeerd zijn met een revocation-datum die voor het referentietijdstip ligt
3. Controleer dat de key het juiste doel heeft (assertionMethod voor VCs, authentication voor VPs)

Dit mechanisme maakt het CRL-beleid voor inschrijftokens (sectie 10.6.5) en mandaattokens (sectie 10.6.4) uniform: als de key geldig was op het moment van uitgifte, is de handtekening geldig.

10.5 VC-encoding

Alle Verifiable Credentials in dit stelsel worden ge-encodeerd conform de W3C Verifiable Credentials Data Model 1.1, sectie 6.3.1 (JWT Encoding). Dit betekent dat een VC wordt verpakt als een signed JWT (JSON Web Token), waarbij de VC-velden worden gemapt op standaard JWT claims.

10.5.1 Mapping van VC-velden naar JWT claims

De volgende mapping wordt gehanteerd conform VC Data Model 1.1:

VC-veld	JWT claim	Toelichting
issuer	iss	DID van de issuer (did:web of did:x509)
credentialSubject.id	sub	DID van het subject (did:web)
issuanceDate	nbf	Uitgiftedatum als UNIX timestamp
expirationDate	exp	Verloopdatum als UNIX timestamp (indien van toepassing)
id	jti	Unieke identifier van het credential
Overige VC-velden	vc	Genest object met de volledige VC-structuur

Het vc claim bevat de volledige VC-structuur inclusief @context, type, credentialSubject en eventueel credentialStatus. De velden die al zijn gemapt naar JWT claims (iss, sub, nbf, exp) MOGEN worden weggelaten uit het vc object om duplicatie te voorkomen, maar MOETEN bij reconstructie van de VC weer worden aangevuld vanuit de JWT claims.

10.5.2 JWT header

De JWT header MOET de volgende velden bevatten:

Veld	Waarde	Toelichting
alg	Conform sectie 10.3	Signing-algoritme, afhankelijk van de DID-methode
typ	JWT	Token type
kid	Key ID	Voor did:web: verwijzing naar de verification method in het DID-document. Voor did:x509: de volledige DID met fragment
x5c	Certificaatketen	Alleen voor did:x509: de volledige certificaatketen in DER-formaat, base64-encoded
x5t#S256	SHA-256 thumbprint	Alleen voor did:x509: thumbprint van het leaf-certificaat

10.5.3 Voorbeeld

Onderstaand voorbeeld toont een HealthcareOrganizationCredential als JWT. De header en payload zijn apart weergegeven; in de praktijk worden deze base64url-encoded en samengevoegd met een handtekening als header.payload.signature.

JWT header (did:x509 issuer):

```
{
  "alg": "PS256",
  "typ": "JWT",
  "x5c": [
    "",
    "",
    ""
  ],
  "x5t#S256": "WE4P5dd8DnLHSkyHaIjhp4udlkF9LqoKwCvu9gl38jk",
  "kid":
"did:x509:0:sha256:WE4P5dd8DnLHSkyHaIjhp4udlkF9LqoKwCvu9gl38jk::subject
:O:Autoriteit::san:otherName:00000000#0"
```

```
}
```

JWT payload:

```
{
  "iss":
"did:x509:0:sha256:WE4P5dd8DnLHSkyHaIjhp4udlkF9LqoKwCvu9gl38jk::subject
:O:Autoriteit::san:otherName:00000000",
  "sub": "did:web:ziekenhuis-voorbeeld.nl",
  "nbf": 1733011200,
  "exp": 1764547200,
  "jti": "urn:uuid:3e671c46-7a3b-4c1e-9b2a-4f8e6d2c1a5b",
  "vc": {
    "@context": [
      "https://www.w3.org/2018/credentials/v1",
      "https://vzvz.nl/credentials/v1"
    ],
    "type": [
      "VerifiableCredential",
      "HealthcareOrganizationCredential"
    ],
    "credentialSubject": {
      "id": "did:web:ziekenhuis-voorbeeld.nl",
      "organization": {
        "ura": "12345678",
        "name": "Ziekenhuis Voorbeeld"
      }
    }
  }
}
```

In dit voorbeeld geeft een autoritatieve bron (geidentificeerd via did:x509 met een UZI-certificaat) een HealthcareOrganizationCredential uit aan een zorginstelling (geidentificeerd via did:web). De sub claim en credentialSubject.id verwijzen beide naar de did:web van de zorginstelling.

10.6 Credential-specificaties

Deze sectie specificeert per credential type de veldnamen, cardinaliteit en validatieregels. Alle credentials conformeren aan de encoding-regels uit sectie 10.5. Generieke validatieregels die voor meerdere credentials gelden staan in sectie 10.6.2. De credential-specifieke secties (10.6.3 t/m 10.6.7) beschrijven aanvullende regels per type.

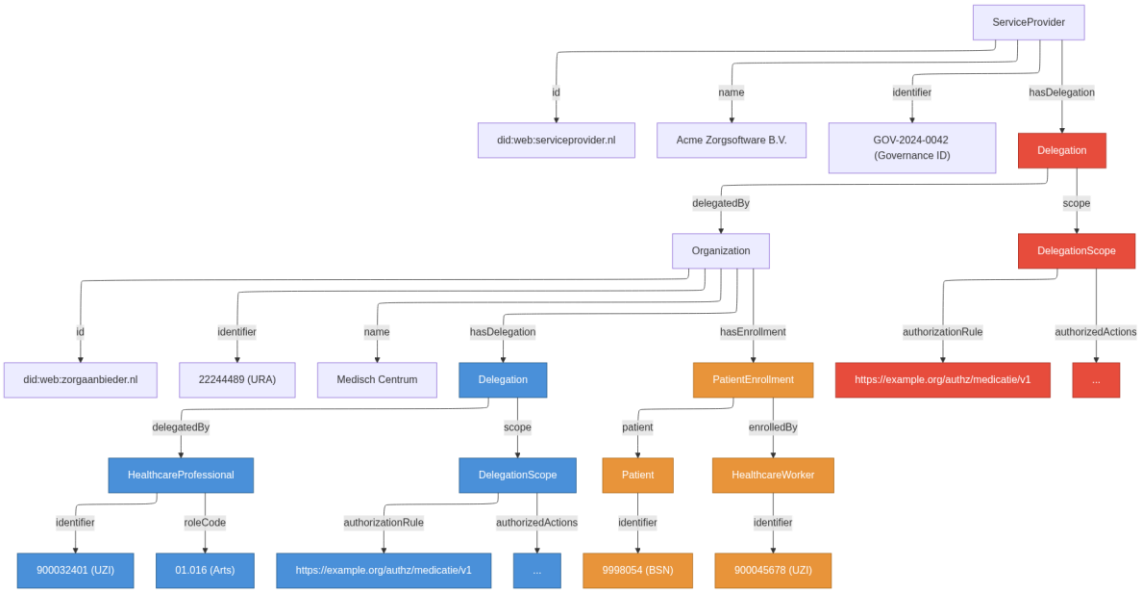
10.6.1 JSON-LD context

Wat is JSON-LD?

JSON-LD (JSON for Linked Data) is een manier om gestructureerde gegevens uit te drukken in JSON, vergelijkbaar met hoe XML-namespaces en XML Schema structuur geven aan SAML assertions. De definitie

wordt opgegeven in een @context veld en definieert de vocabulaire en zorgt ervoor dat alle partijen dezelfde betekenis toekennen aan de velden.

Ontologie



Alle credentials in dit stelsel maken gebruik van een gedeelde JSON-LD context die de ontologie definieert. De context specificeert de volgende namespaces:

- gis: http://gis-nl.example/ -- stelsel-specifieke termen
- schema: http://schema.org/ -- generieke termen
- fhirnl: http://fhir.nl/fhir/NamingSystem/ -- Nederlandse zorgstelsel-identifiers

De context definieert de volgende identifier-termen:

Term	IRI	Datatype	Bron
ura	gis:ura	fhirnl:ura	UZI-register / LRZa
uzi	gis:uzi	fhirnl:uzi-nr-pers	UZI-certificaat (otherName)
roleCode	gis:roleCode	fhirnl:uzi-rolcode	UZI-certificaat (otherName)
bsn	gis:bsn	fhirnl:bsn	GBA / SBV-Z
name	schema:name	String	-

De context definieert de volgende entiteit-types:

Type	IRI	Beschrijving
Organization	gis:Organization	Zorginstelling, geidentificeerd door URA
HealthcareProfessional	gis:HealthcareProfessional	BIG-geregistreerde zorgverlener (zorgverlenerspas, pastype Z), specialisatie van een HealthcareWorker
HealthcareWorker	gis:HealthcareWorker	Medewerker (medewerkerspas op naam, pastype N of Z). HealthcareProfessional is een subtype van HealthcareWorker
Patient	gis:Patient	Patient, geidentificeerd door BSN

ServiceProvider	gis:ServiceProvider	Dienstverlener (softwareleverancier)

En de volgende relatie-types:

Type	IRI	Beschrijving
Delegation	gis:Delegation	Delegatie van bevoegdheid
DelegationScope	gis:DelegationScope	Scope waarbinnen de delegatie geldt
PatientEnrollment	gis:PatientEnrollment	Inschrijving van een patient bij een zorginstelling

En de volgende relatie- en attribuut-termen:

Term	IRI	Beschrijving
hasDelegation	gis:hasDelegation	Verwijzing naar een delegatie
delegatedBy	gis:delegatedBy	De partij die de delegatie verleent
scope	gis:scope	Scope van de delegatie
authorizationRule	gis:authorizationRule	URI van de autorisatieregel
authorizedActions	gis:authorizedActions	Toegestane acties
hasEnrollment	gis:hasEnrollment	Verwijzing naar een inschrijving
patient	gis:patient	De ingeschreven patient
enrolledBy	gis:enrolledBy	De uitvoerder van de inschrijving
services	gis:services	Lijst van diensten waarvoor een dienstverlener is toegelaten

De definitieve context-URI wordt gepubliceerd door de stelselhouder. Tot die tijd wordt `http://gis-nl.example/` als placeholder gebruikt.

10.6.2 Generieke validatieregels

De volgende validatieregels gelden voor alle credentials in dit stelsel. Credential-specifieke secties verwijzen hiernaar en voegen alleen aanvullende regels toe.

Algemeen

1. Het credential MOET in JWT-encoding zijn conform sectie 10.5
2. Het type veld MOET VerifiableCredential bevatten plus het credential-specifieke type
3. De issuanceDate MOET in het verleden liggen
4. Indien expirationDate aanwezig is, MOET deze in de toekomst liggen
5. Het credentialSubject.id MOET een DID zijn dat door de verifier geresolveerd kan worden

DID- en key-resolutie

6. Het DID-document van de issuer MOET geresolveerd worden conform de toepasselijke DID-methode (sectie 10.4)
7. De signing key MOET geresolveerd worden via key-resolutie (sectie 10.4.3) met de issuanceDate van het credential als referentietijdstip
8. De key MOET geldig zijn geweest op het referentietijdstip: niet verlopen (expires) en niet ingetrokken (revoked) voor dat tijdstip
9. Identifier-velden in het credentialSubject die afkomstig zijn uit de issuer DID (UZI-nummer, rolcode, URA-nummer) MOETEN overeenkomen met de corresponderende attributen in de issuer DID-identifier
10. De issuer DID MOET een geaccepteerde trust anchor bevatten. Welke trust anchors geaccepteerd zijn kan per credential type verschillen (zie de credential-specifieke secties)

11. De signing key MOET voorkomen in de assertionMethod van het issuer DID-document

10.6.3 HealthcareOrganizationCredential

Bewijst de identiteit van een zorginstelling. De zorginstelling geeft dit credential aan zichzelf uit op basis van de did:x509 identiteit die het URA-nummer bevat.

VC type: `["VerifiableCredential", "HealthcareOrganizationCredential"]`

Issuer: did:x509 van de zorginstelling

Subject: did:web van de zorginstelling

Vereist pastype: S (servercertificaat)

Trust anchors: PKIoverheid intermediate CAs voor UZI-servercertificaten, of toekomstige GIS-VN intermediate CAs

Veld	IRI	Card.	Beschrijving
id	-	1	did:web van de zorginstelling
@type	-	1	Organization (gis:Organization)
ura	gis:ura	1	URA-nummer, overeenkomend met het URA-nummer in de issuer DID
name	schema:name	1	Naam van de organisatie, overeenkomend met het subject:O attribuut in de issuer DID

Alle velden in de tabel zijn gescopet op credentialSubject.

Aanvullende validatieregels (naast sectie 10.6.2):

- Het pastype in de issuer DID MOET S zijn
- De `name` MOET overeenkomen met het subject:O attribuut in de issuer DID

10.6.4 HealthcareProfessionalDelegationCredential

Bewijst dat een zorgverlener bevoegdheid delegeert aan een zorginstelling. Dit is de VC-tegenhanger van het AORTA SAML mandaattoken. De zorgverlener ondertekent dit credential met de signing key van de UZI-zorgverlenerspas.

VC type: `["VerifiableCredential", "HealthcareProfessionalDelegationCredential"]`

Issuer: did:x509 van de zorgverlener

Subject: did:web van de zorginstelling waarbinnen het mandaat geldig is

Vereist pastype: Z (zorgverlenerspas)

Trust anchors: PKIoverheid intermediate CAs voor UZI-zorgverlenerspassen, of toekomstige GIS-VN intermediate CAs

Veld	IRI	Card.	Beschrijving

id	-	1	did:web van de zorginstelling
@type	-	1	Organization (gis:Organization)
ura	gis:ura	1	URA-nummer van de zorginstelling
hasDelegation.@type	-	1	Delegation (gis:Delegation)
hasDelegation.delegatedBy.@type	-	1	HealthcareProfessional (gis:HealthcareProfessional)
hasDelegation.delegatedBy.uzi	gis:uzi	1	UZI-nummer van de zorgverlener, overeenkomend met de issuer DID
hasDelegation.delegatedBy.roleCode	gis:roleCode	1	UZI-rolcode van de zorgverlener, overeenkomend met de issuer DID
hasDelegation.scope.@type	-	1	DelegationScope (gis:DelegationScope)
hasDelegation.scope.authorizationRule	gis:authorizationRule	1	URI van de autorisatieregel waarbinnen het mandaat is uitgegeven
hasDelegation.scope.authorizedActions	gis:authorizedActions	1..*	Toegestane acties binnen de autorisatieregel

Alle velden in de tabel zijn gescopet op credentialSubject.

Aanvullende validatieregels (naast sectie 10.6.2):

- Het pastype in de issuer DID MOET Z zijn
- De expirationDate MOET voor of op de expires datum van de signing key liggen

Scope: de waarden voor authorizationRule en authorizedActions worden bepaald door het toepasselijke afspraakstelsel. Welke waarden geldig zijn is nog niet vastgesteld (zie OV-012, OV-013).

10.6.5 PatientEnrollmentCredential

Bewijst dat een patient is ingeschreven bij een zorginstelling. Dit is de VC-tegenhanger van het AORTA SAML inschrijftoken. Het credential wordt ondertekend door een zorgverlener of medewerker op naam die de BSN-validatie heeft uitgevoerd.

VC type: ["VerifiableCredential", "PatientEnrollmentCredential"]

Issuer: did:x509 van de zorgverlener of medewerker die het credential ondertekent

Subject: did:web van de zorginstelling

Vereist pastype: Z (zorgverlenerspas) of N (medewerkerspas op naam)

Trust anchors: PKIoverheid intermediate CAs voor UZI-zorgverleners- en medewerkerspassen, of toekomstige GIS-VN intermediate CAs

Veld	IRI	Card.	Beschrijving

id	-	1	did:web van de zorginstelling
@type	-	1	Organization (gis:Organization)
ura	gis:ura	1	URA-nummer van de zorginstelling
hasEnrollment.@type	-	1	PatientEnrollment (gis:PatientEnrollment)
hasEnrollment.patient.@type	-	1	Patient (gis:Patient)
hasEnrollment.patient.bsn	gis:bsn	1	BSN van de patient
hasEnrollment.enrolledBy.@type	-	1	HealthcareWorker (gis:HealthcareWorker)
hasEnrollment.enrolledBy.uzi	gis:uzi	1	UZI-nummer van de uitvoerder, overeenkomend met de issuer DID

Alle velden in de tabel zijn gescopet op credentialSubject.

Het type HealthcareWorker wordt hier gebruikt ongeacht of de uitvoerder een zorgverlener (pastype Z) of medewerker op naam (pastype N) is. Aangezien HealthcareProfessional een subtype is van HealthcareWorker, past dit in beide gevallen. De rolcode is niet relevant voor de inschrijving en wordt daarom niet opgenomen.

Aanvullende validatieregels (naast sectie 10.6.2):

- Het pastype in de issuer DID MOET Z of N zijn
- De geldigheid van het credential is maximaal 18 maanden (conform het huidige AORTA beleid voor inschrijftokens)

Het CRL-beleid voor inschrijftokens wordt afgehandeld door de generieke key-resolutie (sectie 10.4.3): de key wordt geresolveerd op basis van de issuanceDate van het credential. Als de key op dat moment geldig was en niet was ingetrokken, is de handtekening geldig, ook als de key later is ingetrokken.

10.6.6 ServiceProviderCredential

Bewijst dat een dienstverlener is toegelaten tot het stelsel. Dit credential wordt uitgegeven door de stelselhouder.

VC type: `["VerifiableCredential", "ServiceProviderCredential"]`

Issuer: did:web van de stelselhouder (eventueel did:x509 indien de stelselhouder een X.509-gebaseerde identiteit gebruikt)

Subject: did:web van de dienstverlener

Veld	IRI	Card.	Beschrijving
id	-	1	did:web van de dienstverlener
@type	-	1	ServiceProvider (gis:ServiceProvider)
name	schema:name	1	Naam van de dienstverlener
services	gis:services	1..*	Lijst van diensten waarvoor de dienstverlener is toegelaten. Initieel wordt de waarde twiinGtK gebruikt om aan te geven dat de dienstverlener een Twiin-knooppunt opereert. Andere waarden worden gedefinieerd naarmate het stelsel groeit

Alle velden in de tabel zijn gescopet op credentialSubject.

Aanvullende validatieregels (naast sectie 10.6.2):

- De issuer MOET de stelselhouder zijn
- Indien de issuer een did:web is, MOET de signing key voorkomen in de assertionMethod van het issuer DID-document
- Het credential is geldig zolang de stelseltoelating van de dienstverlener geldig is

Opmerking: in de interimfase (zie sectie 8.3.2) kan de stelseltoelating worden vastgesteld op basis van PKIoverheid certificaten in combinatie met een allow-list in plaats van een expliciet credential.

10.6.7 ServiceProviderDelegationCredential

Bewijst dat een zorginstelling de dienstverlener machtigt om namens haar op te treden. De zorginstelling geeft dit credential uit aan de dienstverlener.

VC type: `["VerifiableCredential", "ServiceProviderDelegationCredential"]`

Issuer: did:web van de zorginstelling

Subject: did:web van de dienstverlener

Veld	IRI	Card.	Beschrijving
id	-	1	did:web van de dienstverlener
@type	-	1	ServiceProvider (gis:ServiceProvider)
hasDelegation.@type	-	1	Delegation (gis:Delegation)
hasDelegation.delegatedBy.@type	-	1	Organization (gis:Organization)
hasDelegation.delegatedBy.ura	gis:ura	1	URA-nummer van de delegerende zorginstelling
hasDelegation.scope.@type	-	1	DelegationScope (gis:DelegationScope)
hasDelegation.scope.authorizationRule	gis:authorizationRule	1	URI van de autorisatieregel waarbinnen de delegatie geldt
hasDelegation.scope.authorizedActions	gis:authorizedActions	1..*	Toegestane acties, MOET een subset zijn van de services in het ServiceProviderCredential van de dienstverlener

Alle velden in de tabel zijn gescopet op credentialSubject.

Aanvullende validatieregels (naast sectie 10.6.2):

- De issuer MOET een did:web zijn van een zorginstelling met een geldig HealthcareOrganizationCredential
- De authorizedActions MOETEN een subset zijn van de services in het ServiceProviderCredential van de dienstverlener

Scope: de waarden voor authorizationRule en authorizedActions worden bepaald door het toepasselijke afspraakstelsel. Welke waarden geldig zijn is nog niet vastgesteld (zie OV-012, OV-013, OV-014).

10.7 Verifiable Presentations

10.7.1 Overzicht

Een Verifiable Presentation (VP) is een door de holder ondertekend pakket van een of meer Verifiable Credentials. De VP bindt de credentials aan een specifieke context (audience) en bewijst dat de holder beschikt over het sleutelmateriaal dat bij de credentials hoort.

Bij een token request worden twee VPs aangeboden, gegroepeerd op subject (zie sectie 8.4.1):

VP 1 -- Zorginstelling: bevat de credentials die over de zorginstelling gaan. Ondertekend met sleutelmateriaal van de zorginstelling (did:web).

Credential	Altijd aanwezig
HealthcareOrganizationCredential	Ja
HealthcareProfessionalDelegationCredential	Ja
PatientEnrollmentCredential	Afhankelijk van de toepassing

VP 2 -- Dienstverlener: bevat de credentials die over de dienstverlener gaan. Ondertekend met sleutelmateriaal van de dienstverlener (did:web).

Credential	Altijd aanwezig
ServiceProviderCredential	Ja
ServiceProviderDelegationCredential	Ja

Deze groepering volgt het standaard VP-model: de issuer van de VP is het subject van de credentials in die VP. Dit voorkomt dat een partij credentials presenteert die over een andere partij gaan zonder dat die andere partij daar cryptografisch aan meewerkt.

10.7.2 Structuur

Een VP in dit stelsel MOET in JWT-encoding zijn. De JWT bevat de volgende claims:

- `iss`: de DID van de holder (ondertekende partij)
- `aud`: de audience waarvoor de VP bestemd is (zie sectie 10.7.3)
- `vp`: het VP-object met daarin:
  - `@context: ["https://www.w3.org/2018/credentials/v1"]`
  - `type: ["VerifiablePresentation"]`
  - `verifiableCredential`: een lijst van credentials in JWT-encoding

De VP JWT MOET ondertekend zijn met een sleutel uit de authentication verification relationship van het DID-document van de holder (sectie 10.4.1). De gebruikte sleutel MOET verschillen van de sleutel in assertionMethod (AUTH-015).

10.7.3 Audience binding

De VP wordt gebonden aan de ontvangende partij via het aud claim in de JWT. De waarde van aud MOET de issuer identifier van de authorization server zijn waarnaar het token request wordt gestuurd (sectie 8.5.3).

Voorbeeld: indien het token request wordt gestuurd naar de AS met issuer identifier `https://as.dienstverlener.nl/ura/12345678`, dan MOET `aud` in beide VPs deze waarde bevatten.

De audience binding voorkomt dat een onderschepte VP kan worden hergebruikt bij een andere authorization server.

10.7.4 Brede bevragingen en audience binding

Probleem

In het LSP-model doet een raadpleger een enkel verzoek aan het LSP, waarna het LSP lokaliseert, alle relevante bronhouders bevraagt, en de resultaten samengevoegd terugstuurt. De raadpleger weet niet welke bronhouders worden bevraagd -- dit is bewust transparant (HAR-010).

Dit conflicteert met de audience binding uit sectie 10.7.3: als de audience in de VP gebonden is aan de AS van een specifieke bronhouder, moet de raadpleger vooraf weten welke bronhouders er zijn en voor elke bronhouder een afzonderlijke VP maken. Dat doorbreekt de transparantie van het LSP-model.

Oplossing

Er zijn twee oplossingen die naast elkaar kunnen bestaan. De keuze hangt af van de fase en de mate van wallet-adoptie bij de achterliggende zorginstellingen.

Optie 1: het LSP beheert de wallet

Het LSP beheert als dienstverlener de volledige wallet voor de bij het LSP aangesloten zorginstellingen. Het LSP heeft directe toegang tot de credentials en het sleutelmateriaal van de zorginstelling, en kan zelfstandig VPs samenstellen met de juiste audience voor elke bronhouder.

Deze optie is met name interessant in de eerste fase van het stelsel, omdat er geen afhankelijkheid is van de achterliggende leveranciers voor het beschikbaar hebben van een wallet-implementatie.

Optie 2: herverpakking via gedeelde keys

De zorginstelling beheert haar eigen wallet en maakt een VP met als audience de dienstverlener (het LSP). Het LSP ontvangt de VP, valideert deze, en pakt de credentials uit. Voor elke bronhouder die bevraagd moet worden, verpakt het LSP de credentials opnieuw in een nieuwe VP met de juiste audience (de AS van de betreffende bronhouder).

Dit is mogelijk doordat het DID-document van de zorginstelling naast de eigen authentication key ook een key bevat die wordt beheerd door het LSP. De nieuwe VP wordt ondertekend met deze key. De bronhouder valideert de VP en ziet dat de signing key voorkomt in de authentication relationship van het DID-document van de zorginstelling. De VP is geldig, ondanks dat deze niet door de zorginstelling zelf is ondertekend.

De credentials zelf blijven ongewijzigd; alleen de VP-verpakking verandert.

Beide opties zijn in lijn met AUTH-014: de holder bepaalt welke credentials worden gepresenteerd en aan wie. Bij optie 1 is deze bevoegdheid operationeel gedelegeerd aan het LSP via het wallet-beheer. Bij optie 2 geeft de zorginstelling expliciet toestemming door de key van het LSP op te nemen in haar DID-document.

Relatie met de wallet-architectuur

Deze inrichting past bij de wallet-architectuur uit sectie 8.4.2: de zorginstelling is juridisch eigenaar van de wallet, maar het operationeel beheer kan bij de dienstverlener liggen. De key in het DID-document is de technische uitdrukking van deze delegatie.

10.7.5 Validatie

De authorization server valideert een ontvangen VP door de volgende stappen uit te voeren:

1. Verifieer de JWT-handtekening van de VP met de publieke sleutel uit het DID-document van de holder
2. Controleer dat de signing key voorkomt in de authentication relationship van het DID-document
3. Controleer dat het aud claim overeenkomt met de eigen issuer identifier van de AS
4. Controleer dat de iss claim overeenkomt met het credentialSubject.id van de credentials in de VP
5. Controleer dat de exp en nbf velden kloppen met het moment van validatie
6. Valideer elk credential in de VP conform de generieke (sectie 10.6.2) en credential-specifieke validatieregels

10.8 Revocation

10.8.1 Overzicht

Dit stelsel kent twee mechanismen voor het intrekken van credentials:

- **CRL (Certificate Revocation List)**: voor credentials met een did:x509 issuer. De revocation status wordt bepaald tijdens DID-resolutie en is beschikbaar als revoked veld op de key in het DID-document (sectie 10.4.2). Dit mechanisme wordt beheerd door de certificaatautoriteit (UZI-register) en valt buiten de scope van dit hoofdstuk.
- **StatusList2021**: voor credentials met een did:web issuer en voor langlopende credentials waar intrekking los van de certificaat-levenscyclus nodig is.

10.8.2 Toepasselijkheid

Credential	Revocation-mechanisme	Toelichting
HealthcareOrganizationCredential	CRL (via key-resolutie)	Intrekking volgt de levenscyclus van het servercertificaat
HealthcareProfessionalDelegationCredential	StatusList2021	Intrekking nodig wanneer de zorgverlener de organisatie verlaat, onafhankelijk van de certificaatgeldigheid
PatientEnrollmentCredential	CRL (via key-resolutie)	Geldigheid beperkt tot 18 maanden; intrekking bij vertrek patient is operationeel proces
ServiceProviderCredential	StatusList2021	Stelselhouder kan toelating intrekken
ServiceProviderDelegationCredential	StatusList2021	Zorginstelling kan delegatie intrekken

10.8.3 StatusList2021

Werking

StatusList2021 is een mechanisme waarbij de issuer van een credential een bitstring publiceert als Verifiable Credential. Elke bit in de string correspondeert met een credential. Een bit met waarde 0 betekent "niet ingetrokken", een bit met waarde 1 betekent "ingetrokken". De bitstring wordt gecomprimeerd met GZIP om de omvang te beperken.

Het credential dat intrekbaar is bevat een verwijzing naar de status list:

- `credentialStatus.type`: StatusList2021Entry
- `credentialStatus.statusPurpose`: revocation
- `credentialStatus.statusListIndex`: de positie van de bit in de lijst
- `credentialStatus.statusListCredential`: de URL waar de status list credential te vinden is

De verifier haalt de status list credential op, decomprimeert de bitstring en controleert de bit op de opgegeven index.

Status list credential

De status list zelf wordt gepubliceerd als een Verifiable Credential van type StatusList2021Credential. Dit credential:

- MOET in JWT-encoding zijn
- MOET ondertekend zijn door dezelfde issuer als het credential waarnaar het verwijst
- MOET beschikbaar zijn op een HTTPS endpoint
- MOET het veld credentialSubject.type bevatten met waarde StatusList2021
- MOET het veld credentialSubject.statusPurpose bevatten met waarde revocation
- MOET het veld credentialSubject.encodedList bevatten: de GZIP-gecomprimeerde, base64-gecodeerde bitstring

Caching

Verifiers MOGEN de status list credential cachen. De issuer MOET HTTP cache headers meegeven die aangeven hoe lang de status list geldig is. De maximale cache-duur is afhankelijk van het risicoprofiel:

- ServiceProviderCredential: maximaal 24 uur
- ServiceProviderDelegationCredential: maximaal 24 uur
- HealthcareProfessionalDelegationCredential: maximaal 24 uur

Kortere cache-duren zijn toegestaan. De issuer bepaalt de juiste balans tussen actualiteit en belasting.

10.8.4 Publicatie en hosting

De issuer van een credential is verantwoordelijk voor het publiceren van de bijbehorende status list. De status list URL wordt opgenomen in het credential zelf (via credentialStatus.statusListCredential) en MOET een HTTPS endpoint zijn.

Voor credentials met een did:web issuer (ServiceProviderCredential, ServiceProviderDelegationCredential) is de hosting eenvoudig: de issuer publiceert de status list op een eigen endpoint.

Hosting bij did:x509 issuers

Bij credentials met een did:x509 issuer beschikt de issuer doorgaans niet over een eigen server om een status list te hosten. De partij die de tooling levert voor het aanmaken van het credential (momenteel EAT Europe) host de status list namens de issuer.

In de huidige inrichting kan alleen de issuer zelf -- de houder van de UZI-pas -- een credential intrekken. De intrekking wordt geauthenticeerd met dezelfde pas waarmee het credential is uitgegeven.

Dit model kent een aantal beperkingen die latere uitwerking vragen:

- De zorginstelling kan een credential niet intrekken wanneer een medewerker de organisatie verlaat, ook niet in een conflictsituatie
- Indien de UZI-pas is verlopen, ingetrokken of verloren, kan de issuer geen intrekking meer uitvoeren terwijl er nog geldige credentials in omloop kunnen zijn
- Het is onduidelijk wie de intrekkingsbevoegdheid krijgt wanneer de oorspronkelijke issuer niet meer beschikbaar is

Deze vraagstukken raken de governance van het stelsel en worden in een volgende fase uitgewerkt.

10.8.5 Verificatie

Bij verificatie van een credential dat een credentialStatus veld bevat, MOET de verifier de volgende stappen uitvoeren:

1. Haal de status list credential op van de URL in credentialStatus.statusListCredential, of gebruik een gecachte versie indien de cache nog geldig is
2. Verifieer de handtekening van de status list credential
3. Controleer dat de issuer van de status list credential overeenkomt met de issuer van het te verifieren credential
4. Decomprimeer de bitstring uit credentialSubject.encodedList
5. Lees de bit op de positie aangegeven door credentialStatus.statusListIndex
6. Indien de bit waarde 1 heeft: het credential is ingetrokken en MOET worden geweigerd

Indien de status list credential niet opgehaald kan worden (netwerk fout, endpoint niet beschikbaar), MOET de verifier het credential weigeren. Dit voorkomt dat een aanvaller door het onbereikbaar maken van de status list ingetrokken credentials kan hergebruiken.

10.9 OAuth-profiel

10.9.1 Overzicht

Het OAuth-profiel in dit stelsel is gebaseerd op RFC 7523 (JWT Profile for OAuth 2.0 Client Authentication and Authorization Grants) in combinatie met Verifiable Presentations. Het profiel onderscheidt twee rollen in het token request:

- **Client**: de dienstverlener, die zich authenticert via een client assertion (VP 2)
- **Subject**: de zorginstelling, namens wie het verzoek wordt gedaan, die haar bevoegdheden presenteert via een authorization grant (VP 1)

Dit onderscheid is essentieel omdat de partij die het technische verzoek doet (de dienstverlener) niet dezelfde is als de partij die de bevoegdheid heeft (de zorginstelling). Zie sectie 8.5.1.

De flow is back-channel: er is geen user-agent redirect (OAUTH-004). Het token request gaat rechtstreeks van de client naar de authorization server van de bronhouder.

10.9.2 Scope-model

Het token request bevat een scope die uit twee lagen bestaat:

Use-case scope

De use-case scope selecteert welk autorisatiebeleid van toepassing is en welke credentials de authorization server verwacht. Voorbeelden van use-case scopes zijn "medicatie", "BgZ" of "eOverdracht".

De use-case scope bepaalt:

- Welke credentials verplicht zijn in de presentatie (bv. wel of geen PatientEnrollmentCredential)
- Welk autorisatiebeleid de AS toepast bij het beoordelen van het verzoek
- Welke resource scopes beschikbaar zijn binnen deze use case

De use-case scope wordt uitgedrukt als een identifier. De waarden hiervan zijn nog niet definitief vastgesteld en hangen samen met de scope-architectuur die wordt beschreven in sectie 8.5.5 en de onderzoeksvragen OV-012, OV-013 en OV-014.

Resource scope

De resource scope specificeert welke concrete resources worden opgevraagd. Voor FHIR-gebaseerde uitwisselingen wordt het SMART-on-FHIR scope-formaat gebruikt (OAUTH-009), bijvoorbeeld patient/MedicationRequest.read.

De resource scope wordt gevalideerd door de AS tegen de bevoegdheden in de gepresenteerde credentials (rolcode, authorizedActions) en tegen de use-case scope.

Samenhang

Bij een token request worden beide scope-niveaus gecombineerd. Voorbeeld:

```
scope=usecase:medicatie patient/MedicationRequest.read
patient/MedicationDispense.read
```

Hierbij is usecase:medicatie de use-case scope die het autorisatiebeleid selecteert, en de overige waarden zijn SMART-on-FHIR resource scopes.

10.9.3 Token endpoint

Het token endpoint van de AS is adresseerbaar per URA. De URL-structuur volgt het patroon uit sectie 8.5.3:

https://as.dienstverlener.nl/ura/12345678/token

Het token endpoint wordt gepubliceerd in de AS metadata (sectie 10.9.4).

10.9.4 AS metadata

De authorization server publiceert metadata conform RFC 8414. De metadata is beschikbaar op het .well-known pad dat wordt afgeleid van de issuer identifier:

Issuer: https://as.dienstverlener.nl/ura/12345678
Metadata: https://as.dienstverlener.nl/.well-known/oauth-authorization-server/ura/12345678

Het metadata-document MOET minimaal de volgende velden bevatten:

- issuer: de issuer identifier van de AS, inclusief het URA-pad
- token_endpoint: de URL van het token endpoint
- grant_types_supported: MOET urn:ietf:params:oauth:grant-type:jwt-bearer bevatten (RFC 7523)
- token_endpoint_auth_methods_supported: MOET private_key_jwt bevatten
- token_endpoint_auth_signing_alg_values_supported: MOET de algoritmen uit sectie 10.3.1 bevatten
- dpop_signing_alg_values_supported: MOET ES256 bevatten (sectie 10.3.3)
- delegation_presentation: een Verifiable Presentation (JWT) waarmee de zorginstelling de delegatie aan deze AS bewijst (zie sectie 10.9.5)

RFC 8414 staat uitbreiding van het metadata-document met extra velden toe. Clients die het veld delegation_presentation niet kennen MOETEN het negeren conform de specificatie.

10.9.5 Verificatie van de delegatierelatie

Probleem

In dit stelsel wordt (m)TLS uitsluitend gebruikt voor transportbeveiliging op netwerklaag, niet voor het authenticeren van partijen. Een client die een token request stuurt naar een AS heeft daardoor geen TLS-gebaseerde garantie dat de AS daadwerkelijk opereert namens de zorginstelling waarmee het wil communiceren. Het adresboek (Care Services Directory) wordt hiervoor niet als een voldoende vertrouwde bron beschouwd.

De client heeft een cryptografisch bewijs nodig dat de zorginstelling de AS heeft gedelegeerd aan de dienstverlener die de AS opereert.

Oplossing

De zorginstelling maakt een Verifiable Presentation met daarin het ServiceProviderDelegationCredential en het HealthcareOrganizationCredential. Het HealthcareOrganizationCredential is nodig zodat de client kan verifieren dat de zorginstelling achter het URA-nummer in de delegatie daadwerkelijk de issuer van de VP is. De audience van deze VP is de issuer identifier van de AS zelf. De AS publiceert deze VP in het OAuth metadata-document onder het veld delegation_presentation.

De client voert de volgende stappen uit voordat het een token request stuurt:

1. Haal het OAuth metadata-document op via RFC 8414 discovery
2. Extraheer de delegation_presentation uit het metadata-document
3. Valideer de VP: controleer de handtekening, audience en geldigheid
4. Controleer dat het HealthcareOrganizationCredential het URA-nummer bevat dat overeenkomt met het URA in de issuer identifier van de AS
5. Controleer dat het ServiceProviderDelegationCredential in de VP is uitgegeven door de zorginstelling aan de dienstverlener die de AS opereert
6. Pas na succesvolle validatie wordt het token request verstuurd

Dit mechanisme waarborgt dat de client alleen tokens aanvraagt bij een AS die aantoonbaar gemachtigd is door de betreffende zorginstelling (AUTH-024, OAUTH-013).

10.9.6 Token request

Het token request wordt gestuurd als HTTP POST naar het token endpoint met application/x-www-form-urlencoded encoding.

Parameters:

Parameter	Waarde	Beschrijving
grant_type	urn:ietf:params:oauth:grant-type:jwt-bearer	RFC 7523 grant type
assertion	VP 1 (JWT)	Verifiable Presentation van de zorginstelling met de authorization grant credentials
client_assertion_type	urn:ietf:params:oauth:client-assertion-type:jwt-bearer	RFC 7523 client assertion type
client_assertion	VP 2 (JWT)	Verifiable Presentation van de dienstverlener met de client credentials
scope	string	Use-case scope en resource scopes, spatie-gescheiden

Daarnaast MOET het request een DPoP proof bevatten in de DPoP HTTP header conform RFC 9449. De DPoP proof MOET ondertekend zijn met ES256 (sectie 10.3.3).

Verwerking door de AS

De AS verwerkt het token request in de volgende volgorde (zie ook sectie 8.4.3):

1. Valideer VP 2 (dienstverlener): controleer stelseltoelating via ServiceProviderCredential en delegatie via ServiceProviderDelegationCredential
2. Valideer VP 1 (zorginstelling): controleer identiteit via HealthcareOrganizationCredential
3. Controleer de use-case scope en bepaal welke aanvullende credentials vereist zijn
4. Valideer de aanvullende credentials (PatientEnrollmentCredential, HealthcareProfessionalDelegationCredential) indien vereist door het autorisatiebeleid
5. Controleer dat de gevraagde resource scopes passen binnen de bevoegdheden uit de credentials
6. Valideer de DPoP proof
7. Geef een access token uit

VP-validatie

Bij de validatie van de VPs in het token request controleert de AS aanvullend:

- De jti claim van elke VP MOET uniek zijn. De AS MOET een lijst van ontvangen jti waarden bijhouden binnen een tijdvenster en VPs met een eerder gebruikte jti weigeren. Dit voorkomt replay attacks.
- De exp (expiration) claim van elke VP MOET aanwezig zijn en in de toekomst liggen. Het tijdvenster waarbinnen de AS jti waarden bijhoudt MOET minimaal gelijk zijn aan de maximale levensduur van een VP.
- De aud claim MOET overeenkomen met de issuer identifier van de AS (sectie 10.7.3).

10.9.7 Token response

Bij een succesvol token request retourneert de AS:

```
{
  "access_token": "<opaque token>",
  "token_type": "DPoP",
  "expires_in": 300,
  "scope": "<gehonoreerde scopes>"
}
```

Het access token is opaque: het bevat geen leesbare claims voor de client. De resource server haalt de claims op via token introspectie bij de AS.

Het access token is gebonden aan de DPoP-sleutel (OAUTH-010).

10.9.8 Token gebruik

Bij elk verzoek aan de resource server MOET de client het access token en een verse DPoP proof meesturen. De DPoP proof MOET ondertekend zijn met dezelfde sleutel als bij het token request.

Het verzoek aan de resource server bevat:

- De Authorization header met waarde DPoP <access_token>
- De DPoP header met een verse DPoP proof (JWT) conform RFC 9449

De DPoP proof in het resource request MOET de volgende claims bevatten:

- htm: de HTTP-methode van het verzoek (bv. GET)
- htu: de URL van het resource endpoint
- iat: het tijdstip van aanmaak van de proof
- jti: een unieke identifier voor de proof

De resource server MOET controleren dat de DPoP proof geldig is en dat de publieke sleutel in de proof overeenkomt met de cnf claim uit de token introspectie-response (sectie 10.9.9).

10.9.9 Token introspectie

De resource server valideert het access token via token introspectie bij de AS conform RFC 7662. De introspectie-response bevat de claims die de RS nodig heeft om het autorisatiebesluit te nemen, waaronder:

- active: boolean, of het token geldig is
- scope: de gehonoreerde scopes

- ura: het URA-nummer van de zorginstelling
- cnf: de DPoP-sleutel confirmatie (voor binding-validatie)

Aanvullende claims (UZI-nummer, rolcode, BSN) worden opgenomen afhankelijk van de use-case scope en de gepresenteerde credentials. De RS MOET controleren dat de DPoP proof bij het resource request overeenkomt met de cnf claim in de introspectie-response.

10.9.10 Foutafhandeling

Bij fouten in het token request retourneert de AS een error response conform RFC 6749 sectie 5.2.

Naast de standaard OAuth error codes definieert dit stelsel de volgende aanvullende error codes:

Error code	Beschrijving
invalid_presentation	Een of beide VPs zijn ongeldig (handtekening, structuur, audience)
invalid_credential	Een credential in de VP is ongeldig (verlopen, ingetrokken, issuer niet vertrouwd)
missing_credential	Een credential dat vereist is door het autorisatiebeleid ontbreekt in de VP
insufficient_scope	De gevraagde scope past niet binnen de bevoegdheden uit de credentials
invalid_delegation	De delegatierelatie tussen dienstverlener en zorginstelling is ongeldig of ontbreekt

De error response MOET een error_description veld bevatten met een menselijk leesbare toelichting. De AS MAG GEEN details over de interne autorisatielogica of de inhoud van credentials van de bronhouder opnemen in de error response, om informatielekken te voorkomen.

10.10 Adressering

- Mapping van mCSD-resources naar het geharmoniseerde model
- Endpoint-types en payload types
- Relatie Endpoint-resource naar OAuth AS issuer identifier

10.11 Voorbeelden

Uitgewerkte voorbeelden van de volledige flow:

- Voorbeeld JWT-encoded HealthcareOrganizationCredential
- Voorbeeld ServiceProviderDelegationCredential
- Voorbeeld token request met twee VPs
- Voorbeeld AS metadata document